Combined US Operations of Banco Santander, S.A.

Technology



Windows Servers Hardening Guide

DOCUMENT HISTORY AND VERSION CONTROL

Ownership and Authorship

Version	Date	Author	Owner	Change
1.0	12/16/2022	Victor Fallas	Scott Cain	Initial version – Uplifted to SanUS
2.0	6/20/2023	Victor Fallas	Scott Cain	Out of cycle review to move 9 ADFS rules (4.2.3 – 4.2.10 & 4.4.1) to Out of Scope and 4 virtualization based rules (18.8.5.2, 18.8.5.3, 18.8.5.6, 18.8.5.7) moved to Out of Scope. In Scope Rules 2.5.5.5 & 2.3.6.4 updated language. Compliance date changed from March 31st to July 31st.
3.0	9/15/2023	Victor Fallas	Scott Cain	Moved 5 EMET rules from In Scope to In Scope Non-Measurable
4.0	7/15/2024	Victor Fallas	Scott Cain	Moved Rule 4.1.43 from In Scope to Out of Scope for Domain Controllers only Updated to align with latest Benchmark CIS Microsoft Windows Server 2022 Benchmark v2.0.0 - 04-14-2023
5.0	8/20/2025	Sr. Director Infrastructure Operations	Santander US Head of Infrastructure Operations	Updated to align with Global Guide. Added Note to Scope section about Citrix Moved PowerShell control to Out of Scope – Local #91 Moved Hkey Controls to In Scope Non Measurable
6.0	9/17/2026	Santander US Security Compliance Configuration Team	Santander US Director, Information Security, Head of Infrastructure Security	Updated to align with Global Guide. Controls moved to In Scope Non Measurable & Out of Scope

Sign Off

Role / Function	Action	Date
Technology Policy Administration Team	Review	9/17/2026
Santander US Chief Information Security Officer (“CISO”)	Approve	9/17/2026

TABLE OF CONTENTS

DOCUMENT HISTORY AND VERSION CONTROL 2
Ownership and Authorship 2
Sign Off 2
1 INTRODUCTION 4
1.1 Purpose of this Document 4
1.2 Scope 4
1.3 Out of Scope 4
2 CONTROL AND MONITORING 5
3 GOVERNANCE/OVERSIGHT 5
4 SANTANDER GROUP HARDENING: WINDOWS SERVER 6
4.1 Services 6
4.2 Account Lockout Policy 7
4.3 Password Policy 8
4.4 User Rights Assignment 10
4.5 Security Options 15
4.6 Windows Components - WDigest Authentication 25
4.7 Audit Policies - Account Logon 25
4.8 Audit Policies - Account Management 26
4.9 Audit Policies - Detailed Tracking 26
4.10 Audit Policies - Logon-Logoff 27
4.11 Audit Policies - Policy Change 27
4.12 Audit Policies - Privilege Use 28
4.13 Audit Policies – System 28
4.14 Object Access 29
4.15 Administrative Templates (Computer) 30
4.16 Member Server configuration 37
4.17 Domain Controller configuration 39
4.18 Administrative Templates (User) 40
4.19 External Regulatory Requirements 40
4.2 ACTIVE DIRECTORY 43
4.2.1 Active Directory Audit Policies 43
4.2.2 Active Directory Specific requirements 44
External Regulatory Requirements 47
4.3 ADFS 48
4.3.1 ADFS Initial System Configuration 48
4.3.2 ADFS Local Policies 56
4.3.3 Protection against brute force attacks and user account lockout 57
4.3.4 ADFS Certificates installation and specifications 58
4.3.5 Endpoint of ADFS 58
4.3.6 ADFS Encryption 58
5 CUSO ADDITIONS / EXCEPTIONS 61
5.1 CUSO Controls In Scope Measurable 61
5.2 In Scope Non – Measurable 61
5.3 CUSO Out of Scope 64
6 RELATED AND SOURCE DOCUMENTS 156
6.1 Related Documents 156
6.2 Source Documents 156
7 SUBSIDIARY ENDORSEMENT 156
8 SANTANDER GROUP ANNEX I: RULES CHECKLIST 157
Windows Server 157
External Regulatory Requirements 181
SOX Policy 183
Active Directory 185
External Regulatory Requirements 188
ADFS 189

1 INTRODUCTION

1.1 Purpose of this Document

The Windows Server Hardening Guide (this “Hardening Guide”) provides an overview of the mandatory security configuration for the Windows Servers residing physically in Combined US Operations of Banco Santander, S.A. (“CUSO”), including the business units operating through Santander Holdings USA, Inc. (“SHUSA”) and its subsidiaries (individually, “Subsidiary,” collectively, “Subsidiaries,” and together with SHUSA, “Santander US”) and the Banco Santander, S.A. New York Branch (“BSNY”) data centers, that are managed by Infrastructure Operations within Technology.

1.2 Scope

This Hardening Guide contains the set of recommendations for Windows Servers versions 2016, 2019 and 2022, and the goal is to secure the Windows Server environment and follow the best security practices to build a solid foundation and execute workloads.

In addition, this Hardening Guide includes the recommendations to the different roles available for Windows Servers, such as Active Directory or ADFS (Active Directory Federation Services).

Subsidiaries are not required to separately approve, but must endorse this Hardening Guide, as this subject matter is managed centrally by the SHUSA Technology Function. The Microsoft Windows Server Hardening Guide applies to all supported Windows servers, Active Directory or ADFS servers, located in either the US or Mexico. Also in scope are those servers with the status of “Deployed and Being Assembled”.

1.3 Out of Scope

The Center for Internet Security (“CIS”) rules that are considered “Out of Scope” are those rules that are not applicable to our IT infrastructure environment due to:

- Conflicts with other technical standards
- Application functionalities
- Technical designs
- Overlaps with other hardening rules covered by other guides (like OS hardening)
- Operational impact

The Windows Server administrator should review the Out of Scope section carefully before deploying new databases. From the Out of Scope rules, only rules do not apply to new servers that should be considered when deploying new Windows Servers.

2 CONTROL AND MONITORING

2.1 Controls

All employees responsible for installing and deploying the Windows servers are required to first learn the rules within this document and then to use this document and the other corresponding Window Server documents to maintain the controls that are described in the documents.

This Hardening Guide will be published and available for viewing by all Santander's workforce on the Corporate Governance Website. The asset owners are responsible for ensuring that this Hardening Guide is enforced and implemented.

2.2 Monitoring

IT Infrastructure will compile and maintain the reporting metrics summarizing the hardening of all of the Window Servers. The Key Performance Indicator ("KPI") report is used to evaluate current hardening levels of all systems. These KPIs are presented in the monthly Technology Infrastructure Monthly Operating Review ("MOR") meeting and the monthly Technology and Operations Executive Working Group ("T&O EWG"). The report is accessible to all Bank business Lines for review every month.

3 GOVERNANCE/OVERSIGHT

This Hardening Guide is approved by the Santander US Chief Information Security Officer ("CISO") and reviewed, owned and approved by the Santander US Director, Information Security, Head of Infrastructure Security.

This Hardening Guide is reviewed annually or when a material change to the operating environment, potential changes to regulations and contractual requirements, potential findings, or requested policies exceptions necessitate an out of cycle review, following the Santander US Process and Administrative Document Approval Procedure.

4 SANTANDER GROUP HARDENING: WINDOWS SERVER

4.1 Services

Policy Name	Description	Recommended Value
Status of the 'MSS: (DisableIPSourceRoutingIPv6) IP source routing protection level (protects against packet spoofing)' setting	The 'MSS: (DisableIPSourceRoutingIPv6) IP source routing protection level (protects against packet spoofing)' setting is intended to provide protection against source-routing spoofing on [multi-homed] Microsoft-based systems, which have at least two valid network interface devices enabled and connected. (All Microsoft-based systems having more than one valid networking device enabled can be used as a router or firewall between network segments, whether this is intended or not.) As a vulnerability exists, that could allow a malicious user to circumvent routing rules by 'spoofing' the device to make it look like malicious or invalid traffic was sent from the protected side, this should be disabled/restricted according to the needs of the business. NOTE: To configure the system to drop all source routed packets set the value of this parameter to 2. The registry key for MSS: (DisableIPSourceRoutingIPv6) must be created in the Windows registry tree (HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip6\Parameters\DisableIPSourceRouting) for this control to work properly.	Highest protection, source routing is completely disabled
Status of the 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' setting	The 'DisableIPSourceRouting' setting is intended to provide protection against source-routing spoofing on [multi-homed] Microsoft-based systems, that have at least two valid network interface devices enabled and connected. (All Microsoft-based systems having more than one valid networking device enabled can be used as a router or firewall between network segments, whether this is intended or not.) As a vulnerability exists that could allow a malicious user to circumvent routing rules by 'spoofing' the device to make it look like malicious or invalid traffic was sent from the protected side, this should be disabled/restricted. NOTE: To configure the system to drop all source routed packets set the value of this parameter to 2. The registry key for MSS: (DisableIPSourceRouting) must be created in the Windows registry tree (HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\DisableIPSourceRouting) for this control to work properly.	Enabled

4.2 Account Lockout Policy

The following security policies must be configured in: *\Computer Configuration\Windows Settings\Security Settings\Account Policies\Account Lockout Policy*

Policy Name	Description	Recommended Value
Status of the 'Account Lockout Duration' setting (invalid login attempts)	The 'Account Lockout Duration' setting determines the amount of time an account will be locked upon reaching the maximum number of login attempts allowed by the 'Account Lockout Threshold' setting. A user's password can be guessed or broken via repeated attempts to login by using a logical or known account name and changing the password until successful login occurs. If this is set to '0', the account will be locked until an Administrator or the system unlocks it. This policy setting only has meaning when the 'Account Lockout Threshold' setting is specified. In addition, the 'Account Lockout Duration' setting must be set to a value equal to or greater than that which is configured in the 'Reset Account Lockout Counter After' setting. If not, the 'Reset Account Lockout Counter After' settings will not increment any invalid attempts during the time in which the account has been re-enabled and when the counter is reset.	15
Status of the 'Account Lockout Threshold' setting (invalid login attempts)	The 'Account Lockout Threshold' parameter determines the number of invalid login attempts allowed before an account will be 'locked.' The 'Account Lockout Duration' parameter must be set to a value equal to or greater than that which is configured in the 'Reset Account Lockout Counter After' setting. If it is not set, the 'Reset Account Lockout Counter After' setting will not increment any invalid login attempts during the time in which the account has been re-enabled and when the counter is reset. As user passwords can be guessed or broken via repeated attempts to login by using a logical or known account name and launching a brute-force attack on the password until successful login occurs.	5
Status of the 'Reset Account Lockout Counter After' setting	The 'Reset Account Lockout Counter After' setting determines the minimum amount of time that must elapse before an account that has been locked, due to invalid logon attempts, will have its counter reset to zero. If the 'Account Lockout Threshold' setting is not enabled, the 'Account Lockout Counter After' parameter has no effect on the security of the accounts. In addition, the 'Account Lockout Duration' setting must be set to a value equal to or greater than that which is configured in 'Reset Account Lockout Counter After' setting. If not, the 'Reset Account Lockout Counter After' settings will not increment any invalid logon attempts during the time in which the account has been re-enabled and when the counter is reset. As having this parameter set appropriately makes it more difficult for a malicious user to break passwords, when implemented in conjunction with the 'Account Lockout Threshold' setting.	1440 seconds
Status of the 'Allow Administrator account lockout' setting	This policy setting provides the ability to lock out the built-in local Administrator account. Someone who attempts to use more than a few unsuccessful passwords while trying to log on to the system might be a malicious user who is attempting to determine an account password by trial and error. Limiting the number of failed sign-ins that can be performed nearly eliminates the effectiveness of attacks such as Brute force attacks and mitigates the risks	Enabled

	associated with unauthorized access and strengthens the overall security posture of an organization.	

4.3 Password Policy

Among the characteristics that make 'user identification' via password a workable security solution are the following settings and must be configured in *Computer Configuration\Windows Settings\Security Settings\Account Policies\Password Policy\:*

Policy Name	Description	Recommended Value
Status of the 'Enforce password history' setting	Among the characteristics that make 'user identification' via password a secure and workable solution is the 'password history' setting. By requiring that a series of password-choices be unique, not a repetition of something used recently, it reduces the risk of a malicious user breaking the password through dictionary/brute force attacks or fortuitous guessing based upon 'social engineering,' where a user has mentioned that one of his favourite password-creation strategies is such-and-such. With this password history requirement, users who wish to re-use the same password must select new and unique ones for a certain period, before returning to their 'preferred' one. Each time a new password is chosen, it adds to the security value of using a password as a security tool--while no specific 'password history' can guarantee password security, twelve (12) is generally considered to be an adequate number. This, along with requiring other password security factors, such as increasing the variability of the symbol set-space by requiring mixed-cases, as well as other tactics, such as requiring a new password to be chosen every 45 days, further increases the difficulty of breaking any password by brute-force and social-engineering attacks.	10
Status of the 'Minimum Password Length' setting	Among the several characteristics that make 'user identification' via password a secure and workable solution is setting a 'minimum password length' requirement. Each character that is added to the password length squares the difficulty of breaking the password via 'brute force,' which attempts using every combination possible within the password symbol set-space, to discover a user's password. While no 'minimum length' can be guaranteed secure, eight (8) is commonly considered to be the minimum for most application access, along with requiring other password security factors, such as increasing the size of the symbol set-space by requiring mixed-cases, along with other forms of password variability creation, increases the difficulty of breaking any password by brute-force attack.	8
Status of the 'Store passwords using reversible encryption' setting	Microsoft's 'Store passwords using reversible encryption' setting, the original LANMAN encryption scheme, is very vulnerable to cracking, due to its 'standard': It treats all characters as uppercase and truncates anything longer than 14 characters, while padding all shorter passwords up to 14 characters in length with the same padding characters. As using reversible encryption can allow a malicious user to crack the password easily with tools available online, risking the compromise of any credentials copied from the server/workstation or 'sniffed' off the wire	Disabled

	by a malicious user, the use of reversible encryption should be disabled.	
Status of the 'Maximum Password Age' setting (expiration)	One characteristic that makes 'user identification' via password a secure/workable solution is setting a 'password expiration' requirement. Each time a new password is created, replacing one that has been in place for a given period, this resets the difficulty of breaking a password via brute-force to its maximum level.	45
Status of the 'Password Complexity Requirements' setting	Among the several characteristics that make 'user identification' via password a secure and workable solution is setting the 'password complexity' requirement. This makes the selection of mixed-case, numerical, and 'punctuation' symbols mandatory during password creation. This exponentially increases the size of the 'symbol-set' that must be addressed when conducting a brute-force attack. For example, it makes the number of combinations that must be checked to match the correct combination for an eight-character password potentially '8!' or '8 factorial' to the 92nd power, which is up in the 'googol' range of combinations. When coupled with other measures for password security, such as maximum- and minimum-use duration, system lockout after a specified number of invalid attempts, and password-history requirements, 'password complexity' should only permit credentials to be compromised via blind luck, social engineering, or secretly installed keystroke-logging software on the system.	Enabled
Status of the 'Minimum Password Age' setting	Among the characteristics that make 'user identification' via password a workable security solution is setting a 'minimum password age.' Without this minimum age requirement, any user(s) who wish to re-use the same password can merely cycle through a few previously used passwords until returning to the preferred one (this is determined by the 'Password History' setting). While no specific 'minimum password age' can guarantee password security, one (1) day is generally considered to be the shortest length of time permissible, along with requiring other password security factors, such as increasing the variability of the symbol set-space by requiring mixed-cases, special characters, further increases the difficulty of breaking any password using brute-force methods.	>= 1 day
Status of the number of days before a [Prompt user] password expiration warning prompt is displayed at login	Among the several characteristics that make 'user identification' via password a secure and workable solution is setting the 'expiration warning date' requirement. This establishes the number of days before the host will begin to display 'password expiration warning' messages upon login. Without having a pre-expiration warning message, it is more likely that users will not prepare for this event, which may contribute to the selection of hard-to-remember or easily broken password sequences, which circumvents the intent of having rules for password complexity enforced. This may cause some users to forget or write down their new password, which can lead either to a system compromise or increased calls to Help Desk resources. (Interactive Logon: Prompt User to Change Password Before Expiration)	>=7 days
Status of the 'Require a Password When a Computer Wakes (on Battery)' setting	The 'Require a Password When a Computer Wakes (on Battery)'s group policy setting forces the user to reenter the password when the system resumes from a state of sleep while on battery power. As this group policy invokes	Enabled

	security settings that help deter unauthorized access, it should be configured.	
Status of the 'Require a Password When a Computer Wakes (Plugged In)' setting	The 'Require a Password When a Computer Wakes (Plugged In)' group policy setting forces the user to reenter the password when the system resumes from a state of sleep. As this group policy invokes security settings that help deter unauthorized access, it should be configured.	Enabled
Status of the 'Configure SAM change password RPC methods policy' setting on the host	The Configure SAM change password RPC methods policy setting controls which RPC methods can process password change requests for local accounts stored in SAM. Allowing insecure RPC methods can lead to MITM attacks, privilege escalation, credential theft, and brute force exploits. Attackers may intercept or manipulate password changes if weak authentication is used. To mitigate risks, restrict RPC methods to secure options, enforce NTLMv2/Kerberos authentication, disable legacy RPC interfaces, monitor security logs, and use endpoint protection solutions. These steps reduce attack surfaces and ensure secure password management.	Enabled: Block all change password RPC methods
Status of the 'Do not allow passwords to be saved' setting (Terminal Services)	The 'Do not allow password to be saved' policy setting prevents users of Terminal Services from saving their passwords within the local Client files. As with all credentials used to access critical systems/data, their protection must have primacy in any responsible security program to avoid misuse by malicious users. Best practice dictates that the location in which credentials are maintained should be kept to a minimum to reduce the threat landscape to a manageable level. This check can be run periodically to ensure the requirements are being met regarding the protections defined by internal policy or regulation(s).	Enabled
Status of the 'Always prompt for password upon connection' setting (Terminal Services)	By default, users can store their credentials when establishing shortcuts for Remote Desktop connections which allows them to logon without having to enter a password. This control checks to see if the Terminal Services server will defeat this default capability using this security setting and forcing it down to all systems requesting connections requiring a password to be entered for access. If it is allowed for cached credentials to be stored in shortcuts, a malicious user could exploit the credentials stored in the shortcut and gain access to sensitive systems and data. Run this check periodically.	Enabled

4.4 User Rights Assignment

The following user rights must be configured in: *Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\User Rights Assignment*

Policy Name	Description	Recommended Value
Current list of Groups and User Accounts granted the 'Act as part of the operating system' right	The 'Act as part of the operating system' privilege allows a process to impersonate/gain access to the same local resources as the 'user' being impersonated, but without requiring authentication. (The Manufacturer recommends that any process that needs this privilege should work through the 'LocalSystem' account, not a separate/special user account.) If all servers are connecting to, or members of, the Win-2003 product line, this privilege is not required. As the use of Win-2000 or Win-NT 4.0 servers may be	No one

	require that this privilege be used for applications that exchange clear-text passwords.	
Current list of Groups and User Accounts granted the 'Profile System Performance (SeSystemProfilePrivilege)' right	The 'Profile System Performance (SeSystemProfilePrivilege)' user right allows users to review the operation/performance of system processes. (The default system configuration grants this privilege to Administrators and the Local System, which may not appear but is included). As it is not usually necessary to grant this privilege for use of the System Monitor but may be required when gathering data via Windows Management Instrumentation, due to its capability to permit a malicious user to gather system data, it should be restricted.	Administrators, NT\SERVICE\WdiServiceHost
Current list of Groups and User Accounts granted the 'Lock Pages in Memory' right	The 'Lock Pages in Memory (SeLockMemoryPrivilege)' user right allows a User, Application, or Process to maintain data in physical memory, which prevents this data from being sent to a pagefile in virtual memory. (In the default installation for XP, this is not assigned to any user. For servers, only the Administrator is granted this right be default.) As use of this privilege could tie up large amounts of RAM.	No one
Current list of Groups and User Accounts granted the 'Load and unload device drivers' right	The 'Load and unload device drivers' (SeLoadDriverPrivilege) User Right permits installation and removal of device drivers for the 'Plug and Play' installation process. (During the default installation, this right is assigned only to Administrators.) As a malicious program masquerading as a device drivers could unintentionally be installed with 'trusted' privileges in this manner, this setting should be restricted.	Administrators
Current list of Groups and User Accounts granted the 'Create a Pagefile' right	The 'Create a Pagefile' right allows a user to call the application programming interface (API) that allows creation of a page file to add virtual memory space. (In the default installation, this right is given only to Administrators.) Pagefile alteration can allow a malicious user to slow down a process through lack of paging space. The pagefile may also retain confidential data after system shutdown if the 'Clear virtual memory pagefile' setting (CID-1048) has been disabled. As the Pagefile governs the behavior of the systems' virtual memory space, Groups and User Accounts granted the 'Create a Pagefile' right should be restricted.	Administrators
Current list of Groups and User Accounts granted the 'Create Global Objects' right	The 'Create Global Objects' user right allows a user to create global objects when connected to a Terminal Services session. All running processes on the system have access to global objects. (In the default installation this right is granted to Administrators, Interactive, and Service.) As the creation of global objects can negatively impact system processes, Groups and User Accounts granted the 'Create Global Objects' right should be restricted.	Administrators, SERVICE, LOCAL SERVICE, NETWORK SERVICE
Current list of Groups and User Accounts granted the 'Adjust memory quotas for a process' right	The 'Adjust memory quotas for a process' would allow an application, process, service, or user to increase the processor power assigned to a specific process' execution, thus preempting other jobs in the processor queue. (In the default installation, this right is given only to 'Administrators,' 'Local Service,' and 'Network Service.' As this privilege could easily be misused to create a DoS condition, this right should be limited.	LOCAL SERVICE, NETWORK SERVICE, Administrators, IIS Users and Microsoft SQL Users
Current list of Groups and User Accounts granted the 'Change the system time' right	The 'Change the system time' user right allows users to alter the date/time on the system's internal clock. (The default configuration grants this right to Administrators and Power Users.) As this right would allow changes in the recording of times in the audit trail as stored by the Event Log, as well as	LOCAL SERVICE, Administrators

	being of critical importance for Kerberos authentication, Groups and User Accounts granted this right should be restricted.	
Current list of Groups and User Accounts granted the 'Create Permanent Shared Objects' right	This user right is necessary for the creation of 'permanent shared objects' in the name space of Windows' object manager. (A permanent shared object is one that Windows does not destroy after all references to it are deleted--during the default configuration, this right is assigned only to the 'Local System.') The manufacturer has indicated that this privilege should not normally be required for any other user, but may need be needed for special situations, such as for accounts that run services deeply embedded within the OS.	No one
Current list of Groups and User Accounts granted the 'Deny log on locally' right	The 'Deny logon locally' right prohibits a user from logging on directly at the console. (In the default installation for XP, only the 'Guest' account is included in this setting--for servers, only privileged administrative accounts have console logon capability.) As use of a grant of this right could facilitate creation of a few SYSTEM-level DoS exploits, this right's usage should be set as appropriate to the needs of the business. NOTE: If the 'Everyone' user group is assigned this logon right, all Users will be barred from console logon, so if network access is lost and serial access capability has not been added, the only way to access the system is through the Recovery Console.	At least group ‘Guests’
Current list of Groups and User Accounts granted the 'Generate Security Audits' right	The 'Generate Security Audits' (SeAuditPrivilege) User Right permits the generation of security log records. (In the default configuration it is assigned to the Local Service and Network Service on workstations and domain controllers and the Local System on member servers.) As this right can create a condition causing the generation of many spurious log entries, making it difficult to sort out any actual attack traces and can also create a DoS condition if the 'shutdown the system immediately if unable to generate security audits' setting has been enabled, it should be restricted.	Local Service, Network Service
Current list of Groups and User Accounts granted the 'Modify an object label (SeRelabelPrivilege)' right	The 'Modify an object label (SeRelabelPrivilege)' Group Policy setting determines which user account(s) is/are permitted to alter the 'integrity label' of system objects, including files, registry keys, and/or processes that others own. As this capability may lead to the compromise of confidential information or privilege escalation.	No one
Current list of Groups and User Accounts granted the 'Modify firmware environment values (SeSystemEnvironmentPrivilege)' right	The 'Modify firmware environment values (SeSystemEnvironmentPrivilege)' user right allows the modification of the system environment variables, to permit a user or process to change the locations where program operational files are kept. (In the default installation, this right is given only to Administrators but may be needed during the application development or installation process.) As this privilege could allow the refocusing of system environment targets onto a rogue program source, this capability should be restricted.	Administrators
Current list of Groups and User accounts granted the 'Access credential Manager as a trusted caller (SeTrustedCredManAccessPrivilege)' right	The 'Access credential Manager as a trusted caller (SeTrustedCredManAccessPrivilege)' setting permits a process to read any object/property in any directory, no matter what privileges are assigned. As this permission could allow the compromise of all system's information.	No one
Current list of Groups and User Accounts granted the 'Perform Volume Maintenance Tasks	The 'Perform Volume Maintenance Tasks (SeManageVolumePrivilege)' user right permits non-administrative and/or remote users to manage volumes or disks. (In the default configuration, this is assigned only to	Administrators

(SeManageVolumePrivilege)' right	Administrators.) As malicious use of the capability could result in a DoS, data loss, data disclosure (by reading disk areas containing restricted data), and even performance issues, this capability should be restricted.	
Current list of Groups and User Accounts granted the 'Replace a process level token (SeAssignPrimaryTokenPrivilege)' right	The 'Replace a process level token (SeAssignPrimaryTokenPrivilege)' privilege permits the replacement of a process token of a child process, which can include altering authorization levels. (The default installation configuration grants this right to the Local Service and network Services, while the Local System already has the right.) As this right could be used for privilege escalation, it should be restricted.	Local Service, Network Service, IIS Users and Microsoft SQL Users
Current list of Groups and User Accounts granted the 'Restore files and directories (SeRestorePrivilege)' right	The 'Restore files and directories (SeRestorePrivilege)' user right allows a user or process access to cross file and directory permissions when restoring files and directories, as well as act as the 'valid security principal' for any object being restored. (In the default installation configuration, this right is granted to Administrators and Backup Operators.) As this privilege could be used to overwrite a valid file with malicious content, this capability should be restricted.	Administrators
Current list of Groups and User Accounts granted the 'Take ownership of files or other objects (SeTakeOwnershipPrivilege)' right	The 'Take ownership of file or other objects (SeTakeOwnershipPrivilege)' user right allows a user to take over any object in the system, such as files/folders, printers, processes, registry keys, and/or services. (In the default installation this right is only assigned to Administrators.) As this privilege would allow capturing and controlling any system object, it should be restricted.	Administrators
Current list of Groups and User Accounts granted the 'Debug Programs' right	The 'Debug Programs' user right allows a user to attach a debugger to any process. (The default configuration assigns this right only to Administrators.) As this right would allow a user to capture critical and/or sensitive data from any operating program, Groups and User Accounts granted the 'Debug Programs' right should be restricted.	Administrators
Current list of Groups and User Accounts granted the 'Create a Token Object' right	The ‘Create a Token Object’ right allows a process to create an [access] token object, which provides a security context for a process/thread. (In the default installation, this right is not assigned to any Groups or User Accounts.) As the ‘Create Token Object' right could be used for unauthorized user privilege escalation, Groups and User Accounts granted this right should be restricted.	No one
Current list of Groups and User Accounts granted the 'Allow log on locally (SeInteractiveLogonRight)' right	The 'Log on locally (SeInteractiveLogonRight)' user right allows a User to 'log on locally' via the console/keyboard. (In the default configuration for member servers/workstations, this right is given to Administrators, Power Users, Users, Guest, and Backup Operators	Administrators, Backup Operators
Current list of Groups and User Accounts granted the 'Allow logon through Terminal Services' right	The 'Allow logon through Terminal Services' right allows user logon via a Remote Desktop Protocol (RDP) connection. (In the default installation, this is limited to Administrators and Remote Desktop Users.) Any Group or User Account granted this user right is permitted to logon via Remote Desktop Protocol. As the ability to logon via Terminal Services can allow a malicious user to initiate a Denial-of-Service attack, Groups and User Accounts granted the 'Allow logon through Terminal Services' right should be restricted.	Administrators, Remote Desktop Users
Current list of Groups and User Accounts granted the 'Allow logon through Terminal Services' right	The 'Allow logon through Terminal Services' right allows user logon via a Remote Desktop Protocol (RDP) connection. (In the default installation, this is limited to Administrators and Remote Desktop Users.) Any Group or User Account granted this user right is permitted to logon via Remote Desktop Protocol. As the ability to logon via	Administrators, Remote Desktop Users

	Terminal Services can allow a malicious user to initiate a Denial-of-Service attack, Groups and User Accounts granted the 'Allow logon through Terminal Services' right should be restricted.	
Current list of Groups and User Accounts granted the 'Back up files and directories' right	The 'Back up files and directories' right allows the user to perform backups by circumventing file and directory permissions. (In the default installation, this right is granted to Administrators and Backup Operators.) As this right could be used to traverse and read attributes for all files and directories, Groups and User Accounts granted the 'Backup files and directories' right should be restricted.	Administrators
Current list of Groups and User accounts granted the 'Change the time zone privilege (SeTimeZonePrivilege)' setting	The 'Change the time zone privilege (SeTimeZonePrivilege)' will allow the user to change the system's time zone. As this privilege could allow a user to alter the logging parameters times used by the system log or other time time-sensitive functions such as email, making accurate forensic tracking infeasible, it should be restricted.	Administrators, LOCAL SERVICE
Current list of Groups and User Accounts granted the 'Force shutdown from a remote system' right	The 'Force shutdown from a remote system (SeRemoteShutdownPrivilege)' User Right allows the system to be shutdown remotely. In the default configuration this right is assigned only to Administrators on workstations/member servers and to Administrators and Server Operators on Domain Controllers. As this right can create a denial-of-service condition, it should be restricted.	Administrators
Current list of Groups and User Accounts granted the 'Increase Scheduling Priority' right	The 'Increase Scheduling Priority' (SeIncreaseBasePriorityPrivilege) User Right allows the user/process to increase the 'base class' assigned to a process. (In the default configuration for all workstations, servers, and domain controllers, this right is only assigned to Administrators.) As this privilege could allow critical processes to be superseded by those that are rarely needed, but consume a great many CPU cycles, facilitating a DoS condition, this setting should be restricted.	Administrators
Current list of Groups and User Accounts granted the 'Profile Single Process (SeProfileSingleProcessPrivilege)' right	The 'Profile Single Process (SeProfileSingleProcessPrivilege)' user right allows users to review the operation/performance of non-OS processes. (The default system configuration grants this privilege to Administrators, Power Users (on workstations), and the Local System). As it may be necessary to grant this privilege for use of the System Monitor when it is set to gather I/O data via Windows Management Instrumentation, it should otherwise be restricted.	Administrators
Status of the name of the 'Built-in Administrator' account	The 'Built-in Administrator' account has full access to the system, including all files, directories, and processes. As knowing the name of a valid account with super-user privileges is half the battle in crafting a brute-force exploit, coupled with the fact that the 'Administrator' cannot be locked out, the Administrator account name-value should be renamed.	Rename administrator account
Current list of Groups and User Accounts granted the 'Deny logon as a batch job' right	The Current list of Groups and User Accounts granted the 'Deny logon as a batch job' setting determines which accounts are prevented from logging on as a batch job. As the capability to log on by using a batch-queue tool could be exploited by unauthorized users used to schedule jobs that could create a denial-of-service condition.	Guest
Current list of Groups and User Accounts granted the 'Deny logon as a service' right	The Current list of Groups and User Accounts granted the Deny logon as a service setting determines which users and groups are prevented from logging on as a service.	Guest

Current list of Groups and User Accounts granted the 'Deny logon through terminal (Remote Desktop) service' right	The 'Deny logon through terminal service' or 'Deny log on through Remote Desktop Services' user right prohibits a user from logging on using the Remote Desktop Protocol (RDP) to connect to Terminal Services. In the default installation for XP, no accounts are included in this group, but Users other than Administrators must be granted the right to log in with RDP. For servers, only privileged accounts have RDP logon capability, and the 'Guest' account is included in this 'Deny' group. (This may differ if the system offers Terminal Server services.) As RDP connections can provide a way to launch exploits against the system, membership in this group should be set. NOTE: If the 'Everyone' user group is assigned this logon right, all Users will be barred from RDP-based access to the system, so if network access is lost and serial access capability hasn't been added, the only way to access the system is through the console.	Local Accounts or specific AD Groups
Status of the name of the 'Built-in Guest' account	The 'Guest' account can be employed when a user needs to be granted access to the system but does not need any of the typical rights/privileges granted to an ordinary 'Authenticated User,' such as for use in a 'kiosk' role. As there are known exploits for the 'Guest' role, including allowing non-authenticated users to create a mail relay when the domain 'Guest' account is enabled, this account should be renamed to something unique for your organization. NOTE: In order to prevent a malicious user from identifying the account by its SID after renaming the Guest account, disable the anonymous Security (SID)/Name translation setting.	Disabled

4.5 Security Options

The following security policies must be configured in *Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options*

Policy Name	Description	Recommended Value
Status of the 'Shutdown: Allow system to be shut down without having to log on' setting	The 'Shutdown: Allow system to be shut down without having to log on' setting permits anyone with physical access to the console to shut down the system without entering logon credentials. As host shutdown without valid credentials could lead to a DoS condition, followed by the potential to load malicious code via a flash drive or CD-ROM during the reboot process, this should be disabled.	Disabled
Current list of Groups and User Accounts granted the 'Shut down the system (SeShutdownPrivilege)' right	The 'Shut down the system (SeShutdownPrivilege)' user right allows the user or process to shut down the [local] system. (In the default installation, this is restricted to Administrators, Backup Operators, Power Users, and [ordinary] Users for workstations, to Administrators, Backup Operators, Print Operators, and Server Operators on member servers, and to Administrators and Server Operators for domain controllers.) As this privilege can cause a DoS condition if abused, it should be restricted.	Administrators
Status of the 'Network access: Do not allow anonymous enumeration of SAM accounts' setting	If enabled, the 'Anonymous enumeration of SAM accounts' allows an anonymous user to request the translation of a security ID (SID) to a username. As an attacker could use a well-known SID, such as a local Administrator account, to access the system.	Enabled

Status of the 'Network Access: Do not allow Anonymous Enumeration of SAM Accounts and Shares' setting	The 'Network Access: Do not allow Anonymous Enumeration of SAM Accounts and Shares' setting protects the list of user accounts and provides protection for the list of network file shares that have been established. As this helps to prevent malicious users from requesting the translation of a security ID (SID) to a username, such as that of the local Administrator account, to access the system.	Do not allow enumeration of Security Accounts Manager accounts and names
Status of the 'Network access: Restrict anonymous access to Named Pipes and Shares' setting	The 'Anonymous access to Named Pipes and Shares' setting defines which Named Pipes can be accessed remotely, without authentication between two processes. As these processes may/may not be on the same system, with a communications model that is peer-to-peer, not client-server and has few security protections.	Enabled
Status of the 'Network Access: Let Everyone permissions apply to anonymous users' setting	Enabling the 'Network Access: Let Everyone permissions apply to anonymous users' setting would add the 'anonymous user,' with a 'null [authentication] session,' such as an unauthenticated web browser-connected user or null dial-up-connection user, to the all-inclusive 'Everyone' group. As this capability would grant an anonymous user the escalated network privileges that are assigned by default to the 'Everyone' group, this should be disabled.	Disabled
Status of the 'Network Access: Remotely accessible registry paths' setting (Windows 2003 and later)	The 'Network Access: Remotely accessible registry paths' setting defines the registry paths/child paths which can be accessed from other systems across the network. This access depends on the enablement of the Remote Registry Service and requires authentication, however, opens additional opportunity for a malicious user to gain access and make changes to the registry settings defining how the system will function. If access to the 'Network Access: Remotely accessible registry paths' service is not required for the system's operation, it should be restricted.	System\CurrentControlSet\Control\ProductOptions System\CurrentControlSet\Control\Server Applications Software\Microsoft\Windows NT\CurrentVersion
Status of the 'Network Access: Shares that can be accessed anonymously' setting	Named Pipes' ACLs control access to network-based shares on a system. The 'Network Access: Shares that can be accessed anonymously' setting indicates the list of shares allowing null connection access. While shares can be opened to the 'Everyone' group, this would not include the 'null' (unauthenticated) user. By adding a specific share name to this list, it could allow null connections access to the share	None
Status of the 'Network access: Do not allow storage of passwords and credentials for network authentication' setting	The 'Network access: Do not allow storage of passwords and credentials for network authentication' setting determines whether the Stored Usernames and Passwords feature of Windows will save .NET Passports, credentials, or passwords. When this setting is enabled, the Stored Usernames and Passwords feature is prevented from storing credentials and passwords. When credentials and passwords are stored as part of a user's Domain account information and a malicious user compromises the account, all credentials and passwords will be compromised as well. It is always best practice to turn off any unnecessary services to reduce the overall threat surface of the system. Note: To set this setting, use the registry key/value at location - HKLM\System\CurrentControlSet\Control\Lsa (DisableDomainCreds).	Enabled
Status of the 'Microsoft network client: Digitally Sign Communications (if server agrees)' setting	The 'Microsoft network client: Digitally Sign Communications (if server agrees)' setting is used to specify whether to initiate traffic signing, based upon the receiving server agreeing to sign the traffic that it receives. When enabling this setting, all Server Message Block (SMB) communications by MS clients with servers using the Win2K	Enabled

	or later OS will attempt to be negotiate signing, potentially guaranteeing message integrity. NOTE: If the recipient server is not Win2K or above, SMB traffic will go through, but signing will not take place.	
Status of the 'Microsoft network client: Send Unencrypted Password to Connect to Third-Party SMB Server' setting	The 'Microsoft network client: Send Unencrypted Password to Connect to Third-Party SMB Server' setting will determine if using plain-text passwords is allowed when connecting to a third-party SMB server. As sending unencrypted passwords through a shared network can risk credentials being compromised by anyone using a packet sniffer on the network.	Disabled
Status of the 'Audit: Shut Down system immediately if unable to log security audits' setting	The 'Audit: Shut down system immediately if unable to log security audits' setting is responsible for ensuring that all security related events are captured in the Security Event Logs. If, for any reason, security events are not able to be captured when this setting is enabled, the system will immediately shut down which could negatively impact operations. If a system is shut down as a result, a member of the Administrator Group will be required to log in and archive the logs to allow for further review to determine the cause and respond accordingly. It is important to coordinate the enabling of this setting with requirements stipulated within internal policies and procedures for backup and retention of activity logs. As maximum effectiveness of this setting requires considering setting of the 'Security Log Retention Method' to 'Overwrite Events by Days' or 'Do Not Overwrite Events'.	Disabled
Status of the 'Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings' setting	The ‘Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings' setting determines how the system applies audit policy settings. Windows Vista has the capability of managing audit policy using audit policy subcategories. However, if audit policy is set at the category level, subcategory audit policy settings are overwritten by default. Enabling this setting addresses this issue by forcing the audit policy subcategory settings to override the audit policy category settings. When this setting is enabled, audit policy can be managed at the subcategory level without requiring changes to the Group Policy.	Enabled
Status of the 'Accounts: Limit local account use of blank passwords to console logon only' setting	At times, having a blank password for user login is acceptable, especially at kiosk-type machine that are for public access. However, as allowing remote users to log in without passwords can be a serious security risk, this capability should be restricted appropriately, such as limiting this capability to the physical console.	Enabled
Status of the local 'Guest' account (enabled/disabled)	The 'Guest' account on the local system (Member Server or Domain Controller) can be employed when a user needs to be granted access to the system but does not need any of the typical rights/privileges granted to an ordinary 'Authenticated User,' such as for use in a 'kiosk' role. As there are known exploits for the 'Guest' role, including allowing non-authenticated users to create a mail relay when the domain 'Guest' account is enabled, it should be disabled. NOTE: To prevent a malicious user from identifying the account by its SID after renaming the Guest account, disable the anonymous Security (SID)/Name translation setting.	Disabled
Status of the 'Interactive Logon: Do not require CTRL+ALT+DEL' setting	The Windows OS behaves differently when the 'CTRL+ALT+Delete' is invoked before login--this guarantees that the authentication process for the system is engaged. Otherwise, when only the two-line login screen is presented,	Disabled

	it is possible that a Trojan program is displaying a phony userid/password login screen, which will collect the credentials and exit, leaving the user believing that he/she simply mistyped one or both required values. NOTE: As this is one of the reverse-logic controls, it is important to remember that this should be DISABLED.	
Status of the 'Interactive Logon: Number of Previous Logons to Cache (in case domain controller is not available)' setting	The 'Interactive Logon: Number of previous logons to cache (in case domain controller is not available)' setting is responsible for allowing (or disallowing, by configuring this setting to a value of 'zero') interactive logons with domain accounts to authenticate on a workstation locally when a domain controller is unavailable. By allowing the authentication credentials to be cached locally creates an opportunity for exploitation by a malicious user to gain access to the system and/or sensitive data by using password cracking tools against them. Repeated invalid attempts at accessing the system will not lock the account since it is 'owned' by the domain and not the local system and domain policies have not yet been applied (such as User Account Lockout After Invalid Attempts settings). As users will not be prompted to change their password on a 'cached account,' which could result in increased calls to the Help Desk, due to locked accounts in the domain resulting from expiration or other reason, but not on the local system using the cached credentials, this value should be set according to the needs of the business. NOTE: Remember to consider remote users who may logon using cached credentials before establishing a Virtual Private Networking (VPN) connection to access internal resources when configuring this setting.	4 or fewer
Status of the 'Interactive Logon: Do Not Display Last User Name' setting	The 'Interactive Logon: Do Not Display Last User Name' setting prevents the name of the last authorized user login form being automatically displayed. As this information is half of what is needed by a malicious user to log in and there is an increased risk that an unauthorized user may gain knowledge of the client domain naming standards and obtain a valid username (for use in a brute-force attack).	Enabled
Status of the 'Interactive Logon: Smart Card Removal Behavior' setting	The 'Interactive Logon: Smart Card Removal Behavior' setting allows the control of the status of the workstation when the smart card is removed, from 'no action' to 'log off' user. The 'Smart Cards' are part of the two-factor authentication system used in high security environments, providing a tamper-resistant/portable way to log on to a Microsoft Windows Server family domain, provide client authentication, sign code, and secure e-mail.	Lock Workstation
Status of the 'Network Security: Do not store LAN Manager password hash value on next password change' setting	The 'Network Security: Do not store LAN Manager password hash value on next password change' setting prevents LM password hashes from being stored on the system. Upon enabling this setting, you may want to force all users to change their passwords as the hash values are not automatically deleted. (All pre-existing password hash values will remain in place until they have been cycled AFTER this setting has been enabled.) Also, when this setting is enabled on a member server or workstation, only the local SAM accounts will be protected on that system. To prevent Active Directory from allowing these hash values to be stored for domain accounts, use the Default Domain Controllers Group Policy Object. As enabling this setting should enhance the security baseline unless legacy issues require support for pre-Windows NT systems.	Enabled

Status of the 'Network Security: LAN Manager Authentication Level' setting	This check provides the status of the 'Network Security: LAN Manager Authentication Level' setting. The earliest Windows network-based authentication scheme, 'LanManager' (LM), designed for Windows for Workgroups 3.11, can be easily broken by software available on the Internet. MS has responded over the years by creating more secure authentication protocols, with the strongest being 'NT LanManager, Version 2' (NTLM v2). The most secure setting, as specified by the manufacturer for all OS versions 'Win2K' and above, is to use 'Send NTLMv2 response only.' When there are no Win95/98 hosts on the network, LM can be superseded by NTLM (version 1)	Send NTLMv2 response only. Refuse LM & NTLM.
Status of the 'Network security: Allow LocalSystem NULL session fallback' setting	The 'Network security: Allow LocalSystem NULL session fallback' setting determines the values a service will use on Windows systems to establish connections to a variety of Windows-based systems. When enabled, this setting will permit the use of system-generated keys for NULL sessions which could allow sensitive data to be exposed in transit, therefore, should be disabled.	Disabled
Status of the 'Network security: Allow PKU2U authentication requests to this computer to use online identities' setting	The 'Network security: Allow PKU2U authentication requests to this computer to use online identities' setting is used to manage User IDs from authenticating to the system from the Internet via the PKU2U protocol. However, the use of this capability does not have any impact on the use of Domain/Local account authentication. As this capability may be a useful feature on systems that do not store or process sensitive or protected data, it certainly increases the threat landscape for those that do and should be configured in compliance with organizational requirements and expectations. Note: This setting can be set by using registry key/value at location - HKLM\System\CurrentControlSet\Control\Lsa\pku2u (AllowOnlineID).	Disabled
Status of the 'Network Security: Minimum session security for NTLM SSP based (including secure RPC) clients' setting	This check provides the current status of the 'Network Security: Minimum session security for NTLM SSP based (including secure RPC) clients' setting. Remote Procedure Call (RPC) provides a way for a remote user to execute an operation on the system as if sitting at the console. This can allow a malicious user to initiate RPC-based attacks that focus on 'privilege escalation.' By requiring message integrity, confidentiality, session security and high-strength encryption for clients, the problems with weak authentication that have made RPC vulnerable to 'man-in-the-middle' attacks can be overcome, so these should be deployed on the Client as appropriate to the needs of business. NOTE: The recommendation is to use Message Integrity, Message Confidentiality, NTLMv2 Session Security, and 128-bit Encryption: all these settings must be used together for the complete security process to be successful. (See MS-KB 239869)	“Require NTLMv2 session security” and “Require 128-bit encryption” will be marked
Status of the 'Network Security: Minimum session security for NTLM SSP based (including secure RPC) servers' setting	This check provides the status of the 'Minimum session security for NTLM SSP based (including secure RPC) servers' setting. Remote Procedure Protocol (RPC) provides a way for a remote user to execute an operation on the system as if sitting at the console	“Require NTLMv2 session security” and “Require 128-bit encryption” will be marked
Status of the 'Network security: Allow Local System to use computer identity for NTLM' setting	The 'Network security: Allow Local System to use computer identity for NTLM' setting permits services that operate as Local System using the Negotiate method to use the computer's identity for authentication. In some instances, this could result in requests for authentication to fail	Enabled

	between some Windows-based systems and send error messages to the logs. When this setting is not configured, such services will authenticate anonymously as was normal behaviour in earlier versions of Windows. For Windows 7 or 2008 R2 systems connecting to Vista or 2008 systems, a NULL session will be used which employs a system-generated session key providing no protection whereas the computer identity method allows for signing and encryption. As with all security settings on critical devices, or those that process and/or store sensitive data.	
Status of the 'Microsoft Network Server: Disconnect clients when logon hours expire' setting	The 'Microsoft Network Server: Disconnect clients when logon hours expire' setting forces workstation clients that are connected to services via the domain to disconnect from it when the permitted login period has expired, even though the User will not have the desktop forcibly closed. As this will also disconnect a workstation that is acting as a server, closing the network connections when the allotted time expires. NOTE: This lockout applies only to SMB-based connections.	Enabled
Status of the 'Microsoft network server: Digitally Sign Communications (if Client agrees) setting	When enabling 'Microsoft network server: Digitally Sign Communications (if Client agrees) setting, all Server Message Block (SMB) communications by MS clients to servers using the Win2K or later OS will request signing, which guarantees message integrity, but not confidentiality. As this will potentially break legacy applications. NOTE: If the recipient server is not Win2K or above, SMB traffic will go through, but signing will not take place.	Enabled
Status of the 'Microsoft network server: Amount of Idle Time Required Before Suspending Session' setting	The 'Microsoft network server: Amount of Idle Time Required Before Suspending Session' setting establishes time limits on sessions between computers that share resources with other Windows systems and do so using the SMB protocol, which exchanges credentials, performs authentication, and allocates resources for connection management. As open sessions on systems that have been left unattended can be compromised by malicious users, potentially allowing them access to sensitive data and this can further be used to conserve the resources set aside for maintaining the connection for maximum performance, establishing a specific amount of time that the system is allowed to be idle before the connection is closed automatically.	15 minutes or less
Status of the 'Domain member: Digitally encrypt secure channel data (when possible)' setting	The 'Domain member: Digitally encrypt secure channel data (when possible)' entry is used when negotiating the conditions of a secure channel with a domain controller and specifies whether outgoing secure channel traffic is encrypted (sealed). Enabling this reduces the likelihood of successful sniffing or replay attacks. As enabling this setting may break the communication path to legacy applications.	Enabled
Status of the 'Domain member: Digitally sign secure channel data (when possible)' setting	The 'Domain member: Digitally sign secure channel data (when possible)' entry is used to specify whether outgoing secure channel traffic is signed. (This entry is used when negotiating the conditions of a channel with a domain controller.) Having the traffic digitally signed reduces the likelihood of successful spoofing and/or hijacking attempts going unnoticed, as alterations of the cryptographic hash on a traffic segment will cause error conditions.	Enabled
Status of the 'Domain member: Disable machine account password changes' setting	The 'Domain member: Disable machine account password changes' used to authenticate/authorize a system within a domain.	Disabled

Status of the 'Domain member: Maximum machine account password age' setting	The 'Domain member: Maximum machine account password age' used to authenticate/authorize a system within a domain.	Less than or equal to 45 days
Status of the 'Prevent users from installing printer drivers' setting	The 'Prevent users from installing printer drivers' setting provides protection from users installing unsigned or malware infected drivers onto the system. As installing printer drivers requires code to be loaded directly into operating system kernel's privileged space and a malicious user can use this vector to introduce invalid or Trojan-based print drivers to subvert the system.	Enabled
Status of the 'Devices: Allowed to format and eject removable media' setting (NTFS formatted devices)	The ability to format/eject removable media allows the user to create and/or erase a data or system partition on a removable storage device, such as floppy disks, 'Jaz' and 'Zip' drives, or USB-based 'flash memory' drives, which allow NTFS partition creation. As this capability may allow the copying of user-accessible sensitive data for removal from a restricted area or the destruction of vital information stored on the removable media, by accident of design, this capability should be restricted appropriately.	Administrators
Status of the 'System objects: Strengthen default permissions of internal system objects' setting	The 'System objects: Strengthen default permissions of internal system objects' setting governs access permissions on system objects, such as shared physical and logical resources, including semaphores and DOS device names.	Enabled
Status of the 'SMB v1' protocol for LanManServer services on Windows SC	Server Message Block (SMB) is mainly used for providing shared access to files, printers, and serial ports and miscellaneous communications between nodes on a network. 'mrxsmb10' service implements the SMB v1 protocol on Windows systems. SMB does not encrypt traffic, has weak authentication, and relies on firewall segmenting and clear-text passwords for access control. It is known to be exploited frequently for remote code execution, denial of service and man-in-the-middle attacks.	Disabled
Configure 'Network Security: Configure encryption types allowed for Kerberos'	The Network security: Configure encryption types allowed for Kerberos settings determines the encryption types that the Kerberos protocol is allowed to use. As encryption will not be enabled this is not set, it should be configured.	AES_128_HMAC_SHA1, AES_256_HMAC_SHA1, Future Encryption Types.
Status of the 'Domain member: Digitally encrypt or sign secure channel data (always)' setting	The 'Domain member: Digitally encrypt or sign secure channel data (always)' setting dictates that SMB data exchanged between a server and client (on a secure channel) must be either signed or sealed. If the domain controller on the other side of the channel does not support signing or sealing, the system can refuse to establish a channel--This provides the strongest security for inter-domain communication. As this setting may break the communication path to legacy applications, this should be changed only after careful testing.	Enabled
Status of the 'Domain member: Require strong (Windows 2000 or later) session key' setting	The 'Domain member: Require strong (Windows 2000 or later) session key' is to require a 128-bit key for encrypted secure channel data. When a system joins a domain, an account is created. Thereafter, when the system starts, it uses the computer account password to create a secure channel to domain controller--This channel is used for NTLM passthrough authentication, LSA SID\Name Lookup, etc. As this setting requires that all 'secure traffic' between domain controllers and workstations use a 128-bit key to encrypt the traffic, this should be tested carefully and set as appropriate, for it may otherwise break Unix/Windows network integrations or other legacy connections.	Enabled

Status of the 'Microsoft network client: Digitally sign communications (always)' setting	The 'Microsoft network client: Digitally sign communications (always)' setting is associated with the Server Message Block (SMB) protocol only. Whenever it is enabled, all signed communications will be negotiated with any server that supports it. As enabling this setting helps to reduce the potential for man-in-the-middle (MITM) attacks to occur by providing protection for packet tampering and supports mutual authentication.	Enabled
Status of the 'Microsoft network server: Digitally sign communication (always)' setting (SMB)	The 'Microsoft network server: Digitally sign communication (always)' setting requires that communication from the server must be digitally signed, thus ensuring its authenticity. (This still allows the messages contents to be intercepted and read.) As digitally signing SMB traffic reduces the risk of spoofing and 'man-in-the-middle' (MITM) attacks. (RequireSecuritySignature)	Enabled
Status of the 'TurnOffAnonymousBlock' setting on the host	The TurnOffAnonymousBlock registry key is used to control how Windows handles anonymous user access to certain system information. It influences whether the system restricts or allows anonymous users to retrieve details such as security identifiers (SIDs) or account names. This setting is associated with policies that manage anonymous access and plays a role in enforcing security boundaries within Windows environments.	Disabled
Network access: Restrict clients allowed to make remote calls to SAM	The 'Network Access: Restrict clients allowed to make remote calls to SAM' setting limit the remote querying of SAM to local administrators only. If the policy is set to disable, any user can query any system for its users.	Administrators: Remote Access: Allow
Status of the 'Network Access: Sharing and security model for local accounts' setting	The 'Network Access: Sharing and security model for local accounts' setting determines how user privileges will be treated after network-based logons (using local account privileges) are authenticated. If the mode is set to 'Classic,' network-based logons that rely on local-account credentials will authenticate and be authorized via those local credentials. If set to 'Guest only,' network-based logons that would otherwise use, map, and authorize users according to local-account privileges are mapped instead to the 'Guest' account. As this setting can impede/restrict the activities of remote users who log onto domain-based workstations with 'local accounts,' by reducing the user's capability both for doing work and potentially for reducing harmful behavior, this should be set.	Ensure it is set to Classic – local users authenticate as themselves
Status of the 'Network security: LDAP client encryption requirements' setting on the host	The Network security: LDAP client encryption requirements policy setting controls the encryption level for LDAP client communications. Without encryption, LDAP traffic is vulnerable to MITM attacks, eavesdropping, and data integrity compromises. Attackers can capture or alter LDAP authentication and directory responses, leading to unauthorized access or misleading directory-based decisions. To mitigate risks, configure this setting to "Require sealing" or at least "Negotiate sealing", ensuring LDAP traffic is encrypted. Additionally, enforce LDAPS (SSL/TLS), use IPsec authentication headers, and audit LDAP traffic logs to detect unencrypted transmissions. Strengthening encryption on LDAP communications prevents malicious data interception and modification.	Negotiate sealing or Require sealing
Status of the 'Network Security: LDAP client signing requirements' setting	One of the major shifts in user management has been to use the 'LDAP' (Lightweight Directory Access Protocol) model for extending the Windows OS into a truly extensible 'enterprise' account manager. The 'Network Security: LDAP client signing requirements' setting allows for requiring signing for LDAP communication, (requires specific	Negotiate singning or Require signing

	configuration of the client and server) ensuring that the two systems' communications have been mutually authenticated, by using SSL/TLS 'LDAP signature' identification on the packets. As this security measure can prevent a malicious user from impersonating a secure host and carrying out 'man-in-the-middle' (MITM) attacks, it should be implemented correctly. NOTE: The 'Require Signing' setting can cause communication between server and client to fail if the two are not properly configured. Careful testing is strongly recommended before applying this to a Production environment.	
Status of the 'System objects: Require case insensitivity for non-Windows subsystems' setting	This check provides the current status of the 'System objects: Require case insensitivity for non-Windows subsystems' setting. Because Windows is case-insensitive, but a POSIX subsystem will support case sensitivity, failure to enable this policy setting would make it possible for a user of that subsystem to create a file with the same name as another file, but with a different mix of upper- and lower-case letters. As this situation could potentially confuse users when they try to access such files from normal Win32 tools, because only one of the files will be available, this should be set.	Enabled
Status of the 'User Account Control: Admin Approval Mode for the Built-in Administrator account' setting	The 'User Account Control: Admin Approval Mode for the Built-in Administrator account' setting determines whether or not the Built-in Administrator account will logon to the system in Admin Approval Mode. When this setting is enabled, the Built-in Administrator account will logon to the system in Admin Approval Mode. Admin Approval Mode forces the system to prompt the administrator for consent when an operation requiring privilege elevation is requested. When this setting is disabled, the Built-in Administrator account will logon to the system in Windows XP compatible mode and the account will be granted full administrative privileges. NOTE: Consider implementing this control in conjunction with CID 2583 and CID 2587.	Enabled
Status of the 'User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode' setting	The 'User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode' setting determines how requests for an elevation in privileges by Administrators are handled. When an Administrator account logs into a Windows Vista, or later, operating environment, it is done in Protected [Administrator] Mode status. For certain tasks and actions to be performed on the system, the Administrator account will need to be placed into Elevated [Administrator] Mode. The act of going from Protected Mode to Elevated Mode can be configured by this setting to require credentials to be input or have no interaction to be required at all. When this is set to allow elevations in privileges to occur without any user interaction, it increases the likelihood that malware requiring to be run with administrative privileges will be capable of executing its payload on the system without hindrance. Therefore, the risk associated with this setting should be considered.	Prompt for consent on the secure desktop or Prompt for credentials on the secure desktop
Status of the 'User Account Control: Behavior of the elevation prompt for standard users' setting	The 'User Account Control: Behaviour of the elevation prompt for standard users' setting determines how the system will display elevation prompts to standard users. Windows Vista uses User Account Control elevation to prompt the user for credentials or consent when a system operation requires administrative rights. This policy setting has two possible configurations that affect elevation requests: 1) Prompt for credentials - when this setting is enabled the user is prompted to provide administrator credentials in order for the operation to continue. 2)	Automatically deny elevation request

	Automatically deny elevation requests - when this setting is enabled the system will not perform the requested operation and the user is presented with an access denied error message.	
Status of the 'User Account Control: Detect application installations and prompt for elevation' setting	The 'User Account Control: Detect application installations and prompt for elevation' setting determines whether or not the user is presented with an elevation prompt when Windows Vista detects an installation application. When this setting is enabled, Windows Vista uses heuristic detection to identify installation applications. When Windows detects an installation application, the user is prompted for credentials or consent through an elevation prompt. When this setting is disabled, installation applications are prevented from running and the user is presented with a notification error message.	Enabled
Status of the 'User Account Control: Only elevate UIAccess applications that are installed in secure locations' setting	The 'User Account Control: Only elevate UIAccess applications that are installed in secure locations' setting determines whether or not the system will elevate applications that use a UIAccess integrity level check when requesting execution. When this setting is enabled, applications are permitted to launch with UIAccess integrity only if they reside in secure system folders. When this setting is disabled, applications are permitted to launch with UIAccess integrity regardless of their location in the file system. Restricting which applications are permitted to run with elevated permissions can reduce the risk of a malicious user gaining inappropriate access and/or control.	Enabled
Status of the 'User Account Control: Run all administrators in Admin Approval Mode' setting	The 'User Account Control: Run all administrators in Admin Approval Mode' setting determines whether the system will prompt consent or credentials when an administrative operation is requested. When this setting is enabled, users and administrators are prompted for consent or credentials (depending on other Group Policy settings). When this setting is disabled, both the Windows Vista User Account Control functionality and Application Information Service are disabled. As disabling the functionality of User Account Control presents an attack surface that could allow a malicious user to gain inappropriate access and/or control.	Enabled
Status of the 'User Account Control: Switch to the secure desktop when prompted for elevation' setting	The 'User Account Control: Switch to the secure desktop when prompted for elevation' setting determines whether the system will switch to Secure Desktop when an executable file requests permission elevation. The Secure Desktop functionality changes the interactive user desktop into a secure 'alpha-blended bitmap' display to present the permission elevation prompt to the user. When this setting is enabled, the system will switch to the Secure Desktop for all elevation requests. When this setting is disabled, all elevation requests will be presented through the interactive user desktop. This functionality is designed to prevent malware from imitating the secure desktop by 'painting over' the interactive user desktop.	Enabled
Status of the 'User Account Control: Virtualize file and registry write failures to per-user locations' setting	The 'Virtualize file and registry write failures to per-user locations' setting will determine whether the recording of system 'failure' notifications will be directed to a predefined file-system/registry location. As this setting can help mitigate risks that may occur when run-time data is written to sensitive file and registry areas, this capability should be configured correctly.	Enabled
Status of the 'SMB 1.x MiniRedirector (mrxsmb10)' Windows	Server Message Block (SMB) is mainly used for providing shared access to files, printers, and serial ports and miscellaneous communications between nodes on a	Disabled

service (LanmanWorkstation depend on service 'mrxsmb10')	network. 'mrxsmb10' service is responible for implementing the SMB v1 protocol on Windows systems to provide connectivity to network resources. SMB does not encrypt traffic, has weak authentication, and relies on firewall segmenting and clear-text passwords for access control. It is known to be exploited frequently for remote code execution, denial of service and man-in-the-middle attacks. Use of SMB protocol should be considered carefully.	

4.6 Windows Components - WDigest Authentication

Policy Name	Description	Recommended Value
Status of the 'WDigest Authentication' setting	The 'WDigest Authentication' setting specifies if a copy of the user's plaintext password is to be retained in memory. If this setting is not specified malicious users can gain access and result in credential theft.	Disabled
Status of the 'Set Time Limit for Disconnected Sessions' Group Policy setting (Terminal Services)	The 'Set Time Limit for Disconnected Sessions' Group Policy setting limits the duration of idle Terminal Services sessions upon 'user disconnect' (as opposed to user logoff, which closes the session), when a user exits an RDP/Terminal Services session. As limiting the time for disconnected sessions reduces risk of unauthorized access via an open session.	15 minutes

4.7 Audit Policies - Account Logon

The following security audit policies must be configured in: *Compute Configurations\Windows Settings\Security Settings\Local Policies\Audit Policy\Account Logon*

Policy Name	Description	Recommended Value
Status of the audit setting 'Credential Validation' (advanced audit setting)	The 'Credential Validation' security policy setting tracks local and domain accounts credential submission activities during logon requests. Examples of these activities include validations and failures of credentials and confirmed and failed mappings for logon requests. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled.	Success and Failure (3)
Status of the audit setting 'Audit Group Membership' (advanced audit setting)	The policy 'Audit Group Membership' setting allows you to audit the group membership information in the user's logon token. Events in this subcategory are generated on the computer on which a logon session is created. If this setting is not configured, or if audit settings are too lax on the computers in the organization, security incidents might not be detected, or not enough evidence will be available for network forensic analysis after security incidents occur.	Success (1)

4.8 Audit Policies - Account Management

The following security audit policies must be configured in: *Compute Configurations\Windows Settings\Security Settings\Local Policies\Audit Policy\Account Management*

Policy Name	Description	Recommended Value
Status of the audit setting 'Security Group Management' (advanced audit setting)	The 'Security Group Management' security policy setting tracks security group management activities. Some of these activities include creation, modification, deletion, and type changes of the security group. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled.	Success and Failure (3)
Status of the audit setting 'Account Management: User Account Management' (advanced audit setting)	The 'User Account Management' audit policy setting tracks user account management activities. Some of these activities include creating, modifying, and deleting user accounts, password creation or modifications, and backup or restoration of Credential Manager credentials. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled.	Success and Failure (3)
Status of the audit setting 'Application Group Management' (advanced audit setting)	The 'Application Group Management' security policy setting tracks application group management activities. Examples of these activities are creating, changing, deleting, basic application groups and when members and non-members are added to application groups. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled, monitored and managed.	Success and Failure

4.9 Audit Policies - Detailed Tracking

The following security audit policies must be configured in: *Compute Configurations\Windows Settings\Security Settings\Local Policies\Audit Policy\Detailed Tracking*

Policy Name	Description	Recommended Value
Status of the audit setting 'Process Creation' (advanced audit setting)	The 'Process Creation' audit policy setting tracks events triggered by process creation (start) and the name of the user or application responsible. Some of these events are recorded when a new process is started or when a token is assigned to a new process. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled.	Success (1)
Status of the 'Include command line in process creation events' setting	The policy 'Include command line in process creation events' setting allows you to determine what information is logged in security audit events when a new process has been created. The command line information for every process will be logged in plain text in the security event log as part of the Audit Process Creation event. When this policy setting, any user with access to read the security events will be able to read the command line arguments for any successfully created process. Command line arguments can contain sensitive or private information such as	Enabled

	passwords or user data which may lead to unauthorized activities on the system.	

4.10 Audit Policies - Logon-Logoff

The following security audit policies must be configured in: *Compute Configurations\Windows Settings\Security Settings\Local Policies\Audit Policy\Logon Logoff*

Policy Name	Description	Recommended Value
Status of the audit setting 'Account Lockout' (advanced audit setting)	The 'Account Lockout' security policy setting tracks logon failures on locked-out accounts. This type of forensic event information may be useful in detecting or identifying malicious users attempting to crack user account passwords. Repeated failed logon activity on a known account that is disabled could be an indicator that the site is under brute force or other password attack. In addition, dependent upon regulatory requirements the organization may be subject to, these policy settings could be required for compliance. As with all critical systems and devices, audit settings and logs should be enabled.	Failure (2)
Status of the audit setting 'Logoff' (advanced audit setting)	The 'Logoff' security policy setting tracks logoff events. This security policy setting tracks user and account logoff activity. This type of forensic event information may be useful in detecting or identifying malicious users attempting to subvert system security or cause damage to critical systems/data. In addition, dependent upon regulatory requirements the organization may be subject to, these policy settings could be required for compliance. As with all critical systems and devices, audit settings and logs should be enabled.	Success (1)
Status of the audit setting 'Logon' (advanced audit setting)	The 'Logon' security policy setting tracks logon attempts. This security policy setting tracks user logon activity (successful and failed) and Security Identifiers (SIDs). This type of forensic event information may be useful in detecting or identifying malicious users attempting to subvert system security or cause damage to critical systems/data. In addition, dependent upon regulatory requirements the organization may be subject to, these policy settings could be required for compliance. As with all critical systems and devices, audit settings and logs should be enabled.	Success and Failure (3)
Status of the audit setting 'Special Logon' (advanced audit setting)	The 'Special Logon' security policy setting tracks user's logon who belong to the 'Special Logon' group. The 'Special Logon' group members have Administrator level privileges and can escalate the rights of other objects. Depending upon regulatory requirements, these audit policy settings may be required. As with all critical systems and devices, audit settings and logs should be enabled.	Success (1)

4.11 Audit Policies - Policy Change

The following security audit policies must be configured in: *Compute Configurations\Windows Settings\Security Settings\Local Policies\Audit Policy\Policy Change*

Policy Name	Description	Recommended Value
Status of the audit setting 'Audit Policy Change' (advanced audit setting)	The 'Audit Policy Change' audit policy setting tracks changes to the System Audit Policy and several object and user audit settings. Some of the objects that can be audited are audit settings on policy objects, user, SACL, file, and registry key settings. Special Group list objects can also be audited. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled.	Success and Failure (3)
Status of the audit setting 'Authentication Policy Change' (advanced audit setting)	The 'Authentication Policy Change' audit policy setting tracks events generated by changes to authentication policies. Some of these changes include granting access to a computer from a network, grants for service logons, authentications for batch job logons, and local and remote access grants. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled.	Success (1)
Status of the audit setting 'Authorization Policy Change' (advanced audit setting)	The 'Authorization Policy Change' audit policy setting tracks changes to authorization policies. Examples of these changes are newly created trusts to a domain, removal of trusts to a domain, user rights either assigned or removed, and any changes to data recovery policies (encrypted). Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled.	Success and Failure (3)

4.12 Audit Policies - Privilege Use

The following security audit policies must be configured in: *Compute Configurations\Windows Settings\Security Settings\Local Policies\Audit Policy\Privilege Use*

Policy Name	Description	Recommended Value
Status of the audit setting 'Sensitive Privilege Use' (advanced audit setting)	The 'Sensitive Privilege Use' audit policy setting tracks events where sensitive privileges are used. Examples of some of these sensitive privileges are managing audit and security logs, modifying firmware, generation of security audits, and acting as part of the operating system. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled.	Success and Failure (3)

4.13 Audit Policies – System

The following security audit policies must be configured in: *Compute Configurations\Windows Settings\Security Settings\Local Policies\Audit Policy\System*

Policy Name	Description	Recommended Value

Status of the audit setting 'IPsec Driver' (advanced audit setting)	The 'IPsec Driver' security policy setting tracks the activities and events of the IPsec driver. These events include drops (failed integrity or replay checks), notifications (cleartext, startup, shut down), and failures in loading IPsec filters, failed initializations, or incomplete network interfaces. Depending upon regulatory requirements, these security policy settings may be required. As with all critical systems and devices, any security policy setting should be enabled.	Success and Failure (3)
Status of the audit setting 'Other System Events' (advanced audit setting)	The 'Other System Events' security policy setting tracks Windows Firewall service, driver, security policy, BranchCache, and cryptography notifications and events. Examples of these events would be Firewall service and driver startup, shutdown, and failed initializations or failed user notifications, driver runtime errors, and various BranchCache errors. Depending upon regulatory requirements, these security policy settings may be required. As with all critical systems and devices, security policy settings and logs should be enabled.	Success and Failure (3)
Status of the audit setting 'Security State Change' (advanced audit setting)	The 'Security State Change' audit policy setting tracks changes in system security states. This setting can be configured to audit system start, shut down, changes to time, and Administrator recovery from CrashOnAuditFail events. Depending upon regulatory requirements, these audit policy settings may be required. As with all critical systems and devices, audit settings and audit logs should be enabled.	Success and Failure (3)
Status of the audit setting 'Security System Extension' (advanced audit setting)	The 'Security System Extension' audit policy setting tracks critical system events generated by installing new security extension code(s) and/or installing new services. This audit policy can track when a Local Security Authority has started a trusted logon process, loaded a security or authentication package. This audit policy can also track when a new service is installed on the system. Depending upon regulatory requirements, these audit policy settings may be required. As with all critical systems and devices, audit settings and logs should be enabled.	Success and Failure (3)
Status of the audit setting 'System Integrity' (advanced audit setting)	The System Integrity audit policy setting reports on the integrity of the security system, including potential disk device errors, verification failures, etc. As enabling this audit facility has the potential to fill up a large amount of log space and cause a self-inflicted denial-of-service condition.	Success and Failure (3)
Status of the audit setting 'File Share' (advanced audit setting)	The 'File Share' audit policy setting tracks events regarding file shares. Some events that can be audited are network share accessed, modified, added, and deleted. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled, monitored and managed.	Success and Failure

4.14 Object Access

The following security audit policies must be configured in: *Compute Configurations\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policy\ Object Access*

Policy Name	Description	Recommended Value
Status of the audit setting 'Other Object Access	The 'Other Object Access Events' audit policy setting tracks events of COM+ objects and Task Scheduler jobs. Some of these events include Task Scheduler such as jobs created,	Success and Failure (3)

Events' (advanced audit setting)	enabled, updated, disabled, and deleted. Com+ object events are adds, deletes, and updates. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled.	

4.15 Administrative Templates (Computer)

Policy Name	Description	Recommended Value
Status of the 'Configure RPC packet level privacy setting for incoming connections' setting	This policy setting controls whether packet-level privacy is enabled for RPC for incoming connections and handles authentication for the remote Winspool interface. When this setting is enabled, the printer IRemoteWinspool protection level will be increased and the Windows spooler spoofing vulnerability will no longer occur.	Enabled
Status of the 'Allow Print Spooler to accept client connections' group policy setting	This group policy controls whether the print spooler will accept client connections or not. When the policy is unconfigured or enabled, the spooler will always accept client connections. When the policy is disabled, the spooler will not accept client connections nor allow users to share printers. All printers currently shared will continue to be shared. This policy also blocks the remote attack vector by preventing inbound remote printing operations. The system will no longer function as a print server, but local printing to a directly attached device will still be possible.	Disabled
Status of Windows 'Automatic Updates' (WSUS) setting (NoAutoUpdate)	The Windows 'Automatic Updates' (WSUS) setting configures how Automatic Updates are applied to the Windows system. The 'NoAutoUpdate' sub-setting determines whether to enable or disable automatic updates and compliments other related settings which manage updates. If automatic update to systems is not enabled, it would mean that the systems do not always have the most recent critical operating system updates and service packs installed. System updated and service packs have fixes against known or published vulnerabilities. To ensure that systems are protected against exploitation and compromise due to known vulnerabilities on a regular basis.	Enabled
Status of Structured Exception Handling Overwrite Protection (SEHOP) feature in Windows	The Structured Exception Handling Overwrite Protection (SEHOP) is a Windows Operating System feature designed to mitigate exploits against Structured Exception Handler (SEH) overwrite technique. SEH is a type of buffer overflow attack where an application exception handling function pointer could be compromised to run an arbitrary code controlled by an attacker. Enabling this feature improves the security profile of the systems by actively protecting all applications at run-time, regardless of whether any mitigation techniques are incorporated within the applications or not.	Enabled
Status of the 'Configure multicast DNS (mDNS) protocol' setting on the host	The Configure multicast DNS (mDNS) protocol setting controls whether mDNS is allowed for local network name resolution. While mDNS enables device discovery in zero-configuration networks, it introduces security risks such as MITM attacks, network exposure, DoS attacks, and lateral movement. Attackers can manipulate mDNS traffic to redirect users, enumerate devices, or flood networks. To secure systems, disable mDNS if unnecessary, restrict usage with firewall rules, apply network segmentation, and monitor mDNS traffic logs. For secure name resolution,	Disabled

	prefer DNS over HTTPS (DoH) or DNS over TLS (DoT) to encrypt queries and prevent unauthorized access.	
Windows - Status of NetBIOS name resolution	This setting determines whether NetBIOS name resolution will be performed by the DNS client. By default, NetBIOS name resolution is disabled on public networks for security reasons. Defining this policy setting or not configuring it will result in computers using locally configured settings.	Disabled
Status of the 'Turn off default IPv6 DNS Servers' setting on the host	The Turn off default IPv6 DNS Servers setting disables automatic assignment of IPv6 DNS servers, reducing potential security risks. MITM attacks, DNS hijacking, and IPv6 tunnelling threats can arise if rogue or external IPv6 DNS servers are used. IPv6 DNS traffic is also harder to monitor, making enterprises vulnerable to unnoticed attacks. To mitigate risks, disable default IPv6 DNS servers, restrict DNS queries to internal approved servers, and enforce firewall rules to block unauthorized IPv6 traffic. Organizations should also audit DNS configurations regularly.	Enabled
Status of the 'Network\Lanman Server: Audit insecure guest logon' setting on the host	The Audit insecure guest logon setting logs attempts to use a guest account for accessing the server, helping to monitor unprotected or weak login attempts. Without this setting, attackers could exploit guest logons to gain unauthorized access or launch brute-force attacks. To mitigate such risks, disable guest accounts, enforce strong authentication practices like multi-factor authentication, and enable auditing to track logon attempts. Regularly review logs for unusual activity and restrict network access to minimize the exposure of guest accounts. Properly securing guest logons reduces unauthorized access risks and strengthens overall server security.	Enabled
Status of the 'Require domain users to elevate when setting a network's location' setting	The policy 'Require domain users to elevate when setting a network's location' setting determines whether to require domain users to elevate when setting a network's location. Allowing regular users to set a network location increases the risk and attack surface.	Enabled
Status of the 'Hardened UNC Paths' setting for Sysvol	The policy 'Hardened UNC Paths' setting allows you to configure secure access to UNC paths. Universal Naming Convention (UNC) is a standardized notation that Windows uses to access file resources; in most cases these resources are located on a remote server. UNC allows the system to access files using the standard path format. If this setting is set properly, then Windows only allows access to the specified UNC paths after fulfilling additional security requirements.	Enabled with Require Mutual Authentication, Require Integrity and Require Privacy
Status of the 'Hardened UNC Paths' setting for Netlogon	The policy 'Hardened UNC Paths' setting allows you to configure secure access to UNC paths. Universal Naming Convention (UNC) is a standardized notation that Windows uses to access file resources; in most cases these resources are located on a remote server. UNC allows the system to access files using the standard path format. If this setting is set properly, then Windows only allows access to the specified UNC paths after fulfilling additional security requirements.	Enabled with Require Mutual Authentication, Require Integrity and Require Privacy
Status of the 'Configuration of wireless settings using Windows Connect Now' group policy setting	The ‘Configuration of wireless settings using Windows Connect Now' Group Policy setting automatically starts a network wizard gathering wireless network choices from the user, automatically configures the authentication and encryption settings on the computer, and stores a copy of these settings on a USB flash drive for use/reuse later. As	Disabled

	this setting can conflict with required network configurations and open unsecured channels, it should be configured.	
Status of the 'Configure Redirection Guard' setting	This setting is a security measure that prevents the use of non-administratively created redirection primitives from being followed within a given process. It manages printer access and allows users to continue working without waiting for a print job to finish. Disabling this setting will not redirect files that may be used in the spooler process.	Enabled
Status of the 'Configure RPC connection settings: Protocol to use for outgoing RPC connections' setting	This control determines the protocol and protocol settings to be used for outgoing RPC connections to a remote print spooler. The default protocol is RPC over TCP, with authentication always enabled by default. If the machine is joined to a domain, authentication is always enabled; however, it is not enabled if the machine is not joined to a domain. The attacker can relay NTLM authentication sessions to an attacked machine and execute code remotely via a printer spooler MSRPC interface.	Enabled: RPC over TCP
Status of the 'Use authentication for outgoing RPC over named pipes connections' setting	This control determines the protocol and protocol settings to be used for outgoing RPC connections to a remote print spooler. The default protocol is RPC over TCP, with authentication always enabled by default. If the machine is joined to a domain, authentication is always enabled; however, it is not enabled if the machine is not joined to a domain. The attacker can relay NTLM authentication sessions to an attacked machine and execute code remotely via a printer spooler MSRPC interface.	Enabled: Default
Status of the 'Protocols to allow for incoming RPC connections' setting	This control setting controls which protocols incoming RPC connections to the print spooler can use. Negotiate is used for authentication over RPC over TCP by default. Protocols to allow for incoming RPC connections. To enforce Kerberos authentication, enable and set. Configure RPC listener settings policy to allow Kerberos.	Enabled: RPC over TCP
Status of the 'Authentication protocol to use for incoming RPC connections' setting	This control setting controls which protocols incoming RPC connections to the print spooler can use. Negotiate is used for authentication over RPC over TCP by default. Protocols to allow for incoming RPC connections. To enforce Kerberos authentication, enable and set. Configure RPC listener settings policy to allow Kerberos.	Enabled: Negotiate or higher
Status of the 'Configure RPC over TCP port' setting	This control setting controls which port is used for RPC over TCP for incoming connections to the print spooler and outgoing connections to remote print spoolers. A value of 0 is the default and indicates that dynamic TCP ports will be used if you disable or do not configure this policy setting dynamic TCP ports are used.	Enabled: 0
Status of the 'Manage processing of Queue-specific files' setting	This setting allows standard colour profile processing using the inbox mscms.dll executable. The security baseline is to configure this setting to Enabled with the option of Limit queue-specific files to colour profiles. A remote code execution vulnerability exists when the Windows Print Spooler service improperly performs privileged file operations. An attacker who successfully exploited this vulnerability could run arbitrary code with SYSTEM privileges. The attacker could then install programs, view, change, or delete data, or create new accounts with full user rights.	Enabled: Limit Queue-specific files to Color profiles
Status of the 'Turn off downloading of print drivers over HTTP' setting	The 'Turn off downloading of print drivers over HTTP' setting determines the capability for allowing the user to download print drivers using an HTTP browser. As print drivers from Internet sites can be corrupted, contain a Trojan Horse, or host other sorts of malware, allowing users to download	Enabled

	print drivers over HTTP, which may impact the system's stability and security, should be set.	
Status of the 'Turn off Internet download for Web publishing and online ordering wizards' setting	The 'Turn off Internet download for Web publishing and online ordering wizards' are used by Windows to show the providers recommended by Microsoft to link to for online ordering/web publishing. As allowing the use of this kind of service can potentially allow the downloading of malicious content, this capability should be restricted.	Enabled
Status of the 'Turn off printing over HTTP' service	The 'Turn off printing over HTTP' service allows a user to use the HTTP protocol to send out print jobs. As HTTP is an unsecured, Internet-capable protocol that can potentially be sent through the Cloud as well as the network in a clear-text state, this capability should be restricted.	Enabled
Status of the 'Turn off the 'Publish to Web' task for files and folders' group policy	The 'Turn off the 'Publish to Web' task for files and folders' group policy setting determines whether a user will be allowed to publish items, such as files/folders to the Internet from the 'File and Folder Tasks.' As allowing this type of document publication may put confidential/proprietary information at risk, this capability should be set/restricted.	Enabled
Status of the 'Allow Custom SSPs and APs to be loaded into LSASS' setting	The configuration that LSASS uses to load unique SSPs, and APs is governed by this policy. Custom SSPs and APs may be loaded into LSA if this setting is enabled or if it is left unconfigured. Custom SSPs and APs are not loaded by LSA if this parameter is disabled. Third-party providers can plug in their own modules for login thanks to the Local Security Authority Subsystem Service (LSASS). They can now modify their login, and criminal players may take advantage of this to launch assaults. It prevents the disclosure of passwords to providers and limits the loading of specialised security packages.	Disabled
Status of the 'Block NetBIOS-based discovery for domain controller location' setting on the host	The Block NetBIOS-based discovery for domain controller location setting enhances security by disabling NetBIOS name resolution for domain controller discovery, forcing DNS-based DC location instead. NetBIOS is insecure, lacks authentication, and is vulnerable to NBNS spoofing, MITM attacks, DoS, and NTLM relay exploits. Attackers can redirect authentication requests, manipulate traffic, or disrupt DC communication using spoofed NetBIOS datagrams. To mitigate risks, enable this policy, disable NetBIOS over TCP/IP, use Active Directory-integrated DNS, enforce SMB signing, and monitor network traffic. These actions eliminate NetBIOS-related attack vectors and improve domain security.	Enabled
Status of the 'Offer Remote Assistance' setting (Terminal Services)	The 'Offer Remote Assistance' settings are configured to control the remote assistance capability that allows expert users and/or system administrators to offer remote assistance to someone on another system. This utility employs Terminal Services to provide this functionality and could allow malicious users the ability to gain access to systems from remote locations. As a result, this should be set in compliance with internal security requirements and expectations.	Disabled
Status of the 'Not allow per-user unsigned packages to install by default' setting on the host	The Not allow per-user unsigned packages to install by default setting prevents users from installing unsigned application packages without explicit approval. Allowing unsigned apps poses security risks such as malware infections, privilege escalation, supply chain attacks, and data theft. Attackers could distribute malicious or tampered software, leading to compromised systems. To mitigate risks, enable this policy, enforce code-signing for internal	Enabled

	apps, restrict app installation to administrators, monitor installed applications, and audit system logs. These measures reduce unauthorized software installations and enhance application security.	
Status of the 'Allow Microsoft accounts to be optional' setting	The 'Allow Microsoft accounts to be enabled' setting specifies if the Microsoft accounts are optional for Windows Store apps that require an account to sign in. This provides the organization with greater control over relevant credentials.	Enabled
Status of the 'Disallow Autoplay for non-volume devices' setting	This policy setting disallows Autoplay for MTP devices like cameras or phones. If this setting is not configured, then attacker could use this feature to launch a program to damage a client computer or data on the computer.	Enabled
Status of the 'default behavior for AutoRun'	This policy setting allows you to set the default behaviour for Autorun commands. Autorun commands are generally stored in autorun.inf files. These commands enable applications to start, start installation programs, or start other routines. If this setting is not configured, this code may be executed without user's knowledge or consent, which may lead to security concerns.	Enabled: Do not execute any autorun commands
Status of the 'Turn off Microsoft consumer experiences' setting	The policy 'Turn off Microsoft consumer experiences' setting turns off experiences that help consumers make the most of their devices and Microsoft account. Not configuring this setting allows users to see suggestions from Microsoft and notifications about their Microsoft account, which may not meet the security requirements of your organization.	Enabled
Status of 'Enumerate administrator accounts on elevation' setting	The 'Enumerate administrator accounts on elevation' capability displays the 'administrator' account list on the system. As showing this list may allow a malicious user to target a specific, privileged account for an attack or exploit, this capability should be set.	Disabled
Status of the 'Configure Authenticated Proxy usage for the Connected User Experience and Telemetry service' (DisableEnterpriseAuthProxy) Group Policy setting	'Configure Authenticated Proxy usage for the Connected User Experience and Telemetry service' group policy setting controls whether the Connected User Experience and Telemetry service can automatically use an authenticated proxy to send data back to Microsoft. Sending any data to a 3rd party vendor is a security concern and should only be done on an as needed basis.	Enabled: Disable Authenticated Proxy usage
Status of the 'Enable App Installer Local Archive Malware Scan Override' setting on the host	The Enable App Installer Local Archive Malware Scan Override setting allows users to bypass malware scanning when installing applications from local archives. This increases the risk of malware infections, privilege escalation, ransomware, and supply chain attacks if compromised packages are installed. To mitigate risks, disable this policy, enforce malware scanning, restrict installations to trusted sources, implement application allowlisting, and monitor system logs. These steps prevent unauthorized software deployment and enhance system security by ensuring that all installed applications are verified and safe.	Disabled
Status of the 'Enable App Installer Microsoft Store Source Certificate Validation Bypass' setting on the host	The Enable App Installer Microsoft Store Source Certificate Validation Bypass setting controls whether certificate validation is enforced for Microsoft Store applications. Disabling validation exposes systems to malware, supply chain attacks, privilege escalation, and MITM exploits. Attackers could inject malicious code into application packages, leading to system compromise. To mitigate risks, disable this policy, enforce signed app installations, monitor application activity with WDAC/AppLocker, use endpoint security tools, and audit system logs. These measures	Disabled

	ensure that only verified and trusted applications are installed, reducing attack surfaces.	
Status of the 'Application: Control Event Log behavior when the log file reaches its maximum size' setting	The 'Application: Retain old events' Group Policy setting stops logging events when a maximum file size limit is reached. As this setting may conflict with established continuous logging requirements for forensic purposes, this setting should be configured.	Disabled
Status of the 'Application: Maximum log size' setting (in KB)	The 'Application Event Log' provides a standardized method for Windows applications, such as services or other system-integrated applications, to log application (for local or remote viewing) of each instance of an application start, stop, or status change. System logging and adequate log storage is essential to auditing/tracking system security events, but this can be difficult to balance. As log files need enough space to retain a useful longitudinal baseline, yet be limited in size, to prevent the output itself from becoming a Denial of Service (DoS) attack (by filling up the disk storage) the permitted log size should be set.	Enabled: 32,768 or greater
Status of the 'Security: Control Event Log behavior when the log file reaches its maximum size' setting	The [GPO-based] 'Security: Retain old events' Group Policy setting stops logging events when a maximum file size limit is reached. As this setting may conflict with established continuous logging requirements for forensic purposes, this setting should be configured.	Disabled
Status of the 'Security: Maximum log size' setting (in KB)	The GPO-based 'Security Log' provides information on security events, such as login and privilege use. As these files can become DoS triggers if allowed to grow continuously but still need to be large enough to retain a useful amount of data for performing a forensic investigation, the value restricting Security Log size should be set.	Enabled: 196,608 or greater
Status of the 'Setup: Maximum Log Size (KB)' setting	The 'Setup: Maximum Log Size (KB)' setting specifies the maximum size of the log file in kilobytes. If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users. This setting should be restricted.	Enabled: 32,768 or greater
Status of the 'System: Control Event Log behavior when the log file reaches its maximum size' Group Policy setting	The 'System: Retain old events' Group Policy setting stops logging events when a maximum file size limit is reached. As this setting may conflict with established continuous logging requirements for forensic purposes, this setting should be configured.	Disabled
Status of the 'System: Maximum log size' setting (in KB)	The GPO-based 'System Event Log' provides information on [operating] system events, such as OS segment startup events, such as the 'Routing/Remote Access' service and the associated events that occur during process initialization. By setting the 'Max System Event Log Size' guidelines to an appropriate value, this can prevent the log file from becoming a DoS trigger (if it were allowed to grow unchecked) but still be of sufficient size to retain a useful amount of data for doing a forensic investigation.	Enabled: 32,768 or greater
Status of the 'Turn off Data Execution Prevention for Explorer' setting	The 'Turn off Data Execution Prevention for Explorer' policy setting can allow certain legacy plug-in applications to function without terminating Window Explorer. As permitting Explorer to continue functioning during the operation of these applications can permit the introduction of malware into Explorer, this capability should be set.	Disabled
Status of the 'Block all consumer Microsoft account user authentication'	'Block all consumer Microsoft account user authentication' group policy setting determines whether applications and services on the device can utilize new consumer Microsoft account authentication via the Windows OnlineID and WebAccountManager APIs. Organizations that want to	Enabled

(DisableUserAuth) Group Policy setting	effectively implement identity management policies and maintain firm control of what accounts are used on their computers will probably want to block Microsoft accounts. Organizations may also need to block Microsoft accounts to meet the requirements of compliance standards that apply to their information systems. To prevent applications and services from utilizing this type of authentication, this setting should be enabled.	
Status of the 'Enable EDR in block mode' setting on the host	The Enable EDR in block mode setting determines whether Microsoft Defender detects and logs threats without actively remediating them when in Passive Mode. It is primarily used alongside third-party antivirus solutions to avoid conflicts. Misconfiguration may leave the system vulnerable to malware persistence, privilege escalation, and data exfiltration attacks. To prevent risks, configure the setting to match your security environment. For standalone use, disable Passive Mode and enable active real-time protection. Hybrid environments should prioritize third-party antivirus functionality. Regular monitoring of registry settings and logs ensures effective threat detection and response.	Enabled
Status of the 'Do not allow location redirection' setting	This policy 'Do not allow location redirection' setting controls the redirection of location data to the remote computer in a Remote Desktop Services session. In a more security-sensitive environment, it is desirable to reduce the possible attack surface. If this policy is enabled, users cannot redirect their location data to the remote computer. If this policy is disabled do not configure, users can redirect their location data to the remote computer.	Enabled
Status of the 'Turn on Basic feed authentication over HTTP' Windows group policy setting for RSS Feeds (Internet Explorer)	Windows allows Basic authentication scheme over an unencrypted HTTP connection for user feeds. It is recommended to disable basic authentication as it is vulnerable as it uses plain text passwords that could be used to compromise a system.	Disabled
Status of the 'Turn off KMS Client Online AVS Validation' setting	The policy 'Key Management Service (KMS)' setting is a Microsoft license activation method that entails setting up a local server that stores the licenses. The server itself needs to connect to Microsoft to activate the KMS service, but subsequent on-network clients can activate Microsoft Windows OS and/or their Microsoft Office via the KMS server instead of connecting directly to Microsoft. Preventing this information from being sent can help reduce privacy concerns.	Enabled
Status of the 'Windows Installer: Set Always install with elevated privileges' setting	The Windows Installer: Set Always install with elevated privileges setting can require the use of elevated privileges for the installation of any program on the system. As without elevated privileges, program installation applies the current user's permissions during program installation, this value should be set.	Disabled
Status of the 'Enable MPR notifications for the system' setting	The MPR notification configuration in Winlogon is controlled by this policy. If you enable this setting or do not configure it Winlogon sends MPR notifications if a credential manager is configured. If you disable this setting Winlogon does not send MPR notifications.	Disabled
Status of the 'Sign-in last interactive user automatically after a system-initiated restart' setting	The 'Sign-in last interactive user automatically after a system-initiated restart' setting specifies if the device will automatically sign-in the last interactive user after Windows Update restarts the system. If the setting is not specified malicious users can gain access and can be able to compromise the system.	Disabled

Status of the 'Turn on PowerShell Script Block Logging' setting	The policy 'PowerShell Script Block Logging' allow you to enable logging of all PowerShell script which is input to the Microsoft-Windows-PowerShell/Operational event log. If this setting is not configured, then potential risks of capturing passwords in the logs may emerge. This setting should only be used for debugging purposes, not in normal operation.	Enabled
Status of the 'Disallow Digest authentication' setting (WinRM client)	The 'Disallow Digest authentication' policy setting allows you to manage whether the Windows Remote Management (WinRM) client will not use Digest authentication. If this policy is enabled, the WinRM client will not use Digest authentication. If the policy setting is disabled/not configured, the WinRM client will use Digest authentication. Digest authentication is less robust than other authentication methods available in WinRM, if an attacker get the access over the network where WinRM is running may be able to get the credentials used for the access via WinRM.	Enabled
Status of the 'Allow Basic authentication' setting (WinRM service)	The 'Allow Basic authentication' policy setting allows you to manage whether the Windows Remote Management (WinRM) service accepts Basic authentication from a remote client. If this policy setting is enabled, the WinRM service will accept Basic authentication from a remote client. If the setting is disabled or not configured, the WinRM service will not accept Basic authentication from a remote client. Basic authentication is less powerful than other authentication methods, it's because login credentials including passwords are transmitted in plain text. An attacker can easily get the credentials that are used to access remote hosts via WinRM.	Disabled
Status of the 'Select when Feature Updates are received - DeferFeatureUpdatesPeriodInDays' setting	Forcing new features without prior testing in your environment could cause software incompatibilities as well as introducing new bugs into the operating system. In a controlled corporate environment, it is generally preferred to delay the feature updates until thorough testing, and a deployment plan is in place. This recommendation delays the automatic installation of new features as long as possible.	Enabled: 180 or more days
Status of the 'Select when Quality Updates are received' on the host	The 'Select when Quality Updates are received' setting allows businesses to control when important updates, including bug fixes and security patches, are applied, balancing timely updates with operational needs. Similarly, the 'Allow Diagnostic Data' policy governs how much data is sent to Microsoft, affecting only system-related apps, and presents a security concern if shared with third parties. Both settings should be carefully configured to ensure security without compromising functionality or privacy.	Enabled:0 days

4.16 Member Server configuration

The following security policies must be configured only for Windows in case the Windows Server is running the Active Directory must be comply with values recommended in 2.21 Section.

Policy Name	Description	Recommended Value
Current list of Groups and User Accounts granted the 'Manage Auditing and Security Log (SeSecurityPrivilege)' right	The 'Manage Auditing and Security Log' (SeSecurityPrivilege) privilege assignment determines which user can specify 'object access' audit monitoring for various resources, such as files, registry keys, and AD items. (In the default configuration for all Windows systems, this is assigned only to Administrators.) Assigning user	Administrators

	accounts to this privilege does allow/enable the assignees to carry out generalized object or access auditing--to have that occur it must be enabled in the 'Computer Configuration\Windows Settings\Security Settings\Local Policies\Audit Policies' setting. As any holder of this privilege can clear the log files, to preserve system audit trails, this capability should be restricted.	
Status of the 'Create Symbolic Links' (SeCreateSymbolicLinkPrivilege) right	The 'Create Symbolic Links' (SeCreateSymbolicLinkPrivilege) setting allow user to link and potentially change permissions on files. As this capability can permit a malicious user to exploit security vulnerabilities in an application resource that was not designed to use symbolic links, this should be restricted.	Administrators, NT VIRTUAL MACHINE\Virtual Machines
Current list of Groups and User Accounts granted the 'Deny Access to this computer from the network' right	The 'Deny Access to this computer from the network' user right revokes the right of a User to interact with this Windows system remotely. As this right can lock out both potentially malicious users and those who require system access, it should be configured according to the needs of the business. CAUTION: If the 'Everyone' group is added to this setting, ALL systems will be blocked from accessing this system remotely. Also, as the Qualys scan uses the 'Administrator' login by default to run its checks, one should be very careful about adding the 'ADMINISTRATOR' to this group, as it will block network-based local or 'BUILTIN' 'Administrator' access.	Guests, Local account and member of Administrators group
Current list of Groups and User Accounts granted the 'Impersonate a client after authentication' right	The 'Impersonate a client after authentication' user right allows programs that are run of behalf of the user to impersonate a client. A common usage of this permission is to grant the right to a service account in order to pass client authentication to another service. In the default installation this right is only assigned to Administrators and Service. As the 'Impersonate a client after authentication' user right allows the impersonation of a user with specific rights, the granting of this right to Groups and User Accounts should be restricted.	Administrators, SERVICE, Local Service, Network Service, IIS Users and Microsoft SQL Users
Current list of Groups and User Accounts granted the 'Access this computer from the network' right	The 'Access this computer from the network' right allows a User to interact with remote Windows systems. By Windows default, all user/computer accounts are granted this right when the 'Everyone' group is included during initial configuration	Administrators, Authenticated users
Current list of Groups and User Accounts granted the 'Enable computer and user accounts to be trusted for delegation' right	The 'Enable computer and user accounts to be trusted for delegation (SeEnableDelegationPrivilege)' privilege is not assigned to any system but a domain controller, as it permits a computer/user to alter the 'Trusted for Delegation' setting for objects in Active Directory (Workstations and Servers that are not functioning as Domain Controllers can also be checked to ensure default values have not been changed in the Local Security Policy). This will allow a front-end service/process to function with the rights of a given client's credentials when authenticating itself to a back-end process/service. As this user right should be limited to Domain Controller Administrators and can be a powerful method to facilitate system penetration, allowing Trojans to send out under impersonated accounts.	No one
Current list of Groups and User Accounts granted the 'Allow logon through Terminal Services' right	The 'Allow logon through Terminal Services' right allows user logon via a Remote Desktop Protocol (RDP) connection. (In the default installation, this is limited to Administrators and Remote Desktop Users.) Any Group or User Account granted this user right is permitted to logon via Remote Desktop Protocol. As the ability to logon via Terminal Services can allow a malicious user to initiate a	Administrators, Remote Desktop Users

	Denial-of-Service attack, Groups and User Accounts granted the 'Allow logon through Terminal Services' right should be restricted.	

4.17 Domain Controller configuration

The following security policies must be configured only for Windows Servers are running the Active Directory role.

Policy Name	Description	Recommended Value
Current list of Groups and User Accounts granted the 'Manage Auditing and Security Log (SeSecurityPrivilege)' right	The 'Manage Auditing and Security Log' (SeSecurityPrivilege) privilege assignment determines which user can specify 'object access' audit monitoring for various resources, such as files, registry keys, and AD items. (In the default configuration for all Windows systems, this is assigned only to Administrators.) Assigning user accounts to this privilege does allow/enable the assignees to carry out generalized object or access auditing--to have that occur it must be enabled in the 'Computer Configuration\Windows Settings\Security Settings\Local Policies\Audit Policies' setting. As any holder of this privilege can clear the log files, to preserve system audit trails, this capability should be restricted.	Administrators, Exchange Servers
Status of the 'Create Symbolic Links' (SeCreateSymbolicLinkPrivilege) right	The 'Create Symbolic Links' (SeCreateSymbolicLinkPrivilege) setting allow user to link and potentially change permissions on files. As this capability can permit a malicious user to exploit security vulnerabilities in an application resource that was not designed to use symbolic links, this should be restricted.	Administrators
Current list of Groups and User Accounts granted the 'Deny Access to this computer from the network' right	The 'Deny Access to this computer from the network' user right revokes the right of a User to interact with this Windows system remotely. As this right can lock out both potentially malicious users and those who require system access, it should be configured according to the needs of the business. CAUTION: If the 'Everyone' group is added to this setting, ALL systems will be blocked from accessing this system remotely. Also, as the Qualys scan uses the 'Administrator' login by default to run its checks, one should be very careful about adding the 'ADMINISTRATOR' to this group, as it will block network-based local or 'BUILTIN' 'Administrator' access.	At least group ‘Guests’
Current list of Groups and User Accounts granted the 'Impersonate a client after authentication' right	The 'Impersonate a client after authentication' user right allows programs that are run of behalf of the user to impersonate a client. A common usage of this permission is to grant the right to a service account to pass client authentication to another service. In the default installation this right is only assigned to Administrators and Service. As the 'Impersonate a client after authentication' user right allows the impersonation of a user with specific rights, the granting of this right to Groups and User Accounts should be restricted.	Administrators, SERVICE, Local Service, Network Service
Current list of Groups and User Accounts granted the 'Access this computer from the network' right	The 'Access this computer from the network' right allows a User to interact with remote Windows systems. By Windows default, all user/computer accounts are granted this right when the 'Everyone' group is included during initial configuration	Administrators, ENTERPRISE DOMAIN CONTROLLERS, Authenticated users

Current list of Groups and User Accounts granted the 'Enable computer and user accounts to be trusted for delegation' right	The 'Enable computer and user accounts to be trusted for delegation (SeEnableDelegationPrivilege)' privilege is not assigned to any system but a domain controller, as it permits a computer/user to alter the 'Trusted for Delegation' setting for objects in Active Directory (Workstations and Servers that are not functioning as Domain Controllers can also be checked to ensure default values have not been changed in the Local Security Policy). This will allow a front-end service/process to function with the rights of a given client's credentials when authenticating itself to a back-end process/service. As this user right should be limited to Domain Controller Administrators and can be a powerful method to facilitate system penetration, allowing Trojans to send out under impersonated accounts.	No one, Administrators
Current list of Groups and User Accounts granted the 'Allow logon through Terminal Services' right	The 'Allow logon through Terminal Services' right allows user logon via a Remote Desktop Protocol (RDP) connection (In the default installation, this is limited to Administrators and Remote Desktop Users). Any Group or User Account granted this user right is permitted to logon via Remote Desktop Protocol. As the ability to logon via Terminal Services can allow a malicious user to initiate a Denial-of-Service attack, Groups and User Accounts granted the 'Allow logon through Terminal Services' right should be restricted.	Administrators

4.18 Administrative Templates (User)

Policy Name	Description	Recommended Value
Status of the "Do not preserve zone information in file attachments" setting for Windows users	The 'Do not preserve zone information in file attachments' Group Policy setting restricts the display of network information in file attachments. As this setting can either reveal or restrict private network information that may be used for exploits, this setting should be configured.	Disabled
Status of the 'Prevent users from sharing files within their profile' setting	The 'Prevent users from sharing files within their profile' setting enables or disables file sharing among users. As this setting could facilitate the unauthorized sharing of confidential information, it should be configured.	Enabled
Status of the 'Always install with elevated privileges' setting for Windows User	The policy 'Always install with elevated privileges' setting can require the use of elevated privileges for the installation of any program on the system. As without elevated privileges, program installation applies the current user's permissions during program installation, this value should be set.	Disabled

4.19 External Regulatory Requirements

Policy Name	Description	Recommended Value
Telnet Server service status	The 'telnet' service provides a CLI-based connection to the system. As telnet has weak authentication (cleartext credentials) and the traffic is not encrypted, this should be disabled.	Ensure Telnet Server service is not running
Status of the 'Microsoft FTP (Publishing) Service'	The 'Microsoft FTP Service' provides support for running the File Transfer Protocol (FTP) on the system. This is installed with the Internet Information Service (IIS). This service	Disabled

	allows others to connect to the system through the IIS snap-in with features such as user isolation, throttling for usage of bandwidth, and logging.	
Status of the PowerShell version	PowerShell is a task automation and configuration management framework from Microsoft. Ensure PowerShell is up to date with latest security updates. It helps to reduce the risk associated with known vulnerabilities present in the software.	At least PowerShell 5.1
Status of 'Turn on PowerShell Script Block Logging' setting	The 'Turn on PowerShell Script Block Logging' setting manage the event logging of PowerShell script. If the policy is set to enable, it logs the processing of commands, script blocks, functions, and scripts through user interaction or through automation.	EnableScriptBlockLogging = 1
TFTP Protocol	TFTP protocol uses reserved port 69, so when service is up and running, it will be listening on this port	Ensure TFTP port is not listening
SMTP Protocol	The 'Simple Mail Transport Protocol (SMTP)' service evolved out of the original DARPA requirements and is used to send electronic communications, usually called 'email.' If SMTP is enabled and executed maliciously, an attacker could potentially exploit the service to steer customers away from the company, bring harm to the reputation of the company, or use the messaging services or the organization for personal gain, generating a flood of SPAM. As SMTP is based on a set of protocols that were designed before security was a major concern and has a history of vulnerabilities, especially those that allow message forging, coupled with the fact that ordinary systems are not typically used as SMTP mail servers, this capability should be disabled.	Ensure SMTP port is not listening
Delete credentials after logging off registry	Delete credentials after 30 seconds maximum when logging off.	Less or Equal than 30 seconds
Status of the 'Prevent local guests group from accessing system log' setting	The 'System Log' provides information on system events, such as OS process startup/error activity. As this log preserves the pattern of OS process connections and any errors that occur, along with the time of the event occurrence, this information should be restricted as appropriate, to prevent 'guest' or unauthorized users from obtaining this information.	Yes
Status of the audit setting 'Process Termination' (advanced audit setting)	The 'Process Termination' audit policy setting tracks attempts to end a process. This event is generated when a process exits. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled.	Success (1)
Crowd Strike Service Status	CrowdStrike's next-gen antivirus protects against all types of attacks from commodity malware to sophisticated attacks with one solution.	"CSFalconService" running
Status of the 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run' registry key	The 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run' is the Winlogon key that controls actions that occur when a user logs on to a computer. These programs will be executed under the context of the user and will have the account's associated permissions level. Adversaries may achieve persistence by referencing a malicious program with a Registry run key. Adversaries may also use Masquerading to make the Registry entries look as if they are associated with legitimate programs.	Audit Creation and Update

Status of the 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\RunOnce' registry key	The 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\RunOnce' is the Winlogon key that controls actions that occur when a user logs on to a computer. These programs will be executed under the context of the user and will have the account's associated permissions level. Adversaries may achieve persistence by referencing a malicious program with a Registry run key. Adversaries may also use Masquerading to make the Registry entries look as if they are associated with legitimate programs.	Audit Creation and Update
Status of the 'HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Session Manager' registry key	The 'HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Session Manager' is the Winlogon key that controls actions that occur when a user logs on to a computer. These programs will be executed under the context of the user and will have the account's associated permissions level. Adversaries may achieve persistence by referencing a malicious program with a Registry run key. Adversaries may also use Masquerading to make the Registry entries look as if they are associated with legitimate programs.	Audit Creation and Update
Status of the 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\Shell' registry key	The 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\Shell' is the Winlogon key that controls actions that occur when a user logs on to a computer. These programs will be executed under the context of the user and will have the account's associated permissions level. Adversaries may achieve persistence by referencing a malicious program with a Registry run key. Adversaries may also use Masquerading to make the Registry entries look as if they are associated with legitimate programs.	Audit All
Status of the 'HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon' registry key	The 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon' is the Winlogon key that controls actions that occur when a user logs on to a computer. These programs will be executed under the context of the user and will have the account's associated permissions level. Adversaries may achieve persistence by referencing a malicious program with a Registry run key. Adversaries may also use Masquerading to make the Registry entries look as if they are associated with legitimate programs.	Audit All
Status of the 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\Userinit' registry key	The 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\Userinit' is the Winlogon key that controls actions that occur when a user logs on to a computer. These programs will be executed under the context of the user and will have the account's associated permissions level. Adversaries may achieve persistence by referencing a malicious program with a Registry run key. Adversaries may also use Masquerading to make the Registry entries look as if they are associated with legitimate programs.	Audit All

4.2 ACTIVE DIRECTORY

The following security policies must be configured additionally Windows Server Policies, in case the Windows Server is running the Active Directory services as well.

4.2.1 Active Directory Audit Policies

These policies are configured in: *Computer Configuration\Policies\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies.*

Policy Name	Description	Recommended Value
Status of the audit setting 'Kerberos Authentication Service' (advanced audit setting)	The 'Kerberos Authentication Service' audit policy provides a method of tracking events which are generated as the result of user account Kerberos ticket-granting ticket requests to be used for accessing Active Directory objects. This can be configured to track both successful and failed requests which can be used in forensic and/or troubleshooting efforts. Depending on the type and size of a given company, the enablement of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled.	Success and Failure (3)
Status of the audit setting 'Kerberos Service Ticket Operations' (advanced audit setting)	The 'Kerberos Service Ticket Operations' security policy setting tracks activities generated by Kerberos service ticket requests. Some of these include requests and renewals for Kerberos service tickets. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled.	Success and Failure (3)
Status of the audit setting 'Other Logon/Logoff Events' (advanced audit setting)	The 'Other Logon/Logoff Events' security policy setting tracks additional logon/logoff events such as wired or wireless authentications, screen saver invocations or dismissals, and remote desktop session re-connections and disconnections. Depending upon regulatory requirements, these audit policy settings may be required. As with all critical systems and devices, audit settings and logs should be enabled.	Success and Failure (3)
Status of the audit setting 'Distribution Group Management' (advanced audit setting)	The 'Distribution Group Management' security policy setting allows users to join existing groups, manage properties of groups, membership in groups and even create/remove groups. As having this capability exploited by and unauthorized user can compromise any proprietary data in these groups, group membership should be restricted.	Success and Failure (3)
Status of the audit setting 'Directory Service Access' (advanced audit setting)	The 'Audit Directory Service Access' security policy setting tracks events when AD Domain Services (DS) objects are accessed. Each time an AD DS object is accessed an event is captured in the audit log. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled.	Failure (2)
Status of the audit setting 'Computer Account Management' (advanced audit setting)	The 'Computer Account Management' audit policy setting tracks activities around managing computer accounts. Examples of these activities include creating, deleting, and modifying computer accounts. Depending on the type and size of a given company, the use of audit logs may be	Success

	required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled, monitored and managed.	
Status of the audit setting 'Other Account Management Events' (advanced audit setting)	The 'Other Account Management Events' security policy setting tracks user account management events. Some of these events include access of an account password hash and when an API call is made for Password Policy Checking. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled, monitored and managed.	Success

4.2.2 Active Directory Specific requirements

Policy Name	Description	Recommended Value
Status of the 'Lock screen camera' setting	The 'Lock screen camera' setting specifies if the Camera feature should be available on the lock screen or not. If the setting is not specified malicious users can gain the access over the camera and can be able to compromise the system.	Enabled
Status of the 'Lock screen slide show' setting	The 'Lock screen slide show' setting specifies if slide show can be played on the lock screen. If the setting is not specified malicious users can gain access over the slide show content and compromise the system.	Enabled
Status of the 'Enable insecure guest logons' setting	The policy 'Enable insecure guest logons' setting determines if the SMB client will allow insecure guest logons to an SMB server. Insecure guest logons are used by file servers to allow unauthenticated access to shared folders. While uncommon in an enterprise environment, insecure guest logons are frequently used by consumer Network Attached Storage (NAS) appliances acting as file servers. Windows file servers require authentication and do not use insecure guest logons by default. If this setting is not configured, then clients can allow insecure guest logons which are vulnerable to a variety of man-in-the-middle attacks that can result in data loss, data corruption, and exposure to malware.	Disabled
Status of the 'Registry policy processing (Option: Do not apply during periodic background processing)' setting	The 'Registry policy processing' settings determine when registry policies will be updated and affects the policies existing within the 'Administrative Templates' folder, as well as all additional policies that have values stored within the registry. By enabling this, registry settings that were 'customized' by a user will be overridden and the approved/appropriate settings will be applied.	Disabled
Status of the 'Configure security policy processing: Do not apply during periodic background processing' setting	The 'Registry policy processing' settings determine when registry policies will be updated and affects the policies existing within the 'Administrative Templates' folder, as well as all additional policies that have values stored within the registry. By enabling this, registry settings that were 'customized' by a user will be overridden and the approved/appropriate settings will be applied.	Disabled
Status of 'Process even if the Group Policy objects have not changed' setting in Configure Registry	The Registry policy processing option 'Process even if the Group Policy objects have not changed' reapplies group policies even when policies have not changed. As updating policies while the system is in use can potentially damage	Enabled

preference extension policy processing GPO	data, while reapplying the policy can potentially lock out an intruder.	
Status of the 'Do not display network selection UI' setting	The 'Do not display network selection UI' setting specifies whether anyone can interact with available networks UI on the logon screen. If the setting is not specified unauthorized user could disconnect the PC from the network or can connect the PC to other available networks without signing into Windows and can be able to compromise the system.	Enabled
Status of the 'Do not show feedback notifications' setting	The policy 'Do not show feedback notifications' setting allows an organization to prevent its devices from showing feedback questions from Microsoft. If this setting is not configured, users may confidential information through feedback.	Enabled
Status of the audit setting 'Directory Service Changes' (advanced audit setting)	The 'Directory Service Changes' security policy setting tracks events when AD Domain Services (DS) objects are changed. Each time an AD DS object is created, changed, deleted/undeleted, or moved an event is captured in the audit log. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled.	Success and Failure (3)
Status of the 'Domain controller: LDAP server channel binding token requirements' setting	The 'Domain controller: LDAP server channel binding token requirements' security setting determines whether the LDAP server enforces validation of Channel Binding Tokens received in LDAP bind requests sent over LDAPS connections. This feature enhances the protection and handling of credentials when authenticating network connections using Integrated Windows Authentication (IWA).	Always (2)
Current list of Groups and User Accounts granted the 'Add workstations to domain' right	The 'Add workstations to domain' user right allows the assigned user to add a system to the domain in which the right is granted. This privilege is granted by default: any 'authenticated user' can add as many as 10 [computer] accounts to a given domain. Otherwise, this right must be assigned to the user and included as part of the domain's 'Default Domain Controllers Policy.' If a User has the 'Create Computer Objects' permission for any organizational unit, or for the 'Computers' AD container in a domain, that user can add an unlimited number or workstations to the domain. As this method of granting the right to add workstations could be difficult to track during an audit, for the system would be added based on the 'computer container' permissions rather than on the individuals 'user right,' this right should be limited.	Administrators
Current list of Groups and User Accounts granted the 'Log on as a batch job (SeBatchLogonRight)' right	The 'Log on as a batch job (SeBatchLogonRight)' user right allows the use of the 'Task Scheduler.' (During the default installation, it is assigned to the 'Administrator,' 'System,' and 'Support_xxxxxxxx' (the 'Remote Assistance'-linked account). As this right can be used to run a scheduled task under a specific users' security context and may otherwise allow privilege escalation, this setting should be restricted.	Administrators
Current list of Groups and User Accounts granted the 'Synchronize directory service data (SeSyncAgentPrivilege)' right	The 'Synchronize directory service data (SeSyncAgentPrivilege)' user right allows the user or process to read/synchronize the objects in Active Directory, regardless of access controls on the object. (In the default configuration, this right is assigned only to Administrators on Domain Controllers (DCs) and has no applicability to Member Servers, Workstations, and Servers that are not functioning as Domain Controllers; it can, however, be checked to ensure default values have not been changed in	No One

	the Local Security Policy). As this right can transverse the AD tree on a DC and read all object configurations regardless the permissions levels, it should be restricted.	
Status of the 'Domain controller: Allow vulnerable Netlogon secure channel connections (Security descriptor)' Group policy setting	This security setting determines whether the domain controller bypasses secure RPC for Netlogon secure channel connections for specified machine accounts. Enabling this policy will expose your domain-joined devices and your Active Directory Forest, which could put them at risk. When the Create Vulnerable Connections list (allow list) is configured: Given allow permission, the domain controller will allow accounts to use a Netlogon secure channel without secure RPC. Given deny permission, the domain controller will require accounts to use a Netlogon secure channel with secure RPC which is the same as the default (not necessary).	Not Configured
Status of the 'Domain Controller: LDAP Server Signing Requirements' setting	The 'LDAP Server Signing Requirements' setting determines whether LDAP traffic is signed during transit. This provides a way to ensure the domain controller signs data, which is sent to the client, thus allowing the client to be sure the data was not modified by a man-in-the-middle attack while in transit. (This can be critical in many environments, as the client bases security decisions on LDAP-query results.) As requiring signing of LDAP transmissions by Domain Controllers can thwart man-in-the-middle and data-replay attacks, this should be set. NOTE: Enabling this setting only guarantees the identities of the systems involved and does not encrypt the data in transit.	Require signing
Status of the 'Domain controller: LDAP server signing requirements Enforcement' setting on the host	The Domain controller: LDAP server signing requirements Enforcement setting enforces whether LDAP clients must sign communications with domain controllers. Without LDAP signing, attackers can perform MITM attacks and LDAP relay attacks to intercept credentials and manipulate data. To mitigate these risks, set the policy to "Require signing," enable LDAP signing on clients, use LDAPS for encryption, and monitor event logs for unsigned LDAP traffic. Before enforcing, ensure all applications support signed LDAP requests to prevent authentication failures.	Enabled
Status of the 'Domain Controller: Refuse machine account password changes' setting	The 'Refuse machine account password change' setting allows domain controllers, to permit/refuse regular domain-based systems' to complete a 'machine account password change' request. As a malicious user can use this to gain access to sensitive information or privileges when no automatic change requirement is set, this should be set. NOTE: The manufacturer default for this password is 'Change every 30 days.'	Disabled
Status of the 'Configure validation of ROCA-vulnerable WHfB keys during authentication' setting	This policy setting allows you to configure how Domain Controllers handle Windows Hello for Business (WHfB) keys that are vulnerable to the Return of Coppersmith’s Attack (ROCA) vulnerability. The Return of Coppersmith’s attack or ROCA vulnerability is a cryptographic weakness in a widely used cryptographic library. An attacker can reveal secret keys (offline with no physical access to the affected device) on certified devices using this library.	Enabled: Audit or Enabled: Block

External Regulatory Requirements

Policy Name	Description	Recommended Value
Configure 'Network Security:Restrict NTLM: Outgoing NTLM traffic to remote servers'	NTLM and NTLMv2 authentication is vulnerable to a variety of malicious attacks, including SMB replay, man-in-the-middle attacks, and brute force attacks. Reducing and eliminating NTLM authentication from your environment forces the Windows operating system to use more secure protocols, such as the Kerberos version 5 protocol, or different authentication mechanisms, such as smart cards. As an example, one of such recent vulnerabilities is zero-day Vulnerability published on 1apr2020 on Zoom windows client. Attacker can exploit Zoom Windows client using UNC path injection to expose credentials for use in SMBRelay attacks. When SMB service is disabled or Outbound SMB port connection is disabled from firewall, attack does not work. The 'Network Security:Restrict NTLM: Outgoing NTLM traffic to remote servers' setting denies or audits outgoing NTLM traffic to any windows remote server. If option 'Allow All' is selected or if this setting is not configured, the client computer can authenticate identities to a remote server by using NTLM authentication. In case of a compromised server, client computer could authenticate itself to a poisoned server and would at risk of compromising the sensitive data such as credentials etc. In case of a compromised client, client computer could send sensitive data to the server. If 'Audit All' is selected, the client computer logs an event for each NTLM authentication request to a remote server. This allows identifying the servers receiving NTLM authentication requests from the client computer. If 'Deny All' is selected, client computer cannot authenticate identities to a remote server by using NTLM authentication.	Audit all
Status of the 'Network Security:Restrict NTLM: Audit Incoming NTLM Authentication in this domain' setting	The Restrict NTLM: Audit Incoming NTLM Authentication in this domain setting provides for the audit of the domain controller's NTLM authentication process. As enabling this policy setting on the domain controller limits the audit capability to only authentication traffic on that domain controller.	Enable all
Status 'Network Security:Restrict NTLM: Audit Incoming NTLM Traffic' setting	The Network security: Restrict NTLM: audit Incoming NTLM traffic setting allows for the auditing of all incoming NTLM traffic. As the policy does not block any traffic when enabled, therefore, it can be used to effectively monitor traffic.	Enable auditing for all accounts
Azure Advanced Threat Protection Sensor Service	Microsoft Defender for Identity (formerly Azure Advanced Threat Protection, also known as Azure ATP) is a cloud-based security solution that leverages your on-premises Active Directory signals to identify, detect, and investigate advanced threats, compromised identities, and malicious insider actions directed at your organization.	Ensure ATP sensor is enabled
Azure AD Password Protection Service Status	Azure AD Password Protection for Windows Server Active Directory is used to prevent weak passwords being used in the organization using Windows Server Active Directory. Azure AD Password Protection helps you establish comprehensive defence against weak passwords in your on-premises environment. With Azure AD Password Protection, you will be able to protect all password set and reset operations in Azure and Windows Server Active Directory by ensuring they do not contain weak or leaked password strings.	Enforce PWD security

4.3 ADFS

The following security policies must be configured additionally Windows Server Policies, in case the Windows Server is running the ADFS services as well and web Application Proxy (WAP).

4.3.1 ADFS Initial System Configuration

Only the necessary and dependent services which are active with the ADFS will remain active.

Policy Name	Description	Recommended Value
Status of Application Identity Service	The 'Application Identity' policy setting determines and verifies the identity of an application. If this service is disabled, it will prevent AppLocker from being enforced.	AppIDSvc disabled
Status of the 'Application Experience Lookup' service	The 'Application Experience Lookup' service was introduced in Windows Server 2003 Service Pack 1 (SP1) and is responsible for automatically applying software updates that ensure programs are running on the latest released service packs and Windows OS versions. It is part of the 'Application Compatibility Administrator' and reports on any issues related to compatibility so updates can be applied to the programs and must always be running as it is used by the OS internally.	AeLookupSvc disabled
Status of the 'Application Layer Gateway (ALG)' service	The 'Application Layer Gateway (ALG)' service provides support for third party protocol plug-ins for Internet Connection Sharing and the Windows Firewall. Enabling ALG raises the risk of applications attacking the system prior to full firewall instantiation, allowing a malicious user to alter portions of known and/or hidden applications that utilize dynamic/ephemeral Layer 4 ports to communicate with the known ports of a destination host, this value should be disabled.	ALG disabled
Status of the 'Application Management' service	The 'Application Management' service provides 'software installation' services such as Assign, Publish, and Remove (add-on programs for the Windows OS). As the 'Application Management' service has a known Trojan that attempts to use it to create a system backdoor, if not required for system operation, this service should be disabled.	AppMgmt disabled
Status of the 'Startup type' of 'AppX Deployment Service' (AppXSVC)	Provides infrastructure support for deploying Store applications. This service is started on demand and if disabled Store applications will not be deployed to the system and may not function properly.	AppXSvc disabled
Status of the 'Windows Audio Endpoint Builder' service	The 'Windows Audio Endpoint Builder' service supports the operation of the audio devices attached to the Windows Audio services. As unnecessary services can provide vectors for attack by malicious users, this capability should be restricted.	AudioEndpointBuilder disabled
Status of the 'Windows Audio' service	The 'Windows Audio' Service allows for the management of audio devices for Windows-based programs. As this service has a vulnerability, they could facilitate a malicious user to degrade the system's performance, this service should be disabled.	Audiosrv disabled
Status of the 'Distributed Link Tracking Client' service	The 'Distributed Link Tracking Client' maintains links between NTFS files within a computer or across computers in a network domain, based upon updates from the 'Distributed Link Tracking Server' (see CID-1962). As this is required for keeping up links on the NTFS files scattered across the system LAN, this service is set as 'automatically enabled' by default and should be set disabled.	TrkWks disabled

Status of the 'Windows Extensible Authentication Protocol' (EAP) service	The Extensible Authentication Protocol (EAP) service provides network authentication for such scenarios as 802.1x wired and wireless, VPN, and Network Access Protection (NAP). (EAP also provides application programming interfaces, APIs that are used by network access clients, including wireless and VPN clients, during the authentication process.) As unneeded services are often disabled to block the introduction of unknown exploits, disabling this service will block networks that require EAP authentication, so it should be set disabled.	Eaphost disabled
Status of Windows Function Discovery Provider Host Service	The 'Function Discovery' service provides a uniform, program-based interface to detect and list system-based hardware resources, whether local- or network-based in origin. (The applications on the system can also use 'Function Discovery' to determine the system's performance capabilities, regardless of underlying devices or architecture type). As this capability could be subverted by a malicious user to reveal the hardware devices used by the system, its use should be disabled.	fdPHost disabled
Status of the 'Windows Function Discovery Resource Publication' service	The 'Windows Function Discovery Resource Publication' service will put the system's information, including attached resources, out over the network. As allowing publication of system resources on the network can open vectors to attacks, this should be disabled.	FDResPub disabled
Status of the 'Windows Health Key and Certificate Management' service	The 'Windows Health Key and Certificate Management' service operates the X.509 certificate/key management services for the Network Access Protection Agent (NAPAgent). As this service's configuration can impact the use of certificate enforcement, it should be disabled.	hkmsvc disabled
Status of the 'Hyper-V Data Exchange' Service	The 'Hyper-V Data Exchange' service provides a mechanism to exchange data between the virtual machine and the operating system running on the physical computer. Unless virtual machines are configured on the system, this service can be disabled. Any service or application is a potential point of attack. Therefore, any unneeded services or executable files should be disabled or removed from the environment.	vmickvpexchange disabled
Status of the 'Hyper-V Guest Service Interface' service	Hyper-V Guest Service Interface' service provides an interface for the Hyper-V host to interact with specific services running inside the virtual machine. This service provides an interface for the Hyper-V host to bidirectionally copy files to or from the virtual machine. Non-essential services are a potential point of attack. Therefore, non-essential services should be disabled or removed from the environment.	vmicguestinterface disabled
Status of the 'Hyper-V Guest Shutdown' Service	The 'Hyper-V Guest Shutdown' service provides a mechanism to shut down the operating system of the virtual machine from the management interfaces on physical computer. Any service or application is a potential point of attack. Therefore, any unneeded services or executable files should be disabled or removed from the environment.	vmicshutdown disabled
Status of the 'Hyper-V Heartbeat' Service	The 'Hyper-V Heartbeat' service monitors the state of the virtual machine by reporting a heartbeat at regular intervals. This service helps to identify running virtual machines that have stopped responding. Any service or application is a potential point of attack. Therefore, any unneeded services or executable files should be disabled or removed from the environment.	vmicheartbeat disabled
Status of the 'Hyper-V Remote Desktop Virtualization' Service	The 'Hyper-V Remote Desktop Virtualization' provides a platform for communication between the virtual machine and the operating system running on the physical computer,	vmicrdv disabled

	unless you are using virtual machines on your system, this service can be disabled. Any service or application is a potential point of attack. Therefore, any unneeded services or executable files should be disabled or removed from the environment.	
Status of the 'Hyper-V Time Synchronization' service	The 'Hyper-V Time Synchronization' service synchronizes the system time of virtual machine with the system time of the physical computer. Any service or application is a potential point of attack. Therefore, any unneeded services or executable files should be disabled or removed from the environment.	vmictimesync disabled
Status of the 'Hyper-V Volume Shadow Copy Requestor' Service	The 'Hyper-V Volume Shadow Copy Requestor' service coordinates the communications that are required to use Volume Shadow Copy Service to back up applications and data on the virtual machine from the operating system on the physical computer. Any service or application is a potential point of attack. Therefore, any unneeded services or executable files should be disabled or removed from the environment.	vmicvss disabled
Status of the 'KDC Proxy Server' Service	The 'KDC Proxy Server' service runs on edge servers to proxy Kerberos protocol messages to domain controllers on the corporate network. Any service or application is a potential point of attack. Therefore, any unneeded services or executable files should be disabled or removed from the environment.	KPSSVC disabled
Status of the 'Windows Link-Layer Topology Discovery Mapper' service	The 'Windows Link-Layer Topology Discovery Mapper' service produces a network map of each connected device/system in the topology. As this mapping may allow a malicious user to discover devices that have exploitable conditions, the mapper should be disabled.	lltdsvc disabled
Status of the 'Microsoft iSCSI Software Target' Service	The 'Microsoft iSCSI Software Target' provides centralized, software-based and hardware-independent iSCSI disk subsystems in storage area networks (SANs). You can use iSCSI Software Target, which includes a Microsoft Management Console (MMC) snap-in, to create iSCSI targets and iSCSI virtual disks. Any service or application is a potential point of attack. Therefore, any unneeded services or executable files should disable or removed from the environment.	MSiSCSI disabled
Status of the 'Portable Device Enumerator' service	The 'Portable Device Enumerator' service provides for group policy enforcement on removable mass-storage devices, enabling Windows Media Player and other applications to transfer/synchronize content on removable mass-storage devices. As unnecessary services can provide vectors for malware attacks, the Portable Device Enumerator should be disabled.	WPDBusEnum disabled
Status of the 'Print Spooler' service	The 'Print Spooler' allows authenticated users to print the contents of the spooler queue. As print jobs are kept in the spooling area until completely printed and anyone with 'read' access to it can read the spooled jobs with a text editor, this service should be disabled.	Spooler disabled
Status of the 'Printer Extensions and Notifications' service	The 'Printer Extensions and Notifications' opens custom printer dialog boxes and handles notifications from a remote print server or a printer. If this service is turned off printer extensions and notification cannot be shown to users. Any service or application is a potential point of attack. Therefore, any unneeded services or executable files should disable or removed from the environment.	PrintNotify disabled
Status of the 'Problem Reports and Solutions	The 'Problem Reports and Solutions Control Panel Support' service will report/send system problems and information to Microsoft. As the transmission of system information to any	wercplsupport disabled

Control Panel Support' service	third party may risk compromising confidentiality, this capability should be disabled.	
Status of the 'Remote Access Auto Connection Manager' service	The ‘Remote Access Auto Connection Manager (RasAuto)’ creates a connection to a remote network whenever a program references a remote DNS or NetBIOS name or address.	RasAuto disabled
Status of the 'Remote Access Connection Manager (RasMan)' service	The 'Remote Access Connection Manager (RasMan)' service is used for 'Internet Connection Sharing.' As this is unnecessary unless the host is acting as a RRAS server and any remote network connection that could be created by this connection can be exploited to open a separate, routed connection through the system, this service should be disabled.	RasMan disabled
Status of the 'Resultant Set of Policy Provider' group policy setting	The 'Resultant Set of Policy Provider' group policy setting is used to control the enablement and/or disablement of the Resultant Set of Policy (RSoP) service. The associated data for the RSoP is used for performing diagnostics and monitoring of the effects policies have on the domain. As all settings for critical systems should be determined by appropriate personnel, this setting should be disabled.	RSoPProv disabled
Status of the 'Secure Socket Tunneling Protocol' service	The 'Secure Socket Tunneling Protocol' (SSTP) service works from the application-layer and uses synchronous communication. As secure connection protocols can be vulnerable to man-in-the-middle attacks if the key is not carefully protected, this capability should be disabled.	SstpSvc disabled
Status of the 'Simple Network Management Protocol (SNMP) trap' service	A longstanding protocol for the remote management of network devices, Simple Network Management Protocol (SNMP) is known to have dangerous vulnerabilities associated with it that are easily exploitable by malicious users. The 'SNMP Trap' service is another part of the SNMP protocol, which 'traps' and stores SNMP system messages about errors, updates, and so forth. As this can be a major security risk and if the system does not absolutely require it for remote management purposes, it should be disabled.	SNMPTRAP disabled
Status of the 'Special Administration Console Helper' service	The 'Special Administration Console Helper' service is responsible for permitting remote management tasks to be performed on Windows systems that fail to function when stop errors have occurred and messages have been sent. This user mode service enables users to create command prompt channels with administrative access from the SAC prompt by presenting credentials that have administrative level rights. Windows command prompt channels can be used for running text-based tools as if the user were logged on locally such as shell/console commands (e.g., dir, bootcfg.exe). Given the powerful nature of the capabilities this service provides, this should be disabled.	sacsvr disabled
Status of the 'Superfetch' service	The 'Superfetch' service allows for the preloading of local memory with the instructions for applications that are most often used by that system. As this service may improve system performance, it may also provide a vector for attack via the preloaded instructions, so this capability should be disabled.	SysMain disabled
Status of the 'Telephony' service	The 'Telephony' service is used to provide serial-based connections of speeds up to 115Kbps, and can be enabled through a modem, serial, or SCSI-1 ('parallel port') printer cable access to the system. As this service cannot be secured via a password (for local cable connections) and can be used for a war-dialing attack if the host has a dial-up modem for remote management, especially if NULL	tapisrv disabled

	connections are allowed for connecting legacy systems, this capability should be disabled.	
Status of the 'Themes' service	The 'Themes' Service permits the user to make different desktop themes available for use; if you set this to [Automatic], all users will be able to access those themes. As this service has the possibility of facilitating a privilege escalation attack on the local system through user impersonation, this service should be disabled.	Themes disabled
Status of the 'Windows Error Reporting' service	The 'Windows Error Reporting' service is used to provide the manufacturer with information related to issues that occur on the system. This information can sometimes be considered too inappropriate for dissemination beyond internal resources, especially in highly secured environments. Given this potential for confidential data leakage to a third-party, the service should be disabled.	WerSvc disabled
Status of the 'Windows Event Collector' service	The Windows 'Event Collector' service manages persistent subscriptions to 'Events,' such as event logs, hardware, and IPMI-enabled event sources, and forwards these to a local Event Log. (These events are collected from remote sources that support WS-Management protocol). As unnecessary services can be a target for known and unknown exploits, the capability should be disabled.	Wecsvc disabled
Status of the 'Windows Remote Management Service'	The 'Windows Remote Management Service' is one of three components in Microsoft' Hardware Management offering. (This service offers a method for managing hardware remotely using a standard Simple Object Access Protocol (SOAP) and communicating via http and https.)	WinRM Automatic
Status of the 'Wired AutoConfig' service	The Wired AutoConfig service performs IEEE 802.1X authentication on Ethernet interfaces. (When enabled, this service operates in conjunction with IEEE 802.1X authentication for conforming switches and Remote Authentication Dial-in User Service (RADIUS) servers to handle the 802.1X authentication process, permitting access to IEEE 802.3 networks. As unneeded services can be sometimes used to compromise access controls, this should be disabled.	dot3svc disabled
Status of the Windows IKE and AuthIP IPsec Keying Modules service	The 'Windows IKE and AuthIP IPsec Keying Modules' service operates the Internet Key Exchange (IKE) and Authenticated Internet Protocol (AuthIP) keying modules. As this service is responsible for IPSec key exchange and endpoint authentication.	IKEEXT manual
Status of the 'Windows Net.Tcp Port Sharing' service	The Net.TCP Port Sharing Service accepts worker processes from the service, inspecting and then assigning the incoming message stream to its destination address. As any network transport protocol is subject to potential interception and modification, this setting should be configured disabled. NOTE: This service is available by default, but not enabled, from .NET v3.0 onwards.	NetTcpPortSharing disabled
Status of the 'Smart Card' service	The 'Smart Card' service is responsible for controlling the access allowed for smart cards to be read by the system. There have been identified vulnerabilities within Kerberos that could result in DoS, data leakage/loss if the system is not kept up to date on patches. As will any/all services on connected computing devices.	SCardSvr disabled
Status of the 'Auto Time Zone Updater' service	Automatically sets the system time zone	tzautoupdate disabled

Status of the 'Windows Offline Files' service	The Offline Files service performs maintenance activities on the Offline Files cache, responds to user logon and logoff events, implements the internals of the public API, and dispatches interesting events to those interested in Offline Files activities and changes in cache state.	cscService disabled
Status of the 'User Experience Virtualization' Service	Provides support for application and OS settings roaming	UevAgentService disabled
Status of the 'Windows Search' service	The "Windows Search service" policy setting provides content indexing, property caching, and results for a search of files, e-mail, and other content. As this search capability could potentially be misused to obtain unauthorized information, this should be disabled.	Wsearch disabled
Status of the 'Specify use of ActiveX Installer Service for installation of ActiveX controls' setting (Internet Explorer) (HKU)	This policy setting allows you to specify how ActiveX controls are installed. If the policy is set to enable, ActiveX controls are installed only if the ActiveX Installer Service is present and has been configured to allow the installation of ActiveX controls. If the policy is set to disable or not configured, ActiveX controls, including per-user controls, are installed through the standard installation process. The ActiveX Installer Service can be a more secure method for deploying ActiveX controls needed for business purposes than allowing users to download and install them because organizations can ensure they are legitimate and scan them for malware prior to deployment.	AxInstSV disabled
Status of 'Bluetooth Support' Windows service startup type	The Bluetooth service is responsible for discovery and association of remote Bluetooth devices. Failure or disabling this service may cause already installed Bluetooth devices to fail to operate properly and prevent discovery of new devices. It is recommended to turn off Bluetooth otherwise it may allow rogue devices to communicate with a system that may lead to leakage of sensitive information or a compromised system.	bthserv disabled
Status of the 'Contact Data (PimIndexMaintenanceSvc)' service	The 'Contact Data (PimIndexMaintenanceSvc)' service indexes contact data for fast contact searching. If you stop or disable this service, contacts might be missing from your search results.	PimIndexMaintenanceSvc disabled
Status of the 'Downloaded Maps Manager' (MapsBroker) Windows Service 'Startup type'	Downloaded Maps Manager' Windows service allows offline access to downloaded maps for applications. Mapping technologies can unwillingly reveal your location to attackers and other software that picks up the information. In addition, automatic downloads of data from third-party sources should be minimized when not needed. Therefore, this service should not be needed in high security environments. To maintain a secure environment and reduce the breadth of the attack surface, this setting should be disabled.	MapsBroke disabled
Status of the 'Geolocation Service' (lfsvc) Windows Service 'Startup type'	Geolocation Service' monitors the current location of the system to manage geofences, a geographical location with associated events. Location based services poses primary threats, such as privacy, identity theft, tracking behaviour, personal security, and surveillance among the others. There should no need for such a service in an enterprise environment where third party vendors could gather unauthorized information. To maintain a secure environment and reduce the breadth of the attack surface, this setting should be disabled.	lfsvc disabled
Status of the 'Microsoft Account Sign-in Assistant' service	This service enables user sign-in through Microsoft account identity services. If this service is stopped, users will not be able to logon to the computer with their Microsoft account. Non-essential services are a potential point of attack. Therefore, non-essential services should be disabled or	wlidsvc disabled

	removed from the environment. This setting should be disabled.	
Status of the 'Microsoft Passport' service	Microsoft Passport' service provides process isolation for cryptographic keys used to authenticate to a user's associated identity providers. If this service is disabled, all uses and management of these keys will not be available, which includes machine logon and single sign on for apps and websites. This service should be disabled.	NgcSvc disabled
Status of the 'Microsoft Passport Container' service	Microsoft Passport Container' service is used to manage the local user identity keys used to authenticate user to identity providers as well as TPM virtual smart cards. If this service is disabled, local user identity keys and TPM virtual smart cards will not be accessible. This setting should be disabled.	NgcCtnrSvc disabled
Status of the 'Phone Service'	The 'Phone Service' manages the telephony state on the device. The phone service depends on the Remote Procedure Call (RPC) service. The phone service runs as NT Authority\LocalService in a shared process of svchost.exe. Other services might run in the same process. If Phone Service fails to start, the error is logged. Windows 10 startup proceeds, but a message box is displayed informing you that the PhoneSvc service has failed to start.	PhoneSvc disabled
Status of the 'Quality Windows Audio Video Experience' service	The 'Quality Windows Audio Video Experience' service (qWave) provides a network-based method to carry streaming applications on IP networks, providing monitoring capabilities to regulate [packet] traffic admission, run-time monitoring/reporting, traffic enforcement/regulation, and [QoS] traffic priority establishment. As multimedia services can use significant bandwidth, no matter how well regulated, this should be disabled.	QWAVE disabled
Status of the 'Radio Management Service'	The 'Radio Management Service' manages Radio and Airplane Mode Service. The Radio Management Service runs as NT AUTHORITY\LocalService in a shared process of svchost.exe. Other services might run in the same process. If Radio Management Service fails to start, the error is logged. Windows 10 startup proceeds, but a message box is displayed informing you that the RmSvc service has failed to start.	RmSvc disabled
Status of the 'Sensor Data' Service	Sensor Data' service delivers the data from a variety of sensors. Sensor data is the output of a device that detects and responds to some type of input from the physical environment. The output may be used to provide information or input to another system or process.	SensorDataService disabled
Sensor Monitoring Service	Monitors various sensors to expose data and adapt to system and user state. If this service is stopped or disabled, the display brightness will not adapt to lighting conditions. Stopping this service may affect other system functionality and features as well.	SensrSvc disabled
Status of the 'Sensor' service	A service for sensors that manages different sensors' functionality. Manages Simple Device Orientation (SDO) and History for sensors. Loads the SDO sensor that reports device orientation changes. If this service is stopped or disabled, the SDO sensor will not be loaded and so auto-rotation will not occur. History collection from Sensors will also be stopped.	SensorService disabled
Status of 'Smart Card Device Enumeration' Service	Creates software device nodes for all smart card readers accessible to a given session. If this service is disabled, WinRT APIs will not be able to enumerate smart card readers.	ScDeviceEnum disabled

Status of the 'Startup type' of 'Still Image Acquisition Events' service	The 'Still Image Acquisition Events' service launches applications associated with still image acquisition events. A still image device event is a device-level occurrence that upper-level software should be notified about if that software has requested such notification. The user-mode minidriver is responsible for defining most device events and delivering notifications when an event occurs. In general, events indicate that upper-level software is going to be required to perform some action. To maintain a secure environment and reduce the breadth of the attack surface, unnecessary applications and services should be restricted.	WiaRpc disabled
Permissions set for the 'Universal Plug and Play (UPnP) Device Host' service	The 'Plug and Play' service is responsible for the detection of hardware that is connected/added to the system. The intention is to make it easy for devices and/or components to be incorporated with the system with minimal user interaction. This service has a few known exploits that can be protected against by installing all available patches from Microsoft. As with all services available on connected computing devices, it is a measure of Best Practice to disable all that are not pertinent to the intended function of the system to reduce the number of threat vectors available for exploit by malicious users. Note: Microsoft warns that shutting this service off could result in system instability	upnphost disabled
Status of the 'Startup type' of 'WalletService' service	The 'WalletService' hosts objects used by clients of the wallet. You can pay for your purchases with Microsoft Wallet. With Wallet, you can keep your payment cards, rewards, and membership cards all in one place, so you have your cards available when and where you need them. Any service in windows utilizes CPU and memory resources on the system. Also, to maintain a secure environment and reduce the breadth of the attack surface, unnecessary applications and services should be disabled.	WalletService disabled
Status of the 'Windows Camera Frame Server' service	The 'Windows Camera Frame Server' service enables multiple clients to access video frames from camera devices. The Windows Camera Frame Server service runs as LocalSystem in a shared process of svchost.exe. Other services might run in the same process. If Windows Camera Frame Server fails to start, the error is logged. Windows 10 startup proceeds, but a message box is displayed informing you that the FrameServer service has failed to start. This depends on the Remote Procedure Call (RPC) service.	frameServer disabled
Status of the 'Windows Image Acquisition (WIA)' service	The 'Windows Image Acquisition (WIA)' Service allows for image acquisition services for scanners and cameras. As the service has a vulnerability that could facilitate a malicious user's capability to craft a privilege escalation exploit, resulting in a complete compromise of the system, this service should be disabled/restricted according to the needs of the business. NOTE: If the 'Windows Image Acquisition (WIA)' Service is disabled, scanners or cameras may fail to function properly.	stisvc disabled
Status of Windows Insider Service	The Windows Insider Program is an optional service provided by Microsoft to let users experience the next version of Windows before public release. This service could have unknown bugs, exploits which can increase the security risk, this service should be prohibited for production environment.	wisvc disabled
Status of the 'Windows Mobile Hotspot Service' (icssvc) Windows Service 'Startup type'	Windows Mobile Hotspot Service' provides the ability to share a cellular data connection with another device. The capability to run a mobile hotspot from a domain-connected computer could easily expose the internal network to	icssvc disabled

	wardrivers or other hackers. Therefore, this service should not be needed in high security environments.	
Status of the audit setting 'Application Generated' (advanced audit setting)	The 'Application Generated' security policy setting tracks applications using the Windows Auditing Application Programming Interfaces (APIs). The policy can audit events such as application operation attempts and initializations and creation and deletions of application client contexts. Depending on the type and size of a given company, the enablement of audit logs may be required to meet regulatory requirements.	Success and Failure (3)

4.3.2 ADFS Local Policies

The following controls are only applicable to ADFS server.

Policy Name	Description	Recommended Value
Current list of Groups and User Accounts granted the 'Generate Security Audits' right	This User Right permits the generation of security log records. As this right can create a condition causing the generation of many spurious log entries, making it difficult to sort out any actual attack traces and can also create a DoS condition if the 'shutdown the system immediately if unable to generate security audits' setting has been enabled.	Local service, Network service, NT SERVICE\adfssrv, NT SERVICE\drs, dominio\servicioADFS
Status of the 'ExtendedProtectionTokenCheck' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	Specifies the level of extended protection for authentication supported by the federation server. Extended Protection for Authentication helps protect against man-in-the-middle (MITM) attacks, in which an attacker intercepts a client's credentials and forwards them to a server. Protection against such attacks is made possible through a Channel Binding Token (CBT) which can be either required, allowed, or not required by the server when establishing communications with clients.	ExtendedProtectionTokenCheck Allow
Status of the 'PreventTokenReplays' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	Indicates whether the Federation Service prevents the replay of security tokens.	PreventTokenReplays True
Status of the 'ProxyTrustTokenLifetime' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	Specifies the valid token lifetime, in minutes, for proxy trust tokens. The federation server proxy uses this value to authenticate with its associated federation server.	PreventTokenReplays 22000 minutes
Status of the 'ReplayCacheExpirationInterval' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	Specifies the cache duration, in minutes, for token replay detection. This value determines the lifetime for tokens in the replay cache. When the age of a cached token exceeds this interval, the Federation Service determines the token has expired and does not allow replay of it.	ReplayCacheExpirationInterval 60 minutes
Status of the 'PersistentSsoEnabled' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	Indicates whether to store the SSO token in persistent cookies for devices joined to a workplace.	EnablePersistentSso True

Status of the 'SamlMessageDeliveryWindow' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	Specifies the duration, in minutes, for which the Security Assertion Markup Language (SAML) messages sent by the Federation Service are considered valid.	SamlMessageDeliveryWindow 60 minutes
Status of the 'KmsiEnabled' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	Indicates whether to enable the Keep Me Signed In (KMSI) option for form-based authentication. KMSI is limited to providing only 24 hours of SSO. Note that a workplace joined device gets 7 days of SSO by default and does not need this option enabled.	EnableKmsi False
Status of the 'PersistentSsoLifetimeMins' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	Specifies the duration, in minutes, of the persistent SSO experience.	PersistentSsoLifetimeMins 1440 minutes
Status of the 'LogLevel' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	Specifies an array of log detail. The array defines which types of events to record. The acceptable values for this parameter are Errors, Warnings, Information, SuccessAudits and FailureAudits.	LogLevel FailureAudits
Status of the 'MSS: (NtfsDisable8dot3NameCreation) Enable the computer to stop generating 8.3- style filenames' setting	Disable the computer to stop generating 8.3 style filenames	Disabled on all volumes (1)

4.3.3 Protection against brute force attacks and user account lockout

The following controls are applicable to ADFS server.

Policy Name	Description	Recommended Value
Status of the lockout algorithm for extranet	Indicates whether to enable the lockout algorithm for extranet. When enabled, AD FS checks attributes in Active Directory for the user before validating the credential. If the user is determined to be in lockout state, AD FS will deny the request to the user when accessing from the extranet, to prevent random login attempts from the extranet. Intranet access will continue to be validated against Active Directory. By default, this feature is disabled in a new instance of AD FS and must be explicitly enabled by the administrator.	EnableExtranetLockout Enabled
Maximum number of bad password attempts	Specifies the maximum number of bad password attempts permitted against the directory before the account is throttled when accessing applications from the extranet. If you use Active Directory Domain Services account lockout policies, it is strongly recommended that you set this threshold to a value that is less than the threshold in AD DS to avoid lockout of the user inside and outside the network.	EnableLockoutThresold <=4
Timespan of the lockout observation window	Specifies the timespan of the lockout observation window. AD FS will reset a throttled state of an account when more than one observation window has expired since the last bad password attempt, as reported by Active Directory Domain Services. It is also possible that the last bad password field in AD DS is cleared by AD DS based on its own observation	ExtranetObservationWindow >=30

	windows. In this case, AD FS will allow the request to be passed onto AD DS for validation.	

4.3.4 ADFS Certificates installation and specifications

The following controls are applicable to ADFS server and WAP.

Policy Name	Description	Recommended Value
Status of the 'CertificateDuration' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	Specifies the period, in days, that any certificates that the Federation Service generates remain valid.	CertificateDuration 397 days
Self-signed certificate length	All certificates must have at least 2048 bits length	>=3072 bits

4.3.5 Endpoint of ADFS

The following controls are only applicable to ADFS server.

Policy Name	Description	Recommended Value
Status of endpoint of AD FS	Endpoints provide access to the federation server functionality of AD FS, such as token issuance and the publishing of federation metadata. Depending on the type of endpoint, you can enable or disable the endpoint or control whether the endpoint is published to Web Application Proxy.	disabled

4.3.6 ADFS Encryption

The following controls are only applicable to WAP (Web Application Proxy) server.

Policy Name	Description	Recommended Value
Status of the 'ResponseHeadersEnabled' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	The response headers are included in the outgoing HTTP response sent by AD FS to a web browser. The response headers will be sent only if ResponseHeadersEnabled is set to True (default value). The value can be set to False to prevent AD FS including any of the security headers in the HTTP response. However, this is not recommended.	AdfsResponseHeaders disabled
Allowed ciphers	A cipher suite is a set of cryptographic algorithms. The Schannel SSP implementation of the TLS/SSL protocols use algorithms from a cipher suite to create keys and encrypt information. A cipher suite specifies one algorithm for each of the following tasks:	TLSv1.3: TLS_AES_256_GCM_SHA384, TLS_AES_128_GCM_SHA256 TLSv1.2: TLS_ECDHE_ECDSA WITH_AES_256_GCM _SHA384,TLS_ECDH

		E_RSA_WITH_AES_256_GCM_SHA384,TLS_DHE_RSA_WITH_AES_256_GCM_SHA384,TLS_DHE_RSA_WITH_AES_256_CCM,TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256,TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256,TLS_DHE_RSA_WITH_AES_128_GCM_SHA256.
Status of TLS 1.0 protocols setting	The Transport Layer Security (TLS) and its predecessor Secure Socket Layer (SSL) protocol allow for secure communication between a client and a server. There are known flaws in the SSL v2 and earlier versions of SSL protocol. If older and weak SSL 2.0 is used, it would increase the risk of 'man-in-the-middle attack' which can force the communication to a less secure level. The attacker can also truncate the encrypted messages. Also, SSL v2 uses Identical cryptographic keys for message authentication and encryption, which makes breaking of keys comparatively easy. These flaws have been fixed in TLS 1.0 and later protocols. As TLS 1.1 and later versions are only supported in operating systems Windows 2008 R2 and later, older clients would not be able to access the server supporting only TLS 1.1 and later versions, causing 'Denial-of-service' for legitimate older clients.	Server/Enabled: 0, Server/DisabledByDefault: 1
Status of TLS 1.1 protocols setting	The Transport Layer Security (TLS) and its predecessor Secure Socket Layer (SSL) protocol allow for secure communication between a client and a server. There are known flaws in the SSL v2 and earlier versions of SSL protocol. If older and weak SSL 2.0 is used, it would increase the risk of 'man-in-the-middle attack' which can force the communication to a less secure level. The attacker can also truncate the encrypted messages. Also, SSL v2 uses Identical cryptographic keys for message authentication and encryption, which makes breaking of keys comparatively easy. These flaws have been fixed in TLS protocols such as 1.0, 1.1, 1.2. As TLS 1.1 and later versions are only supported in operating systems Windows 2008 R2 and later, older clients would not be able to access the server supporting only TLS 1.1 and later versions, causing 'Denial-of-service' for legitimate older clients. However, those new clients which can support version 1.1 or later should make use of 1.1 for added security.	Server/Enabled: 0, Server/DisabledByDefault: 1
Status of SSL 2.0 protocols setting	The Secure Socket Layer (SSL) protocol allows for secure communication between a client and a server. There are known flaws in the SSL v2 protocol. The web servers are mostly configured to use older versions of SSL such as 2.0 to allow access for legacy clients. If older and weak SSL 2.0 is used, it would increase the risk of 'man-in-the-middle attack' which can force the communication to a less secure level. The attacker can also truncate the encrypted messages. These flaws have been fixed in SSLv3 (or TLSv1). Thus, SSL 2.0 should be disabled.	Server/Enabled: 0, Server/DisabledByDefault: 1
Status of SSL 3.0 protocols setting	The Secure Socket Layer (SSL) protocol allows for secure communication between a client and a server. There are known flaws in the SSL v2 and earlier versions of SSL protocol. If older and weak SSL 2.0 is used, it would	Server/Enabled: 0, Server/DisabledByDefault: 1

	increase the risk of 'man-in-the-middle attack' which can force the communication to a less secure level. Also, SSL v2 uses Identical cryptographic keys for message authentication and encryption, which makes breaking of keys comparatively easy.	
Status of TLS 1.2 protocols setting	The Transport Layer Security (TLS) and its predecessor Secure Socket Layer (SSL) protocol allow for secure communication between a client and a server. There are known flaws and vulnerabilities in the SSL v2 and earlier versions of SSL protocols which would allow an attacker to compromise the confidentiality and integrity of the message. These flows are fixed in TLS protocols such as 1.0, 1.1, 1.2. Most servers (including all popular Web servers, mail servers, etc.) and clients (including Web-clients and mail clients) support TLS 1.0, TLS 1.1, TLS 1.2 protocols. As TLS 1.0 and 1.1 support use of structurally weak stream cipher which could allow attacker to compromise the message. As TLS 1.2, a latest TLS protocol has fixed such security weaknesses. it is recommended that, if TLS is to be used, TLS 1.2 or later versions should be set as per the need of the organization.	Server/Enabled: 1, Server/DisabledByDefault: 0

5 CUSO ADDITIONS / EXCEPTIONS

5.1 CUSO Controls In Scope Measurable

The following additional controls are in scope for CUSO in addition to the Santander Group hardening controls and need to be added for additional restrictions.

Local Ref #	CIS Ref #	Global Ref #	Control	Value

5.2 In Scope Non – Measurable

*The below listed controls are not included in the Group Hardening Guide, however, are considered In Scope Non-Measurable for CUSO. Please refer to the rationale for justification of why the specific rules are not measured via Qualys.

External Regulatory Requriements

ID	Policy Name	Recommended Value	Criticality (*)	Versions	Rationale
2.18.1 *	Status of the 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run' registry key	Audit Creation and Update	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD	Compliance cannot be measured through Qualys because the tool cannot reliably evaluate the required configuration in the current assessment method. Reporting a result from an unsupported or incomplete measurement would create false assurance.
2.18.2 *	Status of the 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\RunOnce' registry key	Audit Creation and Update	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD	Compliance cannot be measured through Qualys because the tool cannot reliably evaluate the required configuration in the current assessment method. Reporting a result from an unsupported or incomplete measurement would create false assurance.

ID	Policy Name	Recommended Value	Criticality (*)	Versions	Rationale
2.18.3 *	Status of the 'HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Session Manager' registry key	Audit Creation and Update	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD	Compliance cannot be measured through Qualys because the tool cannot reliably evaluate the required configuration in the current assessment method. Reporting a result from an unsupported or incomplete measurement would create false assurance.
2.18.4 *	Status of the 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\Shell' registry key	Audit All	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD	Compliance cannot be measured through Qualys because the tool cannot reliably evaluate the required configuration in the current assessment method. Reporting a result from an unsupported or incomplete measurement would create false assurance.
2.18.5 *	Status of the 'HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon' registry key	Audit All	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD	Compliance cannot be measured through Qualys because the tool cannot reliably evaluate the required configuration in the current assessment method. Reporting a result from an unsupported or incomplete measurement would create false assurance.
* 2.18.6	Status of the 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\Userinit' registry key	Audit All	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD	Compliance cannot be measured through Qualys because the tool cannot reliably evaluate the required configuration in the current assessment method. Reporting a result from an unsupported or incomplete measurement would create false assurance.

ADFS

ID	Policy Name	Recommended Value	Criticality (*)	Versions	Rationale
4.1 ADFS Initial System Configuration					
4.1.64 *	Sensor Monitoring Service	SensrSvc disabled	SERIOUS	Win 2016, 2019 and 2022	Compliance cannot be measured through Qualys because the tool cannot reliably evaluate the required configuration in the current assessment method. Reporting a result from an unsupported or incomplete measurement would create false assurance.
4.4 ADFS Certificates installation and specifications					
* 4.4.2	Self-signed certificate length	>=3072 bits	CRITICAL	Win 2016, 2019 and 2022	Compliance cannot be measured through Qualys because the tool cannot reliably evaluate the required configuration in the current assessment method. Reporting a result from an unsupported or incomplete measurement would create false assurance.
4.6 ADFS Ciphers					
* 4.6.2	Status of the 'ResponseHeadersEnabled' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	AdfsResponseHeaders disabled	CRITICAL	Win 2016, 2019 and 2022	Compliance cannot be measured through Qualys because the tool cannot reliably evaluate the required configuration in the current assessment method. Reporting a result from an unsupported or incomplete measurement would create false assurance.

5.3 CUSO Out of Scope

The following controls are considered Out of Scope for CUSO. Please refer to the rationale for justification as to why they are not measured in Qualys.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
1.1.6	Ensure 'Relax minimum password length limits' is set to 'Enabled'	This policy setting determines whether the minimum password length setting can be increased beyond the legacy limit of 14 characters. For more information please see the following Microsoft Security Blog. The recommended state for this setting is: Enabled. Note: This setting only affects local accounts on the computer. Domain accounts are only affected by settings on the Domain Controllers, because that is where domain accounts are stored.	Enabled.	This control is out of scope because it would require a 14-character minimum password length, conflicting with the applicable standard requiring 8 characters. Excluding the control avoids imposing contradictory requirements and preserves the approved password policy.
2.2.26	Ensure 'Deny log on through Remote Desktop Services' to include 'Guests' (DC only)	This policy setting determines whether users can log on as Remote Desktop clients. After the baseline Member Server is joined to a domain environment, there is no need to use local accounts to access the server from the network. Domain accounts can access the server for administration and end-user processing. This user right supersedes the Allow log on through Remote Desktop Services user right if an account is subject to both policies. The recommended state for this setting is to include: Guests. Caution: Configuring a standalone (non-domain-joined) server as described above may result in an inability to remotely administer the server. Note: The security identifier Local account is not available in Server 2008 R2 and Server 2012 (non-R2) unless MSKB 2871997 has been installed. Note #2: In all versions of Windows Server prior to Server 2008 R2, Remote Desktop Services was known as Terminal Services, so you should substitute the older term if comparing against an older OS.	Guests.	This control is not measured because it was not included in the latest approved syndication and is outside the CIS baseline policy. Excluding it maintains alignment with the currently governed benchmark scope.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
2.2.37	Ensure 'Log on as a batch job' is set to 'Administrators' (DC Only)	This policy setting allows accounts to log on using the task scheduler service. Because the task scheduler is often used for administrative purposes, it may be needed in enterprise environments. However, its use should be restricted in high security environments to prevent misuse of system resources or to prevent attackers from using the right to launch malicious code after gaining user level access to a computer. The recommended state for this setting is: Administrators.	Administrators.	This control is not measured because it was not included in the latest approved syndication and is outside the CIS baseline policy. Excluding it maintains alignment with the currently governed benchmark scope.
2.3.5.1	Ensure 'Domain controller: Allow server operators to schedule tasks' is set to 'Disabled' (DC only)	This policy setting determines whether members of the Server Operators group are allowed to submit jobs by means of the AT schedule facility. The impact of this policy setting configuration should be small for most organizations. Users, including those in the Server Operators group, will still be able to create jobs by means of the Task Scheduler Wizard, but those jobs will run in the context of the account with which the user authenticates when they set up the job. Note: An AT Service Account can be modified to select a different account rather than the LOCAL SYSTEM account. To change the account, open System Tools, click Scheduled Tasks, and then click Accessories folder. Then click AT Service Account on the Advanced menu. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured because it was not included in the latest approved syndication and is outside the CIS baseline policy. Excluding it maintains alignment with the currently governed benchmark scope.
2.3.7.3	Ensure 'Interactive logon: Machine inactivity limit' is set to '900 or fewer second(s), but not 0'	Windows notices inactivity of a logon session, and if the amount of inactive time exceeds the inactivity limit, then the screen saver will run, locking the session. The recommended state for this setting is: 900 or fewer second(s), but not 0. Note: A value of 0 does not conform to the benchmark as it disables the machine inactivity limit.	900 or fewer second(s), but not 0.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
2.3.7.4	Configure 'Interactive logon: Message text for users attempting to log on'	This policy setting specifies a text message that displays to users when they log on. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.	This policy setting specifies a text message that displays to users when they log on. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
2.3.7.5	Configure 'Interactive logon: Message title for users attempting to log on'	This policy setting specifies the text displayed in the title bar of the window that users see when they log on to the system. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.	This policy setting specifies the text displayed in the title bar of the window that users see when they log on to the system. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
2.3.7.8	Ensure 'Interactive logon: Require Domain Controller Authentication to unlock workstation' is set to 'Enabled' (MS only)	Logon information is required to unlock a locked computer. For domain accounts, this security setting determines whether it is necessary to contact a Domain Controller to unlock a computer. The recommended state for this setting is: Enabled.	Enabled.	This control is out of scope because it can conflict with CyberArk management of local credentials. Requiring it could materially increase recovery time and operational complexity during a widespread incident; the decision also considers the impact noted by CIS.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
2.3.9.5	Ensure 'Microsoft network server: Server SPN target name validation level' is set to 'Accept if provided by client' or higher (MS only)	This policy setting controls the level of validation a computer with shared folders or printers (the server) performs on the service principal name (SPN) that is provided by the client computer when it establishes a session using the server message block (SMB) protocol. The server message block (SMB) protocol provides the basis for file and print sharing and other networking operations, such as remote Windows administration. The SMB protocol supports validating the SMB server service principal name (SPN) within the authentication blob provided by a SMB client to prevent a class of attacks against SMB servers referred to as SMB relay attacks. This setting will affect both SMB1 and SMB2. The recommended state for this setting is: Accept if provided by client. Configuring this setting to Required from client also conforms to the benchmark. Note: Since the release of the MS KB3161561 security patch, this setting can cause significant issues (such as replication problems, group policy editing issues and blue screen crashes) on Domain Controllers when used simultaneously with UNC path hardening (i.e. Rule 18.5.14.1). CIS therefore recommends against deploying this setting on Domain Controllers.	Accept if provided by client. Configuring this setting to Required from client also conforms to the benchmark.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
2.3.10.6	Ensure 'Network access: Named Pipes that can be accessed anonymously' is configured (DC only)	This policy setting determines which communication sessions, or pipes, will have attributes and permissions that allow anonymous access. The recommended state for this setting is: LSARPC, NETLOGON, SAMR and (when the legacy Computer Browser service is enabled) BROWSER. Note: A Member Server that holds the Remote Desktop Services Role with Remote Desktop Licensing Role Service will require a special exception to this recommendation, to allow the HydraLSPipe and TermServLicensing Named Pipes to be accessed anonymously.	LSARPC, NETLOGON, SAMR and (when the legacy Computer Browser service is enabled) BROWSER.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
2.3.10.7	Ensure 'Network access: Named Pipes that can be accessed anonymously' is configured (MS only)	This policy setting determines which communication sessions, or pipes, will have attributes and permissions that allow anonymous access. The recommended state for this setting is: <blank> (i.e. None), or (when the legacy Computer Browser service is enabled) BROWSER. Note: A Member Server that holds the Remote Desktop Services Role with Remote Desktop Licensing Role Service will require a special exception to this recommendation, to allow the HydraLSPipe and TermServLicensing Named Pipes to be accessed anonymously.	<blank> (i.e. None), or (when the legacy Computer Browser service is enabled) BROWSER.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
2.3.10.9	Ensure 'Network access: Remotely accessible registry paths and sub-paths' is configured	This policy setting determines which registry paths and sub-paths will be accessible over the network, regardless of the users or groups listed in the access control list (ACL) of the winreg registry key. Note: In Windows XP this setting is called "Network access: Remotely accessible registry paths," the setting with that same name in Windows Vista, Windows Server 2008 (non-R2), and Windows Server 2003 does not exist in Windows XP. Note #2: When you configure this setting you specify a list of one or more objects. The delimiter used when entering the list is a line feed or carriage return, that is, type the first object on the list, press the Enter button, type the next object, press Enter again, etc. The setting value is stored as a comma-delimited list in group policy security templates. It is also rendered as a comma-delimited list in Group Policy Editor's display pane and the Resultant Set of Policy console. It is recorded in the registry as a line-feed delimited list in a REG_MULTI_SZ value. The recommended state for this setting is: System\CurrentControlSet\Control\Print\Printers System\CurrentControlSet\Services\Eventlog Software\Microsoft\OLAP Server Software\Microsoft\Windows NT\CurrentVersion\Print Software\Microsoft\Windows NT\CurrentVersion\Windows System\CurrentControlSet\Control\ContentIndex System\CurrentControlSet\Control\Terminal Server System\CurrentControlSet\Control\Terminal Server\UserConfig System\CurrentControlSet\Control\Terminal	System\CurrentControlSet\Control\Print\Printers System\CurrentControlSet\Services\Eventlog Software\Microsoft\OLAP Server Software\Microsoft\Windows NT\CurrentVersion\Print Software\Microsoft\Windows NT\CurrentVersion\Windows System\CurrentControlSet\Control\ContentIndex System\CurrentControlSet\Control\Terminal Server System\CurrentControlSet\Control\Terminal Server\UserConfig System\CurrentControlSet\Control\Terminal Server\DefaultUserCo	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

		Server\DefaultUserConfiguration Software\Microsoft\Windows NT\CurrentVersion\Perflib System\CurrentControlSet\Services\SysmonLog The recommended state for servers that hold the Active Directory Certificate Services Role with Certification Authority Role Service includes the above list and: System\CurrentControlSet\Services\CertSvc The recommended state for servers that have the WINS Server Feature installed includes the above list and: System\CurrentControlSet\Services\WINS	nfiguration Software\Microsoft\Windows NT\CurrentVersion\Perflib System\CurrentControlSet\Services\SysmonLog The recommended state for servers that hold the Active Directory Certificate Services Role with Certification Authority Role Service includes the above list and: System\CurrentControlSet\Services\CertSvc The recommended state for servers that have the WINS Server Feature installed includes the above list and: System\CurrentControlSet\Services\WINS	

CIS #	CIS Control Name	Description	Recommended Value	Rationale
2.3.11.6	Ensure 'Network security: Force logoff when logon hours expire' is set to 'Enabled'	This policy setting determines whether to disconnect users who are connected to the local computer outside their user account's valid logon hours. This setting affects the Server Message Block (SMB) component. If you enable this policy setting you should also enable Microsoft network server: Disconnect clients when logon hours expire (Rule 2.3.9.4). The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
2.3.11.12	Ensure 'Network security: Restrict NTLM: Audit Incoming NTLM Traffic' is set to 'Enable auditing for all accounts'	This policy setting allows the auditing of incoming NTLM traffic. Events for this setting are recorded in the operational event log (e.g. Applications and Services Log\Microsoft\Windows\NTLM). The recommended state for this setting is: Enable auditing for all accounts.	Enable auditing for all accounts.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
2.3.11.13	Ensure 'Network security: Restrict NTLM: Audit NTLM authentication in this domain' is set to 'Enable all' (DC only)	This policy setting allows auditing of NTLM authentication within the domain from the Domain Controller. The recommended state for this setting is: Enable all. Note: This setting is specific to each Domain Controller and will only log authentications made to that Domain Controller.	Enable all.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
2.3.11.14	Ensure 'Network security: Restrict NTLM: Outgoing NTLM traffic to remote servers' is set to 'Audit all' or higher	This policy setting allows the auditing of outgoing NTLM traffic. Events for this setting are recorded in the operational event log (e.g. Applications and Services Log\Microsoft\Windows\NTLM). The recommended state for this setting is: Audit all. Configuring this setting to Deny All also conforms to the benchmark. Note: Configuring this setting to Deny All is more secure, however it could have a negative impact on applications that still require NTLM. Test carefully before implementing the Deny All value.	Audit all. Configuring this setting to Deny All also conforms to the benchmark.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
2.3.17.1	Ensure 'User Account Control: Admin Approval Mode for the Built-in Administrator account' is set to 'Enabled'	This policy setting controls the behavior of Admin Approval Mode for the built-in Administrator account. The recommended state for this setting is: Enabled.	Enabled.	This control is out of scope because it can conflict with CyberArk management of local credentials.
2.3.17.2	Ensure 'User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode' is set to 'Prompt for consent on the secure desktop' or higher	This policy setting controls the behavior of the elevation prompt for administrators. The recommended state for this setting is: Prompt for consent on the secure desktop. Configuring this setting to Prompt for credentials on the secure desktop also conforms to the benchmark.	Prompt for consent on the secure desktop. Configuring this setting to Prompt for credentials on the secure desktop also conforms to the benchmark.	This control is out of scope because it can conflict with CyberArk management of local credentials.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
2.3.17.3	Ensure 'User Account Control: Behavior of the elevation prompt for standard users' is set to 'Automatically deny elevation requests'	This policy setting controls the behavior of the elevation prompt for standard users. The recommended state for this setting is: Automatically deny elevation requests.	Automatically deny elevation requests.	This control is out of scope because it can conflict with CyberArk management of local credentials.
2.3.17.4	Ensure 'User Account Control: Detect application installations and prompt for elevation' is set to 'Enabled'	This policy setting controls the behavior of application installation detection for the computer. The recommended state for this setting is: Enabled.	Enabled.	This control is out of scope because it can conflict with CyberArk management of local credentials.
2.3.17.5	Ensure 'User Account Control: Only elevate UIAccess applications that are installed in secure locations' is set to 'Enabled'	This policy setting controls whether applications that request to run with a User Interface Accessibility (UIAccess) integrity level must reside in a secure location in the file system. Secure locations are limited to the following: • …\Program Files\, including subfolders • …\Windows\System32\ • …\Program Files (x86)\, including subfolders (for 64-bit versions of Windows) Note: Windows enforces a public key infrastructure (PKI) signature check on any interactive application that requests to run with a UIAccess integrity level regardless of the state of this security setting. The recommended state for this setting is: Enabled.	Enabled.	This control is out of scope because it can conflict with CyberArk management of local credentials.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
2.3.17.6	Ensure 'User Account Control: Run all administrators in Admin Approval Mode' is set to 'Enabled'	This policy setting controls the behavior of all User Account Control (UAC) policy settings for the computer. If you change this policy setting, you must restart your computer. The recommended state for this setting is: Enabled. Note: If this policy setting is disabled, the Security Center notifies you that the overall security of the operating system has been reduced.	Enabled.	This control is out of scope because it can conflict with CyberArk management of local credentials.
2.3.17.7	Ensure 'User Account Control: Switch to the secure desktop when prompting for elevation' is set to 'Enabled'	This policy setting controls whether the elevation request prompt is displayed on the interactive user's desktop or the secure desktop. The recommended state for this setting is: Enabled.	Enabled.	This control is out of scope because it can conflict with CyberArk management of local credentials.
2.3.17.8	Ensure 'User Account Control: Virtualize file and registry write failures to per-user locations' is set to 'Enabled'	This policy setting controls whether application write failures are redirected to defined registry and file system locations. This policy setting mitigates applications that run as administrator and write run-time application data to: • %ProgramFiles% • %windir% • %windir%\System32 • HKEY_LOCAL_MACHINE\SOFTWARE The recommended state for this setting is: Enabled.	Enabled.	This control is out of scope because it can conflict with CyberArk management of local credentials.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
5.1	Ensure 'Print Spooler (Spooler)' is set to 'Disabled' (DC only)	This service spools print jobs and handles interaction with printers. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
5.2	Ensure 'Print Spooler (Spooler)' is set to 'Disabled' (MS only)	This service spools print jobs and handles interaction with printers. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
9.1.1	Ensure 'Windows Firewall: Domain: Firewall state' is set to 'On (recommended)'	Select On (recommended) to have Windows Firewall with Advanced Security use the settings for this profile to filter network traffic. If you select Off, Windows Firewall with Advanced Security will not use any of the firewall rules or connection security rules for this profile. The recommended state for this setting is: On (recommended).	On (recommended).	This control is out of scope at the Windows Server level because equivalent network protection is implemented and governed through the perimeter firewall.
9.1.2	Ensure 'Windows Firewall: Domain: Inbound connections' is set to 'Block (default)'	This setting determines the behavior for inbound connections that do not match an inbound firewall rule. The recommended state for this setting is: Block (default).	Block (default).	This control is out of scope at the Windows Server level because equivalent network protection is implemented and governed through the perimeter firewall.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
9.1.3	Ensure 'Windows Firewall: Domain: Settings: Display a notification' is set to 'No'	Select this option to have Windows Firewall with Advanced Security display notifications to the user when a program is blocked from receiving inbound connections. The recommended state for this setting is: No. Note: When the Apply local firewall rules setting is configured to No, it's recommended to also configure the Display a notification setting to No. Otherwise, users will continue to receive messages that ask if they want to unblock a restricted inbound connection, but the user's response will be ignored.	No.	This control is out of scope at the Windows Server level because equivalent network protection is implemented and governed through the perimeter firewall.
9.1.4	Ensure 'Windows Firewall: Domain: Logging: Name' is set to '%SystemRoot%\System32\logfiles\firewall\domainfw.log'	Use this option to specify the path and name of the file in which Windows Firewall will write its log information. The recommended state for this setting is: %SystemRoot%\System32\logfiles\firewall\domainfw.log.	%SystemRoot%\System32\logfiles\firewall\domainfw.log.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
9.1.5	Ensure 'Windows Firewall: Domain: Logging: Size limit (KB)' is set to '16,384 KB or greater'	Use this option to specify the size limit of the file in which Windows Firewall will write its log information. The recommended state for this setting is: 16,384 KB or greater.	16,384 KB or greater.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
9.1.6	Ensure 'Windows Firewall: Domain: Logging: Log dropped packets' is set to 'Yes'	Use this option to log when Windows Firewall with Advanced Security discards an inbound packet for any reason. The log records why and when the packet was dropped. Look for entries with the word DROP in the action column of the log. The recommended state for this setting is: Yes.	Yes.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
9.1.7	Ensure 'Windows Firewall: Domain: Logging: Log successful connections' is set to 'Yes'	Use this option to log when Windows Firewall with Advanced Security allows an inbound connection. The log records why and when the connection was formed. Look for entries with the word ALLOW in the action column of the log. The recommended state for this setting is: Yes.	Yes.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
9.2.1	Ensure 'Windows Firewall: Private: Firewall state' is set to 'On (recommended)'	Select On (recommended) to have Windows Firewall with Advanced Security use the settings for this profile to filter network traffic. If you select Off, Windows Firewall with Advanced Security will not use any of the firewall rules or connection security rules for this profile. The recommended state for this setting is: On (recommended).	On (recommended).	This control is out of scope at the Windows Server level because equivalent network protection is implemented and governed through the perimeter firewall.
9.2.2	Ensure 'Windows Firewall: Private: Inbound connections' is set to 'Block (default)'	This setting determines the behavior for inbound connections that do not match an inbound firewall rule. The recommended state for this setting is: Block (default).	Block (default).	This control is out of scope at the Windows Server level because equivalent network protection is implemented and governed through the perimeter firewall.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
9.2.3	Ensure 'Windows Firewall: Private: Settings: Display a notification' is set to 'No'	Select this option to have Windows Firewall with Advanced Security display notifications to the user when a program is blocked from receiving inbound connections. The recommended state for this setting is: No. Note: When the Apply local firewall rules setting is configured to No, it's recommended to also configure the Display a notification setting to No. Otherwise, users will continue to receive messages that ask if they want to unblock a restricted inbound connection, but the user's response will be ignored.	No.	This control is out of scope at the Windows Server level because equivalent network protection is implemented and governed through the perimeter firewall.
9.2.4	Ensure 'Windows Firewall: Private: Logging: Name' is set to '%SystemRoot%\System32\logfiles\firewall\privatefw.log'	Use this option to specify the path and name of the file in which Windows Firewall will write its log information. The recommended state for this setting is: %SystemRoot%\System32\logfiles\firewall\privatefw.log.	%SystemRoot%\System32\logfiles\firewall\privatefw.log.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
9.2.5	Ensure 'Windows Firewall: Private: Logging: Size limit (KB)' is set to '16,384 KB or greater'	Use this option to specify the size limit of the file in which Windows Firewall will write its log information. The recommended state for this setting is: 16,384 KB or greater.	16,384 KB or greater.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
9.2.6	Ensure 'Windows Firewall: Private: Logging: Log dropped packets' is set to 'Yes'	Use this option to log when Windows Firewall with Advanced Security discards an inbound packet for any reason. The log records why and when the packet was dropped. Look for entries with the word DROP in the action column of the log. The recommended state for this setting is: Yes.	Yes.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
9.2.7	Ensure 'Windows Firewall: Private: Logging: Log successful connections' is set to 'Yes'	Use this option to log when Windows Firewall with Advanced Security allows an inbound connection. The log records why and when the connection was formed. Look for entries with the word ALLOW in the action column of the log. The recommended state for this setting is: Yes.	Yes.	This control is out of scope at the Windows Server level because equivalent network protection is implemented and governed through the perimeter firewall.
9.3.1	Ensure 'Windows Firewall: Public: Firewall state' is set to 'On (recommended)'	Select On (recommended) to have Windows Firewall with Advanced Security use the settings for this profile to filter network traffic. If you select Off, Windows Firewall with Advanced Security will not use any of the firewall rules or connection security rules for this profile. The recommended state for this setting is: On (recommended).	On (recommended).	This control is out of scope at the Windows Server level because equivalent network protection is implemented and governed through the perimeter firewall.
9.3.2	Ensure 'Windows Firewall: Public: Inbound connections' is set to 'Block (default)'	This setting determines the behavior for inbound connections that do not match an inbound firewall rule. The recommended state for this setting is: Block (default).	Block (default).	This control is out of scope at the Windows Server level because equivalent network protection is implemented and governed through the perimeter firewall.
9.3.3	Ensure 'Windows Firewall: Public: Settings: Display a notification' is set to 'No'	Select this option to have Windows Firewall with Advanced Security display notifications to the user when a program is blocked from receiving inbound connections. The recommended state for this setting is: No.	No.	This control is out of scope at the Windows Server level because equivalent network protection is implemented and governed through the perimeter firewall.
9.3.4	Ensure 'Windows Firewall: Public: Settings: Apply local firewall rules' is set to 'No'	This setting controls whether local administrators are allowed to create local firewall rules that apply together with firewall rules configured by Group Policy. The recommended state for this setting is: No. Note: When the Apply local firewall rules setting is configured to No, it's recommended to also configure the Display a notification setting to No. Otherwise, users will continue to receive messages that ask if they want to unblock a restricted inbound connection, but the user's response will be ignored.	No.	This control is out of scope at the Windows Server level because equivalent network protection is implemented and governed through the perimeter firewall.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
9.3.5	Ensure 'Windows Firewall: Public: Settings: Apply local connection security rules' is set to 'No'	This setting controls whether local administrators are allowed to create connection security rules that apply together with connection security rules configured by Group Policy. The recommended state for this setting is: No.	No.	This control is out of scope at the Windows Server level because equivalent network protection is implemented and governed through the perimeter firewall.
9.3.6	Ensure 'Windows Firewall: Public: Logging: Name' is set to '%SystemRoot%\System32\logfiles\firewall\publicfw.log'	Use this option to specify the path and name of the file in which Windows Firewall will write its log information. The recommended state for this setting is: %SystemRoot%\System32\logfiles\firewall\publicfw.log.	%SystemRoot%\System32\logfiles\firewall\publicfw.log.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
9.3.7	Ensure 'Windows Firewall: Public: Logging: Size limit (KB)' is set to '16,384 KB or greater'	Use this option to specify the size limit of the file in which Windows Firewall will write its log information. The recommended state for this setting is: 16,384 KB or greater.	16,384 KB or greater.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
9.3.8	Ensure 'Windows Firewall: Public: Logging: Log dropped packets' is set to 'Yes'	Use this option to log when Windows Firewall with Advanced Security discards an inbound packet for any reason. The log records why and when the packet was dropped. Look for entries with the word DROP in the action column of the log. The recommended state for this setting is: Yes.	Yes.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
9.3.9	Ensure 'Windows Firewall: Public: Logging: Log successful connections' is set to 'Yes'	Use this option to log when Windows Firewall with Advanced Security allows an inbound connection. The log records why and when the connection was formed. Look for entries with the word ALLOW in the action column of the log. The recommended state for this setting is: Yes.	Yes.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
17.3.1	Ensure 'Audit PNP Activity' is set to include 'Success'	This policy setting allows you to audit when plug and play detects an external device. The recommended state for this setting is to include: Success. Note: A Windows 10, Server 2016 or newer OS is required to access and set this value in Group Policy.	Success.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
17.6.1	Ensure 'Audit Detailed File Share' is set to include 'Failure'	This subcategory allows you to audit attempts to access files and folders on a shared folder. Events for this subcategory include: • 5145: network share object was checked to see whether client can be granted desired access. The recommended state for this setting is to include: Failure	Failure	This control is out of scope because these audit events are not required to be forwarded to or processed by the SIEM, as confirmed with the SIEM team under RITM019596301. Measuring local generation without an approved monitoring and response process would not provide effective audit assurance.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
17.6.4	Ensure 'Audit Removable Storage' is set to 'Success and Failure'	This policy setting allows you to audit user attempts to access file system objects on a removable storage device. A security audit event is generated only for all objects for all types of access requested. If you configure this policy setting, an audit event is generated each time an account accesses a file system object on a removable storage. Success audits record successful attempts and Failure audits record unsuccessful attempts. If you do not configure this policy setting, no audit event is generated when an account accesses a file system object on a removable storage. The recommended state for this setting is: Success and Failure. Note: A Windows 8.0, Server 2012 (non-R2) or newer OS is required to access and set this value in Group Policy.	Success and Failure.	This control is out of scope because these audit events are not required to be forwarded to or processed by the SIEM, as confirmed with the SIEM team under RITM019596301. Measuring local generation without an approved monitoring and response process would not provide effective audit assurance.
17.7.4	Ensure 'Audit MPSSVC Rule-Level Policy Change' is set to 'Success and Failure'	This subcategory determines whether the operating system generates audit events when changes are made to policy rules for the Microsoft Protection Service (MPSSVC.exe). Events for this subcategory include: • 4944: The following policy was active when the Windows Firewall started. • 4945: A rule was listed when the Windows Firewall started. • 4946: A change has been made to Windows Firewall exception list. A rule was added. • 4947: A change has been made to Windows Firewall exception list. A rule was modified. • 4948: A change has been made to Windows Firewall exception list. A rule was deleted. •	Success and Failure	This control is out of scope because these audit events are not required to be forwarded to or processed by the SIEM, as confirmed with the SIEM team under RITM019596301. Measuring local generation without an approved monitoring and response process would not provide effective audit assurance.

		4949: Windows Firewall settings were restored to the default values. • 4950: A Windows Firewall setting has changed. • 4951: A rule has been ignored because its major version number was not recognized by Windows Firewall. • 4952: Parts of a rule have been ignored because its minor version number was not recognized by Windows Firewall. The other parts of the rule will be enforced. • 4953: A rule has been ignored by Windows Firewall because it could not parse the rule. • 4954: Windows Firewall Group Policy settings have changed. The new settings have been applied. • 4956: Windows Firewall has changed the active profile. • 4957: Windows Firewall did not apply the following rule. • 4958: Windows Firewall did not apply the following rule because the rule referred to items not configured on this computer. The recommended state for this setting is: Success and Failure		

CIS #	CIS Control Name	Description	Recommended Value	Rationale
17.7.5	Ensure 'Audit Other Policy Change Events' is set to include 'Failure'	This subcategory contains events about EFS Data Recovery Agent policy changes, changes in Windows Filtering Platform filter, status on Security policy settings updates for local Group Policy settings, Central Access Policy changes, and detailed troubleshooting events for Cryptographic Next Generation (CNG) operations. • 5063: A cryptographic provider operation was attempted. • 5064: A cryptographic context operation was attempted. • 5065: A cryptographic context modification was attempted. • 5066: A cryptographic function operation was attempted. • 5067: A cryptographic function modification was attempted. • 5068: A cryptographic function provider operation was attempted. • 5069: A cryptographic function property operation was attempted. • 5070: A cryptographic function property modification was attempted. • 6145: One or more errors occurred while processing security policy in the group policy objects. The recommended state for this setting is to include: Failure.	Failure.	This control is out of scope because these audit events are not required to be forwarded to or processed by the SIEM, as confirmed with the SIEM team under RITM019596301. Measuring local generation without an approved monitoring and response process would not provide effective audit assurance.
18.1.2.2	Ensure 'Allow users to enable online speech recognition services' is set to 'Disabled'	This policy enables the automatic learning component of input personalization that includes speech, inking, and typing. Automatic learning enables the collection of speech and handwriting patterns, typing history, contacts, and recent calendar information. It is required for the use of Cortana. Some of this collected information may be stored on the user's OneDrive, in the case of inking and typing; some of the information will be uploaded to Microsoft to personalize speech. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.1.3	Ensure 'Allow Online Tips' is set to 'Disabled'	This policy setting configures the retrieval of online tips and help for the Settings app. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.4.1	Ensure 'Apply UAC restrictions to local accounts on network logons' is set to 'Enabled' (MS only)	This setting controls whether local accounts can be used for remote administration via network logon (e.g., NET USE, connecting to C$, etc.). Local accounts are at high risk for credential theft when the same account and password is configured on multiple systems. Enabling this policy significantly reduces that risk. Enabled: Applies UAC token-filtering to local accounts on network logons. Membership in powerful group such as Administrators is disabled and powerful privileges are removed from the resulting access token. This configures the LocalAccountTokenFilterPolicy registry value to 0. This is the default behavior for Windows. Disabled: Allows local accounts to have full administrative rights when authenticating via network logon, by configuring the LocalAccountTokenFilterPolicy registry value to 1. For more information about local accounts and credential theft, review the "Mitigating Pass-the-Hash (PtH) Attacks and Other Credential Theft Techniques" documents. For more information about LocalAccountTokenFilterPolicy, see Microsoft Knowledge Base article 951016: Description of User Account Control and remote restrictions in Windows Vista. The recommended state for this setting is: Enabled.	Enabled.	This control is out of scope because it can conflict with CyberArk management of local credentials.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.4.4	Ensure 'Enable Certificate Padding' is set to 'Enabled'	This policy setting configures whether the WinVerifyTrust function performs strict Windows Authenticode signature verification for Portable Executable files (PE files). If enabled, PE files will be considered "unsigned" if Windows identifies content in them that does not conform to the Authenticode specification. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.4.6	Ensure 'NetBT NodeType configuration' is set to 'Enabled: P-node (recommended)'	This setting determines which method NetBIOS over TCP/IP (NetBT) uses to register and resolve names. The available methods are: • The B-node (broadcast) method only uses broadcasts. • The P-node (point-to-point) method only uses name queries to a name server (WINS). • The M-node (mixed) method broadcasts first, then queries a name server (WINS) if broadcast failed. • The H-node (hybrid) method queries a name server (WINS) first, then broadcasts if the query failed. The recommended state for this setting is: Enabled: P-node (recommended) (point- to-point). Note: Resolution through LMHOSTS or DNS follows these methods. If the NodeType registry value is present, it overrides any DhcpNodeType registry value. If neither NodeType nor DhcpNodeType is present, the computer uses B-node (broadcast) if there are no WINS servers configured for the network, or H-node (hybrid) if there is at least one WINS server configured.	Enabled: P-node (recommended) (point-to-point).	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.5.2	Ensure 'MSS: (DisableIPSourceRouting IPv6) IP source routing protection level' is set to 'Enabled: Highest protection, source routing is completely disabled'	IP source routing is a mechanism that allows the sender to determine the IP route that a datagram should follow through the network. The recommended state for this setting is: Enabled: Highest protection, source routing is completely disabled.	Enabled: Highest protection, source routing is completely disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.5.4	Ensure 'MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes' is set to 'Disabled'	Internet Control Message Protocol (ICMP) redirects cause the IPv4 stack to plumb host routes. These routes override the Open Shortest Path First (OSPF) generated routes. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.5.5	Ensure 'MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds' is set to 'Enabled: 300,000 or 5 minutes'	This value controls how often TCP attempts to verify that an idle connection is still intact by sending a keep-alive packet. If the remote computer is still reachable, it acknowledges the keep-alive packet. The recommended state for this setting is: Enabled: 300,000 or 5 minutes.	Enabled: 300,000 or 5 minutes.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.5.6	Ensure 'MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers' is set to 'Enabled'	NetBIOS over TCP/IP is a network protocol that among other things provides a way to easily resolve NetBIOS names that are registered on Windows-based systems to the IP addresses that are configured on those systems. This setting determines whether the computer releases its NetBIOS name when it receives a name-release request. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.5.7	Ensure 'MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses' is set to 'Disabled'	This setting is used to enable or disable the Internet Router Discovery Protocol (IRDP), which allows the system to detect and configure default gateway addresses automatically as described in RFC 1256 on a per-interface basis. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.5.8	Ensure 'MSS: (SafeDllSearchMode) Enable Safe DLL search mode' is set to 'Enabled'	The DLL search order can be configured to search for DLLs that are requested by running processes in one of two ways: • Search folders specified in the system path first, and then search the current working folder. • Search current working folder first, and then search the folders specified in the system path. When enabled, the registry value is set to 1. With a setting of 1, the system first searches the folders that are specified in the system path and then searches the current working folder. When disabled the registry value is set to 0 and the system first searches the current working folder and then searches the folders that are specified in the system path. Applications will be forced to search for DLLs in the system path first. For applications that require unique versions of these DLLs that are included with the application, this entry could cause performance or stability problems. The recommended state for this setting is: Enabled. Note: More information on how Safe DLL search mode works is available at this link: Dynamic-Link Library Search Order - Windows applications | Microsoft Docs	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.5.9	Ensure 'MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires' is set to 'Enabled: 5 or fewer seconds'	Windows includes a grace period between when the screen saver is launched and when the console is actually locked automatically when screen saver locking is enabled. The recommended state for this setting is: Enabled: 5 or fewer seconds.	Enabled: 5 or fewer seconds.	This control is out of scope because it can conflict with CyberArk management of local credentials.
18.5.10	Ensure 'MSS: (TcpMaxDataRetransmissions IPv6) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3'	This setting controls the number of times that TCP retransmits an individual data segment (non-connect segment) before the connection is aborted. The retransmission time-out is doubled with each successive retransmission on a connection. It is reset when responses resume. The base time-out value is dynamically determined by the measured round-trip time on the connection. The recommended state for this setting is: Enabled: 3.	Enabled: 3.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.5.11	Ensure 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3'	This setting controls the number of times that TCP retransmits an individual data segment (non-connect segment) before the connection is aborted. The retransmission time-out is doubled with each successive retransmission on a connection. It is reset when responses resume. The base time-out value is dynamically determined by the measured round-trip time on the connection. The recommended state for this setting is: Enabled: 3.	Enabled: 3.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.5.12	Ensure 'MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning' is set to 'Enabled: 90% or less'	This setting can generate a security audit in the Security event log when the log reaches a user-defined threshold. The recommended state for this setting is: Enabled: 90% or less. Note: If log settings are configured to Overwrite events as needed or Overwrite events older than x days, this event will not be generated.	Enabled: 90% or less.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.6.4.4	Ensure 'Turn off multicast name resolution' is set to 'Enabled'	Link-Local Multicast Name Resolution (LLMNR) is a secondary name resolution protocol. With LLMNR, queries are sent using multicast over a local network link on a single subnet from a client computer to another client computer on the same subnet that also has LLMNR enabled. LLMNR does not require a DNS server or DNS client configuration and provides name resolution in scenarios in which conventional DNS name resolution is not possible. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.5.1	Ensure 'Enable Font Providers' is set to 'Disabled'	This policy setting determines whether Windows is allowed to download fonts and font catalog data from an online font provider. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.7.1	Ensure 'Audit client does not support encryption' is set to 'Enabled'	This policy setting determines whether the Server Message Block (SMB) server will log events when the SMB client doesn't support encryption. Enabling this will create event log entries in Applications and Services Logs\Microsoft\Windows\SMBClient\Audit, with Event ID 31998. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.6.7.2	Ensure 'Audit client does not support signing' is set to 'Enabled'	This policy setting determines whether the Server Message Block (SMB) server will log events when the SMB client doesn't support signing. Enabling this will create event log entries in Applications and Services Logs\Microsoft\Windows\SMBClient\Audit, with Event ID 31999. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.7.4	Ensure 'Enable remote mailslots' is set to 'Disabled'	This policy settings controls whether the SMB server will use remote mailslots over the computer browser service. The remote mailslots protocol is an old, simple, unreliable, and insecure inter-process communication method. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.7.5	Ensure 'Mandate the minimum version of SMB' is set to 'Enabled: 3.1.1'	This policy settings controls the minimum version of Server Message Block (SMB) protocol that can be used on the system. The recommended state for this setting is: Enabled: 3.1.1. Note: This group policy setting does not prevent the use of SMBv1 if it is installed and enabled on the system. If the following recommendations are configured as prescribed in this benchmark, SMBv1 will be disabled on the system: Configure SMB v1 client driver and Configure SMB v1 server.	Enabled: 3.1.1.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.6.7.6	Ensure 'Set authentication rate limiter delay (milliseconds)' is set to 'Enabled: 2000' or more	This policy settings configures the SMB server invalid authentication delay value in milliseconds. The recommended state for this setting is: Enabled: 2000 or more.	Enabled: 2000 or more.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.8.1	Ensure 'Audit insecure guest logon' is set to 'Enabled'	This policy determines whether the Server Message Block (SMB) client will log events when the client is logged on as guest account. Enabling this will create event log entries in Applications and Service Logs\Microsoft\Windows\SMBClient\Security, with Event IDs 3023, 31017, 31018, and 31022. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.8.2	Ensure 'Audit server does not support encryption' is set to 'Enabled'	This policy setting determines whether the Server Message Block (SMB) client will log events when the SMB server doesn't support encryption. Enabling this will create event log entries in Applications and Services Logs\Microsoft\Windows\SMBServer\Audit, with Event ID 3021. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.8.3	Ensure 'Audit server does not support signing' is set to 'Enabled'	This policy setting determines whether the Server Message Block (SMB) client will log events when the SMB server doesn't support signing. Enabling this will create event log entries in Applications and Services Logs\Microsoft\Windows\SMBServer\Audit, with Event ID 3022. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.6.8.4	Ensure 'Enable authentication rate limiter' is set to 'Enabled'	This policy settings configures the Server Message Block (SMB) server authentication rate limiter. The authentication rate limiter is a feature of SMB that is designed to address brute force attacks. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.8.6	Ensure 'Enable remote mailslots' is set to 'Disabled'	This policy settings controls whether the SMB client will use remote mailslots over Multiple UNC Provider (MUP). The remote mailslots protocol is an old, simple, unreliable, and insecure inter-process communication method. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.8.7	Ensure 'Mandate the minimum version of SMB' is set to 'Enabled: 3.1.1'	This policy settings controls the minimum version of Server Message Block (SMB) protocol that can be used on the system. The recommended state for this setting is: Enabled: 3.1.1. Note: This group policy setting does not prevent the use of SMBv1 if it is installed and enabled on the system. If the following recommendations are configured as prescribed in this benchmark, SMBv1 will be disabled on the system: Configure SMB v1 client driver and Configure SMB v1 server.	Enabled: 3.1.1.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.8.8	Ensure 'Require Encryption' is set to 'Enabled'	This policy setting controls whether the SMB client will require encryption. The recommended state for this setting is: Enabled. Warning: The SMB server must support and have SMB encryption enabled (requires SMB v3.0 or later).	Enabled. Warning: The SMB server must support and have SMB encryption enabled	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without

			(requires SMB v3.0 or later).	implying disregard for the control's requirements.
CIS #	**CIS Control Name**	**Description**	**Recommended Value**	**Rationale**
18.6.9.1	Ensure 'Turn on Mapper I/O (LLTDIO) driver' is set to 'Disabled'	This policy setting changes the operational behavior of the Mapper I/O network protocol driver. LLTDIO allows a computer to discover the topology of a network it's connected to. It also allows a computer to initiate Quality-of-Service requests such as bandwidth estimation and network health analysis. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.9.2	Ensure 'Turn on Responder (RSPNDR) driver' is set to 'Disabled'	This policy setting changes the operational behavior of the Responder network protocol driver. The Responder allows a computer to participate in Link Layer Topology Discovery requests so that it can be discovered and located on the network. It also allows a computer to participate in Quality-of-Service activities such as bandwidth estimation and network health analysis. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.10.2	Ensure 'Turn off Microsoft Peer-to-Peer Networking Services' is set to 'Enabled'	The Peer Name Resolution Protocol (PNRP) allows for distributed resolution of a name to an IPv6 address and port number. The protocol operates in the context of clouds. A cloud is a set of peer computers that can communicate with each other by using the same IPv6 scope. Peer-to-Peer protocols allow for applications in the areas of RTC, collaboration, content distribution and distributed processing. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.6.11.2	Ensure 'Prohibit installation and configuration of Network Bridge on your DNS domain network' is set to 'Enabled'	You can use this procedure to control a user's ability to install and configure a Network Bridge. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.11.3	Ensure 'Prohibit use of Internet Connection Sharing on your DNS domain network' is set to 'Enabled'	Although this "legacy" setting traditionally applied to the use of Internet Connection Sharing (ICS) in Windows 2000, Windows XP & Server 2003, this setting now freshly applies to the Mobile Hotspot feature in Windows 10 & Server 2016. The recommended state for this setting is: Enabled. Warning: In order for Application Guard to function correctly, ICS must be enabled. If Application Guard is used in the environment, then an exception to this recommendation might be needed. To learn more on how to disable portions of ICS without breaking Application Guard, please visit: FAQ - Microsoft Defender Application Guard | Microsoft Learn.	Enabled. Warning: In order for Application Guard to function correctly, ICS must be enabled. If Application Guard is used in the environment, then an exception to this recommendation might be needed. To learn more on how to disable portions of ICS without breaking Application Guard, please visit: FAQ - Microsoft Defender Application Guard | Microsoft Learn.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.6.19.2.1	Ensure TCPIP6 Parameter 'DisabledComponents' is set to '0xff (255)')	Internet Protocol version 6 (IPv6) is a set of protocols that computers use to exchange information over the Internet and over home and business networks. IPv6 allows for many more IP addresses to be assigned than IPv4 did. Older networking, hosts and operating systems may not support IPv6 natively. The recommended state for this setting is: DisabledComponents - 0xff (255).	DisabledComponents - 0xff (255).	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.20.2	Ensure 'Prohibit access of the Windows Connect Now wizards' is set to 'Enabled'	This policy setting prohibits access to Windows Connect Now (WCN) wizards. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.21.1	Ensure 'Minimize the number of simultaneous connections to the Internet or a Windows Domain' is set to 'Enabled: 3 = Prevent Wi-Fi when on Ethernet'	This policy setting prevents computers from establishing multiple simultaneous connections to either the Internet or to a Windows domain. The recommended state for this setting is: Enabled: 3 = Prevent Wi-Fi when on Ethernet.	Enabled: 3 = Prevent Wi-Fi when on Ethernet.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.6.21.2	Ensure 'Prohibit connection to non-domain networks when connected to domain authenticated network' is set to 'Enabled' (MS only)	This policy setting prevents computers from connecting to both a domain based network and a non-domain based network at the same time. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.7.9	Ensure 'Configure Windows protected print' is set to 'Enabled'	This policy setting controls whether Windows protected print is enabled on the system. Windows protected print uses the modern print platform and Windows protected print mode. Modern print is designed to work only with Mopria-certified printers. Mopria is a collection of printer manufacturers and software vendors that define standards for IPP printing and eSCL scanning. The recommended state for this setting is: Enabled. Note: Windows protected print will not prohibit administrators or users from installing third-party print drivers through an installation package provided by the print device manufacturer.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.7.10	Ensure 'Limits print driver installation to Administrators' is set to 'Enabled'	This policy setting controls whether users who aren't Administrators can install print drivers on the system. The recommended state for this setting is: Enabled. Note: On August 10, 2021, Microsoft announced a Point and Print Default Behavior Change which modifies the default Point and Print driver installation and update behavior to require Administrator privileges. This is documented in KB5005652—Manage new Point and Print default driver installation behavior (CVE-2021-34481).	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.7.12	Ensure 'Point and Print Restrictions: When installing drivers for a new connection' is set to 'Enabled: Show warning and elevation prompt'	This policy setting controls whether computers will show a warning and a security elevation prompt when users create a new printer connection using Point and Print. The recommended state for this setting is: Enabled: Show warning and elevation prompt. Note: On August 10, 2021, Microsoft announced a Point and Print Default Behavior Change which modifies the default Point and Print driver installation and update behavior to require Administrator privileges. This is documented in KB5005652— Manage new Point and Print default driver installation behavior (CVE-2021-34481). This change overrides all Point and Print Group Policy settings and ensures that only Administrators can install printer drivers from a print server using Point and Print.	Enabled: Show warning and elevation prompt.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.7.13	Ensure 'Point and Print Restrictions: When updating drivers for an existing connection' is set to 'Enabled: Show warning and elevation prompt'	This policy setting controls whether computers will show a warning and a security elevation prompt when users are updating drivers for an existing connection using Point and Print. The recommended state for this setting is: Enabled: Show warning and elevation prompt. Note: On August 10, 2021, Microsoft announced a Point and Print Default Behavior Change which modifies the default Point and Print driver installation and update behavior to require Administrator privileges. This is documented in KB5005652— Manage new Point and Print default driver installation behavior (CVE-2021-34481). This change overrides all Point and Print Group Policy settings and ensures that only Administrators can install printer drivers from a print server using Point and Print.	Enabled: Show warning and elevation prompt.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.8.1.1	Ensure 'Turn off notifications network usage' is set to 'Enabled'	This policy setting blocks applications from using the network to send notifications to update tiles, tile badges, toast, or raw notifications. This policy setting turns off the connection between Windows and the Windows Push Notification Service (WNS). This policy setting also stops applications from being able to poll application services to update tiles. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.4.1	Ensure 'Encryption Oracle Remediation' is set to 'Enabled: Force Updated Clients'	Some versions of the CredSSP protocol that is used by some applications (such as Remote Desktop Connection) are vulnerable to an encryption oracle attack against the client. This policy controls compatibility with vulnerable clients and servers and allows you to set the level of protection desired for the encryption oracle vulnerability. The recommended state for this setting is: Enabled: Force Updated Clients.	Enabled: Force Updated Clients.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.4.2	Ensure 'Remote host allows delegation of non- exportable credentials' is set to 'Enabled'	Remote host allows delegation of non-exportable credentials. When using credential delegation, devices provide an exportable version of credentials to the remote host. This exposes users to the risk of credential theft from attackers on the remote host. The Restricted Admin Mode and Windows Defender Remote Credential Guard features are two options to help protect against this risk. The recommended state for this setting is: Enabled. Note: More detailed information on Windows Defender Remote Credential Guard and how it compares to Restricted Admin Mode can be found at this link: Protect Remote Desktop credentials with Windows Defender Remote Credential Guard (Windows 10) | Microsoft Docs	Enabled.	This control is out of scope because the environment uses CrowdStrike as the approved endpoint protection platform, while the setting applies exclusively to Windows Defender. Measuring it would assess a component that is not the deployed security control.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.5.1	Ensure 'Turn On Virtualization Based Security' is set to 'Enabled'	This policy setting specifies whether Virtualization Based Security is enabled. Virtualization Based Security uses the Windows Hypervisor to provide support for security services. The recommended state for this setting is: Enabled Note: Virtualization Based Security requires a 64-bit version of Windows with Secure Boot enabled, which in turn requires that Windows was installed with a UEFI BIOS configuration, not a Legacy BIOS configuration. In addition, if running Windows on a virtual machine, the hardware-assisted CPU virtualization feature (Intel VT-x or AMD-V) must be exposed by the host to the guest VM. More information on system requirements for this feature can be found at Windows Defender Credential Guard Requirements (Windows 10) | Microsoft Docs Note #2: Credential Guard and Device Guard are not currently supported when using Azure IaaS VMs.	Enabled	This control is excluded because it requires UEFI boot, while 96% of the estate uses MBR. Applying the setting would create material availability and implementation risk.
18.9.5.2	Ensure 'Turn On Virtualization Based Security: Select Platform Security Level' is set to 'Secure Boot' or higher	This policy setting specifies whether Virtualization Based Security (VBS) is enabled. VBS uses the Windows Hypervisor to provide support for security services. The recommended state for this setting is: Secure Boot or Secure Boot and DMA Protection. Note: VBS requires a 64-bit version of Windows with Secure Boot enabled, which in turn requires that Windows was installed with a UEFI BIOS configuration, not a Legacy BIOS configuration. In addition, if running Windows on a virtual machine, the hardware- assisted CPU virtualization feature (Intel VT-x or AMD-V) must be exposed by the host to the guest VM. More information on system requirements for this feature can be found at Windows Defender Credential Guard Requirements (Windows 10) | Microsoft Docs Note #2: Credential Guard and Device Guard are not currently supported when using Azure IaaS VMs.	Secure Boot or Secure Boot and DMA Protection.	This control is excluded because it requires UEFI boot, while 96% of the estate uses MBR. Applying the setting would create material availability and implementation risk.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.5.3	Ensure 'Turn On Virtualization Based Security: Virtualization Based Protection of Code Integrity' is set to 'Enabled with UEFI lock'	This setting enables virtualization based protection of Kernel Mode Code Integrity. When this is enabled, kernel mode memory protections are enforced and the Code Integrity validation path is protected by the Virtualization Based Security feature. The recommended state for this setting is: Enabled with UEFI lock Note: Virtualization Based Security requires a 64-bit version of Windows with Secure Boot enabled, which in turn requires that Windows was installed with a UEFI BIOS configuration, not a Legacy BIOS configuration. In addition, if running Windows on a virtual machine, the hardware-assisted CPU virtualization feature (Intel VT-x or AMD-V) must be exposed by the host to the guest VM. More information on system requirements for this feature can be found at Windows Defender Credential Guard Requirements (Windows 10) | Microsoft Docs Note #2: Credential Guard and Device Guard are not currently supported when using Azure IaaS VMs.	Enabled with UEFI lock	This control is excluded because it requires UEFI boot, while 96% of the estate uses MBR. Applying the setting would create material availability and implementation risk.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.5.4	Ensure 'Turn On Virtualization Based Security: Require UEFI Memory Attributes Table' is set to 'True (checked)'	This option will only enable Virtualization Based Protection of Code Integrity on devices with UEFI firmware support for the Memory Attributes Table. Devices without the UEFI Memory Attributes Table may have firmware that is incompatible with Virtualization Based Protection of Code Integrity which in some cases can lead to crashes or data loss or incompatibility with certain plug-in cards. If not setting this option the targeted devices should be tested to ensure compatibility. The recommended state for this setting is: True (checked) Note: Virtualization Based Security requires a 64-bit version of Windows with Secure Boot enabled, which in turn requires that Windows was installed with a UEFI BIOS configuration, not a Legacy BIOS configuration. In addition, if running Windows on a virtual machine, the hardware-assisted CPU virtualization feature (Intel VT-x or AMD-V) must be exposed by the host to the guest VM. More information on system requirements for this feature can be found at Windows Defender Credential Guard Requirements (Windows 10) | Microsoft Docs Note #2: Credential Guard and Device Guard are not currently supported when using Azure IaaS VMs.	True (checked)	This control is excluded because it requires UEFI boot, while 96% of the estate uses MBR. Applying the setting would create material availability and implementation risk.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.5.5	Ensure 'Turn On Virtualization Based Security: Credential Guard Configuration' is set to 'Enabled with UEFI lock' (MS Only)	This setting lets users turn on Credential Guard with virtualization-based security to help protect credentials. The "Enabled with UEFI lock" option ensures that Credential Guard cannot be disabled remotely. In order to disable the feature, you must set the Group Policy to "Disabled" as well as remove the security functionality from each computer, with a physically present user, in order to clear configuration persisted in UEFI. The recommended state for this setting is: Enabled with UEFI lock, but only on Member Servers (not Domain Controllers). Note: Virtualization Based Security requires a 64-bit version of Windows with Secure Boot enabled, which in turn requires that Windows was installed with a UEFI BIOS configuration, not a Legacy BIOS configuration. In addition, if running Windows on a virtual machine, the hardware-assisted CPU virtualization feature (Intel VT-x or AMD-V) must be exposed by the host to the guest VM. More information on system requirements for this feature can be found at Windows Defender Credential Guard Requirements (Windows 10) | Microsoft Docs Note #2: Credential Guard and Device Guard are not currently supported when using Azure IaaS VMs.	Enabled with UEFI lock, but only on Member Servers (not Domain Controllers).	This control is excluded because it requires UEFI boot, while 96% of the estate uses MBR. Applying the setting would create material availability and implementation risk.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.5.6	Ensure 'Turn On Virtualization Based Security: Credential Guard Configuration' is set to 'Disabled' (DC Only)	This setting lets users turn on Credential Guard with virtualization-based security to help protect credentials. The recommended state for this setting is: Disabled on Domain Controllers. Note: Virtualization Based Security requires a 64-bit version of Windows with Secure Boot enabled, which in turn requires that Windows was installed with a UEFI BIOS configuration, not a Legacy BIOS configuration. In addition, if running Windows on a virtual machine, the hardware-assisted CPU virtualization feature (Intel VT-x or AMD-V) must be exposed by the host to the guest VM. More information on system requirements for this feature can be found at Windows Defender Credential Guard Requirements (Windows 10) | Microsoft Docs Note #2: Credential Guard and Device Guard are not currently supported when using Azure IaaS VMs.	Disabled on Domain Controllers.	This control is excluded because it requires UEFI boot, while 96% of the estate uses MBR. Applying the setting would create material availability and implementation risk.
18.9.5.7	Ensure 'Turn On Virtualization Based Security: Secure Launch Configuration' is set to 'Enabled'	Secure Launch protects the Virtualization Based Security environment from exploited vulnerabilities in device firmware. The recommended state for this setting is: Enabled. Note: Virtualization Based Security requires a 64-bit version of Windows with Secure Boot enabled, which in turn requires that Windows was installed with a UEFI BIOS configuration, not a Legacy BIOS configuration. In addition, if running Windows on a virtual machine, the hardware-assisted CPU virtualization feature (Intel VT-x or AMD-V) must be exposed by the host to the guest VM. More information on system requirements for this feature can be found at Windows Defender Credential Guard Requirements (Windows10) | Microsoft Docs Note #2: Credential Guard and Device Guard are not currently supported when using Azure IaaS VMs.	Enabled.	This control is excluded because it requires UEFI boot, while 96% of the estate uses MBR. Applying the setting would create material availability and implementation risk.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.7.2	Ensure 'Prevent device metadata retrieval from the Internet' is set to 'Enabled'	This policy setting allows you to prevent Windows from retrieving device metadata from the Internet. The recommended state for this setting is: Enabled. Note: This will not prevent the installation of basic hardware drivers, but does prevent associated third-party utility software from automatically being installed under the context of the SYSTEM account.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.13.1	Ensure 'Boot-Start Driver Initialization Policy' is set to 'Enabled: Good, unknown and bad but critical'	This policy setting allows you to specify which boot-start drivers are initialized based on a classification determined by an Early Launch Antimalware boot-start driver. The Early Launch Antimalware boot-start driver can return the following classifications for each boot-start driver: • Good: The driver has been signed and has not been tampered with. • Bad: The driver has been identified as malware. It is recommended that you do not allow known bad drivers to be initialized. • Bad, but required for boot: The driver has been identified as malware, but the computer cannot successfully boot without loading this driver. • Unknown: This driver has not been attested to by your malware detection application and has not been classified by the Early Launch Antimalware boot-start driver. If you enable this policy setting you will be able to choose which boot-start drivers to initialize the next time the computer is started. If your malware detection application does not include an Early Launch Antimalware boot-start driver or if your Early Launch Antimalware boot-start driver has been	Enabled: Good, unknown and bad but critical.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

		disabled, this setting has no effect and all boot-start drivers are initialized. The recommended state for this setting is: Enabled: Good, unknown and bad but critical.		
CIS #	**CIS Control Name**	**Description**	**Recommended Value**	**Rationale**
18.9.19.3	Ensure 'Configure registry policy processing: Process even if the Group Policy objects have not changed' is set to 'Enabled: TRUE'	The "Process even if the Group Policy objects have not changed" option updates and reapplies registry policies even if the registry policies have not changed. This setting affects all registry policy settings within the Administrative Templates folder and any other policies that store values in the registry. The recommended state for this setting is: Enabled: TRUE (checked).	Enabled: TRUE (checked).	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.19.5	Ensure 'Configure security policy processing: Process even if the Group Policy objects have not changed' is set to 'Enabled: TRUE'	The "Process even if the Group Policy objects have not changed" option updates and reapplies security policies even if the security policies have not changed. This setting affects all policy settings within the built-in security template of Group Policy (e.g. Windows Settings\Security Settings). The recommended state for this setting is: Enabled: TRUE (checked).	Enabled: TRUE (checked).	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.19.6	Ensure 'Continue experiences on this device' is set to 'Disabled'	This policy setting determines whether the Windows device is allowed to participate in cross-device experiences (continue experiences). The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.19.7	Ensure 'Turn off background refresh of Group Policy' is set to 'Disabled'	This policy setting prevents Group Policy from being updated while the computer is in use. This policy setting applies to Group Policy for computers, users and Domain Controllers. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.20.1.2	Ensure 'Turn off handwriting personalization data sharing' is set to 'Enabled'	This setting turns off data sharing from the handwriting recognition personalization tool. The handwriting recognition personalization tool enables Tablet PC users to adapt handwriting recognition to their own writing style by providing writing samples. The tool can optionally share user writing samples with Microsoft to improve handwriting recognition in future versions of Windows. The tool generates reports and transmits them to Microsoft over a secure connection. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.20.1.4	Ensure 'Turn off Internet Connection Wizard if URL connection is referring to Microsoft.com' is set to 'Enabled'	This policy setting specifies whether the Internet Connection Wizard can connect to Microsoft to download a list of Internet Service Providers (ISPs). The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.20.1.7	Ensure 'Turn off Registration if URL connection is referring to Microsoft.com' is set to 'Enabled'	This policy setting specifies whether the Windows Registration Wizard connects to Microsoft.com for online registration. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.20.1.8	Ensure 'Turn off Search Companion content file updates' is set to 'Enabled'	This policy setting specifies whether Search Companion should automatically download content updates during local and Internet searches. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.20.1.9	Ensure 'Turn off the "Order Prints" picture task' is set to 'Enabled'	This policy setting specifies whether the "Order Prints Online" task is available from Picture Tasks in Windows folders. The Order Prints Online Wizard is used to download a list of providers and allow users to order prints online. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.20.1.11	Ensure 'Turn off the Windows Messenger Customer Experience Improvement Program' is set to 'Enabled'	This policy setting specifies whether Windows Messenger can collect anonymous information about how the Windows Messenger software and service is used. Microsoft uses information collected through the Customer Experience Improvement Program to detect software flaws so that they can be corrected more quickly, enabling this setting will reduce the amount of data Microsoft is able to gather for this purpose. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.20.1.12	Ensure 'Turn off Windows Customer Experience Improvement Program' is set to 'Enabled'	This policy setting specifies whether the Windows Customer Experience Improvement Program can collect anonymous information about how Windows is used. Microsoft uses information collected through the Windows Customer Experience Improvement Program to improve features that are most used and to detect flaws so that they can be corrected more quickly. Enabling this setting will reduce the amount of data Microsoft is able to gather for this purpose. The recommended state for this setting is: Enabled.	This policy setting specifies whether the Windows Customer Experience Improvement Program can collect anonymous information about how Windows is used. Microsoft uses information collected through the Windows Customer Experience Improvement Program to improve features that are most used and to detect flaws so that they can be corrected more quickly. Enabling this setting will reduce the amount of data Microsoft is able to gather for this purpose. The recommended state for this setting is: Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.20.1.13	Ensure 'Turn off Windows Error Reporting' is set to 'Enabled'	This policy setting controls whether or not errors are reported to Microsoft. Error Reporting is used to report information about a system or application that has failed or has stopped responding and is used to improve the quality of the product. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.23.1	Ensure 'Support device authentication using certificate' is set to 'Enabled: Automatic'	This policy setting allows you to set support for Kerberos to attempt authentication using the certificate for the device to the domain. Support for device authentication using certificate will require connectivity to a DC in the device account domain which supports certificate authentication for computer accounts. The recommended state for this setting is: Enabled: Automatic.	Enabled: Automatic.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.24.1	Ensure 'Enumeration policy for external devices incompatible with Kernel DMA Protection' is set to 'Enabled: Block All'	This policy is intended to provide additional security against external DMA-capable devices. It allows for more control over the enumeration of external DMA-capable devices that are not compatible with DMA Remapping/device memory isolation and sandboxing. The recommended state for this setting is: Enabled: Block All. Note: This policy does not apply to 1394, PCMCIA or ExpressCard devices. The protection also only applies to Windows 10 R1803 or higher, and also requires a UEFI BIOS to function. Note #2: More information on this feature is available at this link: Kernel DMA Protection for Thunderbolt™ 3 (Windows 10) | Microsoft Docs.	Enabled: Block All.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.25.1	Ensure 'Configure password backup directory' is set to 'Enabled: Active Directory' or 'Enabled: Azure Active Directory'	This policy setting configures which directory Windows LAPS will use to back up the local admin account password. The recommended state for this setting is: Enabled: Active Directory or Enabled: Azure Active Directory. Note: Organizations that utilize third-party commercial software to manage unique & complex local Administrator passwords on domain members may opt to disregard these LAPS recommendations. Note #2: Windows LAPS does not support standalone computers - they must be joined to an Active Directory domain or Entra ID (formerly Azure Active Directory). Note #3: Windows LAPS does not support simultaneous storage of the local admin password in both directory types. Note #4: If the setting is configured and the managed device is not joined to the configured directory type, the local administrator password will not be managed by Windows LAPS.	Enabled: Active Directory or Enabled: Azure Active Directory.	This control is out of scope because it would require a 14-character minimum password length, conflicting with the applicable standard requiring 8 characters. Excluding the control avoids imposing contradictory requirements and preserves the approved password policy.
18.9.25.2	Ensure 'Do not allow password expiration time longer than required by policy' is set to 'Enabled'	This policy setting configures whether the password age dictated by the Windows LAPS "Password Settings" policy is enforced and cannot be extended manually (only shortened) by an authorized technician. If an expiration is detected, the password is changed immediately, and password expiration is set according to policy. The recommended state for this setting is: Enabled. Note: Organizations that utilize third-party commercial software to manage unique & complex local Administrator passwords on domain members may opt to disregard these LAPS recommendations. Note #2: Windows LAPS does not support standalone computers - they must be joined to an Active Directory domain or Entra ID (formerly Azure Active Directory).	Enabled.	This control is out of scope because it would require a 14-character minimum password length, conflicting with the applicable standard requiring 8 characters. Excluding the control avoids imposing contradictory requirements and preserves the approved password policy.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.25.3	Ensure 'Enable password encryption' is set to 'Enabled'	This policy setting controls whether the Windows LAPS managed password is encrypted before being sent to Active Directory. The recommended state for this setting is: Enabled. Note: Organizations that utilize third-party commercial software to manage unique & complex local Administrator passwords on domain members may opt to disregard these LAPS recommendations. Note #2: Windows LAPS does not support standalone computers - they must be joined to an Active Directory domain or Entra ID (formerly Azure Active Directory). Note #3: This setting has no effect unless the password has been configured to be backed up to Active Directory, and the Active Directory domain functional level is at Windows Server 2016 or above. Note #4: This setting has no relevance (but is harmless) when storing Windows LAPS passwords to Entra ID (formerly Azure Active Directory) as it automatically encrypts all Windows LAPS passwords.	Enabled.	This control is out of scope because it would require a 14-character minimum password length, conflicting with the applicable standard requiring 8 characters. Excluding the control avoids imposing contradictory requirements and preserves the approved password policy.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.25.4	Ensure 'Password Settings: Password Complexity' is set to 'Enabled: Large letters + small letters + numbers + special characters'	This policy setting configures the Windows LAPS Password Settings policy for password complexity. Each additional character in a password increases its complexity exponentially. For instance, a seven-character, all lower-case alphabetic password would have 26 to the power of 7 (approximately 8 x 10 to the power of 9 or 8 billion) possible combinations. At 1,000,000 attempts per second (a capability of many password-cracking utilities), it would only take 133 minutes to crack. A seven-character alphabetic password with case sensitivity has 52 to the power of 7 combinations. A seven-character case-sensitive alphanumeric password without punctuation has 627 combinations. An eight-character password has 26 to the power of 8 (or 2 x 10 to the power of 11) possible combinations. Although this might seem to be a large number, at 1,000,000 attempts per second it would take only 59 hours to try all possible passwords. Remember, these times will significantly increase for passwords that use ALT characters and other special keyboard characters such as "!" or "@". Proper use of the password settings can help make it difficult to mount a brute force attack. The recommended state for this setting is: Enabled: Large letters + small letters + numbers + special characters. Note: Organizations that utilize third-party commercial software to manage unique & complex local Administrator passwords on domain members may opt to disregard these LAPS recommendations. Note #2: Windows LAPS does not support standalone computers - they must be joined to an Active Directory domain or Entra ID (formerly Azure Active Directory).	Enabled: Large letters + small letters + numbers + special characters.	This control is out of scope because it would require a 14-character minimum password length, conflicting with the applicable standard requiring 8 characters. Excluding the control avoids imposing contradictory requirements and preserves the approved password policy.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.25.5	Ensure 'Password Settings: Password Length' is set to 'Enabled: 15 or more'	This policy setting configures the Windows LAPS Password Settings policy for password length. Each additional character in a password increases its complexity exponentially. For instance, a seven-character, all lower-case alphabetic password would have 26 to the power of 7 (approximately 8 x 10 to the power of 9 or 8 billion) possible combinations. At 1,000,000 attempts per second (a capability of many password-cracking utilities), it would only take 133 minutes to crack. A seven-character alphabetic password with case sensitivity has 52 to the power of 7 combinations. A seven-character case-sensitive alphanumeric password without punctuation has 627 combinations. An eight-character password has 26 to the power of 8 (or 2 x 10 to the power of 11) possible combinations. Although this might seem to be a large number, at 1,000,000 attempts per second it would take only 59 hours to try all possible passwords. Remember, these times will significantly increase for passwords that use ALT characters and other special keyboard characters such as "!" or "@". Proper use of the password settings can help make it difficult to mount a brute force attack. The recommended state for this setting is: Enabled: 15 or more. Note: Organizations that utilize third-party commercial software to manage unique & complex local Administrator passwords on domain members may opt to disregard these LAPS recommendations. Note #2: Windows LAPS does not support standalone computers - they must be joined to an Active Directory domain or Entra ID (formerly Azure Active Directory).	Enabled: 15 or more.	This control is out of scope because it would require a 14-character minimum password length, conflicting with the applicable standard requiring 8 characters. Excluding the control avoids imposing contradictory requirements and preserves the approved password policy.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.25.6	Ensure 'Password Settings: Password Age (Days)' is set to 'Enabled: 30 or fewer'	This policy setting configures the Windows LAPS Password Settings policy for password age. Because attackers can crack passwords, the more frequently the password is changed the less opportunity an attacker has to use a cracked password. The recommended state for this setting is: Enabled: 30 or fewer. Note: Organizations that utilize third-party commercial software to manage unique & complex local Administrator passwords on domain members may opt to disregard these LAPS recommendations. Note #2: Windows LAPS does not support standalone computers - they must be joined to an Active Directory domain or Entra ID (formerly Azure Active Directory).	Enabled: 30 or fewer.	This control is out of scope because it would require a 14-character minimum password length, conflicting with the applicable standard requiring 8 characters. Excluding the control avoids imposing contradictory requirements and preserves the approved password policy.
18.9.25.7	Ensure 'Post-authentication actions: Grace period (hours)' is set to 'Enabled: 8 or fewer hours, but not 0'	This policy settings configures post-authentication actions which will be executed after detecting an authentication by the Windows LAPS managed account. The Grace period refers to the amount of time (hours) to wait after an authentication before executing the specified post-authentication actions. The recommended state for this setting is: Enabled: 8 or fewer hours, but not 0. Note: Organizations that utilize third-party commercial software to manage unique & complex local Administrator passwords on domain members may opt to disregard these LAPS recommendations. Note #2: Windows LAPS does not support standalone computers - they must be joined to an Active Directory domain or Entra ID (formerly Azure Active Directory). Note #3: If this policy is set to 0 it prevents all post-authentication actions from occurring.	Enabled: 8 or fewer hours, but not 0.	This control is out of scope because it would require a 14-character minimum password length, conflicting with the applicable standard requiring 8 characters. Excluding the control avoids imposing contradictory requirements and preserves the approved password policy.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.25.8	Ensure 'Post-authentication actions: Actions' is set to 'Enabled: Reset the password and logoff the managed account' or higher	This policy settings configures post-authentication actions which will be executed after detecting an authentication by the LAPS managed account. The Action refers to actions to take upon expiry of the grace period before executing the specified post-authentication actions. Post-authentication actions: • Reset password: upon expiry of the grace period, the managed account password will be reset. • Reset the password and logoff the managed account: upon expiry of the grace period, the managed account password will be reset and any interactive logon sessions using the managed account will terminated. • Reset the password and reboot the device: upon expiry of the grace period, the managed account password will be reset and the managed device will be immediately rebooted. Warning: After an interactive logon session is terminated, other authenticated sessions using the Windows LAPS managed account may still be active. The only way to ensure that the previous password is no longer in use is to reboot the OS. The recommended state for this setting is: Enabled: Reset the password and logoff the managed account or higher. Note: Organizations that utilize third-party commercial software to manage unique & complex local Administrator passwords on domain members may opt to disregard these LAPS recommendations. Note #2: Windows LAPS does not support standalone computers - they must be joined to an Active Directory domain or Entra ID (formerly Azure Active Directory).	Enabled: Reset the password and logoff the managed account or higher.	This control is out of scope because it would require a 14-character minimum password length, conflicting with the applicable standard requiring 8 characters. Excluding the control avoids imposing contradictory requirements and preserves the approved password policy.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.26.2	Ensure 'Configures LSASS to run as a protected process' is set to 'Enabled: Enabled with UEFI Lock'	This policy setting controls whether the Local Security Authority Subservice Service (LSASS) runs in protected mode and also has the option to lock in protected mode with Unified Extensible Firmware Interface (UEFI). The Local Security Authority (LSA), which includes the LSASS process, validates users for local and remote sign-ins and enforces local security policies. The recommended state for this setting is: Enabled: Enabled with UEFI Lock. Note: This additional protection to prevent reading memory and code injection by non-protected processes is supported by Windows 8.1 (or newer).	Enabled: Enabled with UEFI Lock.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.27.1	Ensure 'Disallow copying of user input methods to the system account for sign-in' is set to 'Enabled'	This policy prevents automatic copying of user input methods to the system account for use on the sign-in screen. The user is restricted to the set of input methods that are enabled in the system account. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.28.1	Ensure 'Block user from showing account details on sign-in' is set to 'Enabled'	This policy prevents the user from showing account details (email address or user name) on the sign-in screen. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.28.3	Ensure 'Do not enumerate connected users on domain-joined computers' is set to 'Enabled'	This policy setting prevents connected users from being enumerated on domain-joined computers. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.28.4	Ensure 'Enumerate local users on domain-joined computers' is set to 'Disabled' (MS only)	This policy setting allows local users to be enumerated on domain-joined computers. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.28.5	Ensure 'Turn off app notifications on the lock screen' is set to 'Enabled'	This policy setting allows you to prevent app notifications from appearing on the lock screen. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.28.6	Ensure 'Turn off picture password sign-in' is set to 'Enabled'	This policy setting allows you to control whether a domain user can sign in using a picture password. The recommended state for this setting is: Enabled. Note: If the picture password feature is permitted, the user's domain password is cached in the system vault when using it.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.28.7	Ensure 'Turn on convenience PIN sign-in' is set to 'Disabled'	This policy setting allows you to control whether a domain user can sign in using a convenience PIN. In Windows 10, convenience PIN was replaced with Passport, which has stronger security properties. To configure Passport for domain users, use the policies under Computer Configuration\Administrative Templates\Windows Components\Microsoft Passport for Work. Note: The user's domain password will be cached in the system vault when using this feature. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.31.1	Ensure 'Allow Clipboard synchronization across devices' is set to 'Disabled'	This policy setting determines whether Clipboard contents can be synchronized across devices. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.31.2	Ensure 'Allow upload of User Activities' is set to 'Disabled'	This policy setting determines whether published User Activities can be uploaded to the cloud. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.33.6.1	Ensure 'Allow network connectivity during connected-standby (on battery)' is set to 'Disabled'	This policy setting allows you to control the network connectivity state in standby on modern standby-capable systems. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.33.6.2	Ensure 'Allow network connectivity during connected-standby (plugged in)' is set to 'Disabled'	This policy setting allows you to control the network connectivity state in standby on modern standby-capable systems. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.35.2	Ensure 'Configure Solicited Remote Assistance' is set to 'Disabled'	This policy setting allows you to turn on or turn off Solicited (Ask for) Remote Assistance on this computer. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.36.1	Ensure 'Enable RPC Endpoint Mapper Client Authentication' is set to 'Enabled' (MS only)	This policy setting controls whether RPC clients authenticate with the Endpoint Mapper Service when the call they are making contains authentication information. The Endpoint Mapper Service on computers running Windows NT4 (all service packs) cannot process authentication information supplied in this manner. This policy setting can cause a specific issue with 1-way forest trusts if it is applied to the trusting domain DCs (see Microsoft KB3073942), so we do not recommend applying it to Domain Controllers. Note: This policy will not be in effect until the system is rebooted. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.36.2	Ensure 'Restrict Unauthenticated RPC clients' is set to 'Enabled: Authenticated' (MS only)	This policy setting controls how the RPC server runtime handles unauthenticated RPC clients connecting to RPC servers. This policy setting impacts all RPC applications. In a domain environment this policy setting should be used with caution as it can impact a wide range of functionality including group policy processing itself. Reverting a change to this policy setting can require manual intervention on each affected machine. This policy setting should never be applied to a Domain Controller. A client will be considered an authenticated client if it uses a named pipe to communicate with the server or if it uses RPC Security. RPC Interfaces that have specifically requested to be accessible by unauthenticated clients may be exempt from this restriction, depending on the selected value for this policy setting. • "None" allows all RPC clients to connect to RPC Servers running on the machine on which the policy setting is applied. • "Authenticated" allows only authenticated RPC Clients (per the definition above) to connect to RPC Servers running on the machine on which the policy setting is applied. Exemptions are granted to interfaces that have requested them. • "Authenticated without exceptions" allows only authenticated RPC Clients (per the definition above) to connect to RPC Servers running on the machine on which the policy setting is applied. No exceptions are allowed. This value has the potential to cause serious problems and is not recommended. Note: This policy setting will not be applied until the system is rebooted. The recommended state for this setting is: Enabled: Authenticated.	Enabled: Authenticated.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.39.2	Ensure 'Configure SAM change password RPC methods policy' is set to 'Enabled: Allow strong encryption change password RPC method only' (DC only)	This policy setting determines which RPC methods can be used to change passwords stored in the Security Account Manager (SAM). The recommended state for this setting is: Enabled: Allow strong encryption change password RPC method only.	Enabled: Allow strong encryption change password RPC method only.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.47.5.1	Ensure 'Microsoft Support Diagnostic Tool: Turn on MSDT interactive communication with support provider' is set to 'Disabled'	This policy setting configures Microsoft Support Diagnostic Tool (MSDT) interactive communication with the support provider. MSDT gathers diagnostic data for analysis by support professionals. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.47.11.1	Ensure 'Enable/Disable PerfTrack' is set to 'Disabled'	This policy setting specifies whether to enable or disable tracking of responsiveness events. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.9.49.1	Ensure 'Turn off the advertising ID' is set to 'Enabled'	This policy setting turns off the advertising ID, preventing apps from using the ID for experiences across apps. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.51.1.1	Ensure 'Enable Windows NTP Client' is set to 'Enabled'	This policy setting specifies whether the Windows NTP Client is enabled. Enabling the Windows NTP Client allows synchronization from a systems computer clock to NTP server(s). The recommended state for this setting is: Enabled. Note: If a third-party time provider is used in the environment, an exception to this recommendation will be needed.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.9.51.1.2	Ensure 'Enable Windows NTP Server' is set to 'Disabled' (MS only)	This policy setting specifies whether the Windows NTP Server is enabled. Disabling this setting prevents the system from acting as a NTP Server (time source) to service NTP requests from other systems (NTP Clients). The recommended state for this setting is: Disabled. Note: In most enterprise managed environments, you should not disable the Windows NTP Server on Domain Controllers, as it is very important for the operation of NT5DS (domain hierarchy-based) time synchronization.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.4.1	Ensure 'Allow a Windows app to share application data between users' is set to 'Disabled'	Manages a Windows app's ability to share data between users who have installed the app. Data is shared through the SharedLocal folder. This folder is available through the Windows.Storage API. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.8.3	Ensure 'Turn off Autoplay' is set to 'Enabled: All drives'	Autoplay starts to read from a drive as soon as you insert media in the drive, which causes the setup file for programs or audio media to start immediately. An attacker could use this feature to launch a program to damage the computer or data on the computer. Autoplay is disabled by default on some removable drive types, such as floppy disk and network drives, but not on CD-ROM drives. Note: You cannot use this policy setting to enable Autoplay on computer drives in which it is disabled by default, such as floppy disk and network drives. The recommended state for this setting is: Enabled: All drives.	Enabled: All drives.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.9.1.1	Ensure 'Configure enhanced anti-spoofing' is set to 'Enabled'	This policy setting determines whether enhanced anti-spoofing is configured for devices which support it. The recommended state for this setting is: Enabled.	Enabled.	This control is out of scope because it would require a 14-character minimum password length, conflicting with the applicable standard requiring 8 characters. Excluding the control avoids imposing contradictory requirements and preserves the approved password policy.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.11.1	Ensure 'Allow Use of Camera' is set to 'Disabled'	This policy setting controls whether the use of Camera devices on the machine are permitted. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.13.1	Ensure 'Turn off cloud consumer account state content' is set to 'Enabled'	This policy setting determines whether cloud consumer account state content is allowed in all Windows experiences. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.13.2	Ensure 'Turn off cloud optimized content' is set to 'Enabled'	This policy setting turns off cloud optimized content in all Windows experiences. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.14.1	Ensure 'Require pin for pairing' is set to 'Enabled: First Time' OR 'Enabled: Always'	This policy setting controls whether or not a PIN is required for pairing to a wireless display device. The recommended state for this setting is: Enabled: First Time OR Enabled: Always.	Enabled: First Time OR Enabled: Always.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.15.1	Ensure 'Do not display the password reveal button' is set to 'Enabled'	This policy setting allows you to configure the display of the password reveal button in password entry user experiences. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.16.1	Ensure 'Allow Diagnostic Data' is set to 'Enabled: Diagnostic data off (not recommended)' or 'Enabled: Send required diagnostic data'	This policy setting determines the amount of diagnostic and usage data reported to Microsoft: • A value of (0) Diagnostic data off (not recommended). Using this value, no diagnostic data is sent from the device. This value is only supported on Enterprise, Education, and Server editions. If you choose this setting, devices in your organization will still be secure. • A value of (1) Send required diagnostic data. This is the minimum diagnostic data necessary to keep Windows secure, up to date, and performing as expected. Using this value disables the Optional diagnostic data control in the Settings app. •	Enabled: Diagnostic data off (not recommended) or Enabled: Send required diagnostic data.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

		A value of (3) Send optional diagnostic data. Additional diagnostic data is collected that helps us to detect, diagnose and fix issues, as well as make product improvements. Required diagnostic data will always be included when you choose to send optional diagnostic data. Optional diagnostic data can also include diagnostic log files and crash dumps. Use the Limit Dump Collection and the Limit Diagnostic Log Collection policies for more granular control of what optional diagnostic data is sent. Windows telemetry settings apply to the Windows operating system and some first party apps. This setting does not apply to third party apps running on Windows 10/11. The recommended state for this setting is: Enabled: Diagnostic data off (not recommended) or Enabled: Send required diagnostic data. Note: If your organization relies on Windows Update, the minimum recommended setting is Required diagnostic data. Because no Windows Update information is collected when diagnostic data is off, important information about update failures is not sent. Microsoft uses this information to fix the causes of those failures and improve the quality of updates. Note #2: The Configure diagnostic data opt-in settings user interface group policy can be used to prevent end users from changing their data collection settings. Note #3: Enhanced diagnostic data setting is not available on Windows 11 and Windows Server 2022 and has been replaced with policies that can control the amount of optional diagnostic data that is sent. For more information on these settings visit Manage diagnostic data using Group Policy and MDM		

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.16.3	Ensure 'Disable OneSettings Downloads' is set to 'Enabled'	This policy setting controls whether Windows attempts to connect with the OneSettings service to download configuration settings. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.16.5	Ensure 'Enable OneSettings Auditing' is set to 'Enabled'	This policy setting controls whether Windows records attempts to connect with the OneSettings service to the Event Log. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.16.6	Ensure 'Limit Diagnostic Log Collection' is set to 'Enabled'	This policy setting controls whether additional diagnostic logs are collected when more information is needed to troubleshoot a problem on the device. The recommended state for this setting is: Enabled. Note: Diagnostic logs are only sent when the device has been configured to send optional diagnostic data. Diagnostic data is limited when recommendation Allow Diagnostic Data is set to Enabled: Diagnostic data off (not recommended) or Enabled: Send required diagnostic data to send only basic information.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.16.7	Ensure 'Limit Dump Collection' is set to 'Enabled'	This policy setting limits the type of memory dumps that can be collected when more information is needed to troubleshoot a problem. The recommended state for this setting is: Enabled. Note: Memory dumps are only sent when the device has been configured to send optional diagnostic data. Diagnostic data is limited when recommendation Allow Diagnostic Data is set to Enabled: Diagnostic data off (not recommended) or Enabled: Send required diagnostic data to send only basic information.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.16.8	Ensure 'Toggle user control over Insider builds' is set to 'Disabled'	This policy setting determines whether users can access the Insider build controls in the Advanced Options for Windows Update. These controls are located under "Get Insider builds," and enable users to make their devices available for downloading and installing Windows preview software. The recommended state for this setting is: Disabled. Note: This policy setting applies only to devices running Windows 10 Pro or Windows 10 Enterprise, up until Release 1703. For Release 1709 or newer, Microsoft encourages using the Manage preview builds setting (Rule 18.9.103.1.1). We have kept this setting in the benchmark to ensure that any older builds of Windows 10 in the environment are still enforced.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.18.1	Ensure 'Enable App Installer' is set to 'Disabled'	This policy setting controls whether user have access to the Windows Package Manager. Windows Package Manager is a package manager solution that consists of a command line tool and set of services for installing applications on Microsoft Windows Server 2019 (or newer). The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.18.2	Ensure 'Enable App Installer Experimental Features' is set to 'Disabled'	This policy setting controls whether users can enable experimental features in the Windows Package Manager. The recommended state for this setting is Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.18.3	Ensure 'Enable App Installer Hash Override' is set to 'Disabled'	This policy setting controls whether or not users can override the SHA256 security validation in the Windows Package Manager settings. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.18.5	Ensure 'Enable App Installer ms-appinstaller protocol' is set to 'Disabled'	This policy setting controls whether users can install packages from a website that is using the ms-appinstaller protocol. The ms-appinstaller protocol allows users to install an application by clicking a link on a website. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.18.7	Ensure 'Enable Windows Package Manager command line interfaces' is set to 'Disabled'	This policy setting controls whether a user can perform actions using the Windows Package Manager through a command line interface (Windows CLI or PowerShell). The recommended state for this setting is: Disabled. Note: This policy does not override the Enable App Installer policy, which is set to Disabled in the L2 profile of the CIS Windows Operating System Benchmarks.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.26.3.1	Ensure 'Setup: Control Event Log behavior when the log file reaches its maximum size' is set to 'Disabled'	This policy setting controls Event Log behavior when the log file reaches its maximum size. The recommended state for this setting is: Disabled. Note: Old events may or may not be retained according to the Backup log automatically when full policy setting.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.29.2	Ensure 'Do not apply the Mark of the Web tag to files copied from insecure sources' is set to 'Disabled'	This policy setting determines whether files that are sourced from insecure locations are tagged with Mark of the Web (MOTW). The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.29.4	Ensure 'Turn off heap termination on corruption' is set to 'Disabled'	Without heap termination on corruption, legacy plug-in applications may continue to function when a File Explorer session has become corrupt. Ensuring that heap termination on corruption is active will prevent this. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.29.5	Ensure 'Turn off shell protocol protected mode' is set to 'Disabled'	This policy setting allows you to configure the amount of functionality that the shell protocol can have. When using the full functionality of this protocol, applications can open folders and launch files. The protected mode reduces the functionality of this protocol allowing applications to only open a limited set of folders. Applications are not able to open files with this protocol when it is in the protected mode. It is recommended to leave this protocol in the protected mode to increase the security of Windows. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.37.1	Ensure 'Turn off location' is set to 'Enabled'	This policy setting turns off the location feature for the computer. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.41.1	Ensure 'Allow Message Service Cloud Sync' is set to 'Disabled'	This policy setting allows backup and restore of cellular text messages to Microsoft's cloud services. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.43.4.1	Ensure 'Enable EDR in block mode' is set to 'Enabled'	This policy setting controls whether Microsoft Defender Antivirus Endpoint Detection and Response (EDR) is enabled in block mode (passive remediation). The recommended state for this setting is: Enabled. Note: EDR in block mode is only available in Microsoft Defender for Endpoint Plan 2. Note #2: This setting is available with Microsoft Defender Antivirus platform release v4.18.2202.X and newer.	Enabled.	This control is out of scope because the environment uses CrowdStrike as the approved endpoint protection platform, while the setting applies exclusively to Windows Defender. Measuring it would assess a component that is not the deployed security control.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.43.5.1	Ensure 'Configure local setting override for reporting to Microsoft MAPS' is set to 'Disabled'	This policy setting configures a local override for the configuration to join Microsoft Active Protection Service (MAPS), which Microsoft renamed to Windows Defender Antivirus Cloud Protection Service and then Microsoft Defender Antivirus Cloud Protection Service. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.43.5.2	Ensure 'Join Microsoft MAPS' is set to 'Disabled'	This policy setting allows you to join Microsoft Active Protection Service (MAPS), which Microsoft has now renamed to Windows Defender Antivirus Cloud Protection Service and then Microsoft Defender Antivirus Cloud Protection Service. Microsoft MAPS / Microsoft Defender Antivirus Cloud Protection Service is the online community that helps you choose how to respond to potential threats. The community also helps stop the spread of new malicious software infections. You can choose to send basic or additional information about detected software. Additional information helps Microsoft create new definitions and help it to protect your computer. Possible options are: • (0x0) Disabled (default) • (0x1) Basic membership •	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

		(0x2) Advanced membership Basic membership will send basic information to Microsoft about software that has been detected including where the software came from the actions that you apply or that are applied automatically and whether the actions were successful. Advanced membership in addition to basic information will send more information to Microsoft about malicious software spyware and potentially unwanted software including the location of the software file names how the software operates and how it has impacted your computer. The recommended state for this setting is: Disabled. Note: In Windows 10 and above, Basic membership is no longer available, so setting the value to 1 Basic, or 2 Advanced, enrolls the device into Advanced membership. For more information, please visit: Turn on cloud protection in Microsoft Defender Antivirus - Microsoft Defender for Endpoint | Microsoft Learn.		

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.43.6.1.1	Ensure 'Configure Attack Surface Reduction rules' is set to 'Enabled'	This policy setting controls the state for the Attack Surface Reduction (ASR) rules. The recommended state for this setting is: Enabled.	Enabled.	This control is out of scope because the environment uses CrowdStrike as the approved endpoint protection platform, while the setting applies exclusively to Windows Defender. Measuring it would assess a component that is not the deployed security control.
18.10.43.6.1.2	Ensure 'Configure Attack Surface Reduction rules: Set the state for each ASR rule' is configured	This policy setting sets the Attack Surface Reduction rules. The recommended state for this setting is: 26190899-1602-49e8-8b27-eb1d0a1ce869 - 1 (Block Office communication application from creating child processes) 3b576869-a4ec-4529-8536-b80a7769e899 - 1 (Block Office applications from creating executable content) 56a863a9-875e-4185-98a7-b882c64b5ce5 - 1 (Block abuse of exploited vulnerable signed drivers) 5beb7efe-fd9a-4556-801d-275e5ffc04cc - 1 (Block execution of potentially obfuscated scripts) 75668c1f-73b5-4cf0-bb93-3ecf5cb7cc84 - 1 (Block Office applications from injecting code into other processes) 7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c - 1 (Block Adobe Reader from creating child processes) 9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2 - 1 (Block credential stealing from the Windows local security authority subsystem (lsass.exe)) b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4 - 1 (Block untrusted and unsigned processes that run from USB) be9ba2d9-53ea-4cdc-84e5-9b1eeee46550 - 1 (Block executable	26190899-1602-49e8-8b27-eb1d0a1ce869 - 1 (Block Office communication application from creating child processes) 3b576869-a4ec-4529-8536-b80a7769e899 - 1 (Block Office applications from creating executable content) 56a863a9-875e-4185-98a7-b882c64b5ce5 - 1 (Block abuse of exploited vulnerable signed drivers) 5beb7efe-fd9a-4556-801d-275e5ffc04cc - 1 (Block execution of potentially obfuscated scripts) 75668c1f-73b5-4cf0-bb93-3ecf5cb7cc84 - 1 (Block Office applications from injecting code into other processes) 7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c - 1 (Block Adobe Reader from creating child processes) 9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2 - 1 (Block credential stealing from the Windows local security authority subsystem (lsass.exe))	This control is out of scope because the environment uses CrowdStrike as the approved endpoint protection platform, while the setting applies exclusively to Windows Defender. Measuring it would assess a component that is not the deployed security control.

		content from email client and webmail) d3e037e1-3eb8-44c8-a917-57927947596d - 1 (Block JavaScript or VBScript from launching downloaded executable content) d4f940ab-401b-4efc-aadc-ad5f3c50688a - 1 (Block Office applications from creating child processes) e6db77e5-3df2-4cf1-b95a-636979351e5b - 1 (Block persistence through WMI event subscription) Note: More information on ASR rules can be found at the following link: Use Attack surface reduction rules to prevent malware infection | Microsoft Docs	b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4 - 1 (Block untrusted and unsigned processes that run from USB) be9ba2d9-53ea-4cdc-84e5-9b1eeee46550 - 1 (Block executable content from email client and webmail) d3e037e1-3eb8-44c8-a917-57927947596d - 1 (Block JavaScript or VBScript from launching downloaded executable content) d4f940ab-401b-4efc-aadc-ad5f3c50688a - 1 (Block Office applications from creating child processes) e6db77e5-3df2-4cf1-b95a-636979351e5b - 1 (Block persistence through WMI event subscription)	
18.10.43.6.3.1	Ensure 'Prevent users and apps from accessing dangerous websites' is set to 'Enabled: Block'	This policy setting controls Microsoft Defender Exploit Guard network protection. The recommended state for this setting is: Enabled: Block.	Enabled: Block.	This control is out of scope because the environment uses CrowdStrike as the approved endpoint protection platform, while the setting applies exclusively to Windows Defender. Measuring it would assess a component that is not the deployed security control.
18.10.43.7.1	Ensure 'Enable file hash computation feature' is set to 'Enabled'	This setting determines whether hash values are computed for files scanned by Microsoft Defender. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.43.8.1	Ensure 'Convert warn verdict to block' is set to 'Enabled'	This policy setting controls whether Microsoft Defender Antivirus network protection will display a warning, or block network traffic. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.43.10.1	Ensure 'Configure real-time protection and Security Intelligence Updates during OOBE' is set to 'Enabled'	This policy setting configures whether Real-time Protection and Security Intelligence Updates are enabled during the Out of Box experience (OOBE). The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.43.10.2	Ensure 'Scan all downloaded files and attachments' is set to 'Enabled'	This policy setting configures scanning for all downloaded files and attachments. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.43.10.3	Ensure 'Turn off real-time protection' is set to 'Disabled'	This policy setting configures real-time protection prompts for known malware detection. Microsoft Defender Antivirus alerts you when malware or potentially unwanted software attempts to install itself or to run on your computer. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.43.10.4	Ensure 'Turn on behavior monitoring' is set to 'Enabled'	This policy setting allows you to configure behavior monitoring for Microsoft Defender Antivirus. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.43.10.5	Ensure 'Turn on script scanning' is set to 'Enabled'	This policy setting allows script scanning to be turned on/off. Script scanning intercepts scripts then scans them before they are executed on the system. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.43.11.1.1.1	Ensure 'Configure Brute-Force Protection aggressiveness' is set to 'Enabled: Medium' or higher	This policy setting configures whether Brute-Force Protection in Microsoft Defender Antivirus is enabled. Brute-force protection can detect and block attempts to forcibly sign in to a system. The recommended state for this setting is: Enabled: Medium. Configuring this setting to High also conforms to the benchmark.	Enabled: Medium. Configuring this setting to High also conforms to the benchmark.	This control is out of scope because the environment uses CrowdStrike as the approved endpoint protection platform, while the setting applies exclusively to Windows Defender. Measuring it would assess a component that is not the deployed security control.
18.10.43.11.1.1.2	Ensure 'Configure Remote Encryption Protection Mode' is set to 'Enabled: Audit' or higher	This policy setting configures the Brute-Force Protection feature in Microsoft Defender Antivirus. Brute-Force Protection can detect and block attempts to forcibly initiate sign-ins and sessions. The recommended state for this setting is: Enabled: Audit. Configuring this setting to Block also conforms to the benchmark. Note: Configuring the value to either Default or Off does not conform to this benchmark. Note #2: This setting's name is duplicated in the Remote Encryption Protection section, but they configure two different behaviors.	Enabled: Audit. Configuring this setting to Block also conforms to the benchmark.	This control is out of scope because the environment uses CrowdStrike as the approved endpoint protection platform, while the setting applies exclusively to Windows Defender. Measuring it would assess a component that is not the deployed security control.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.43.11.1.2.1	Ensure 'Configure how aggressively Remote Encryption Protection blocks threats' is set to 'Enabled: Medium' or higher	This policy setting configures how aggressively Remote Encryption Prevention Protection blocks malicious IP addresses. The recommended state for this setting is: Enabled: Medium or higher. Configuring this setting to High also conforms to the benchmark.	Enabled: Medium or higher. Configuring this setting to High also conforms to the benchmark.	This control is out of scope because the environment uses CrowdStrike as the approved endpoint protection platform, while the setting applies exclusively to Windows Defender. Measuring it would assess a component that is not the deployed security control.
18.10.43.12.1	Ensure 'Configure Watson events' is set to 'Disabled'	This policy setting allows you to configure whether or not Watson events are sent. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.43.13.1	Ensure 'Scan excluded files and directories during quick scans' is set to 'Enabled: 1'	This policy setting manages whether or not Microsoft Defender Antivirus scans excluded files and directories when running a Quick Scan. The recommended state for this setting is: Enabled: 1.	Enabled: 1.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.43.13.2	Ensure 'Scan packed executables' is set to 'Enabled'	This policy setting manages whether or not Microsoft Defender Antivirus scans packed executables. Packed executables are executable files that contain compressed code. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.43.13.3	Ensure 'Scan removable drives' is set to 'Enabled'	This policy setting manages whether or not to scan for malicious software and unwanted software in the contents of removable drives, such as USB flash drives, when running a full scan. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.43.13.4	Ensure 'Trigger a quick scan after X days without any scans' is set to 'Enabled: 7'	This policy setting configures the number of days after the last scan (of any type) before an aggressive Quick Scan is automatically triggered. The recommended state for this setting is: Enabled: 7 days.	Enabled: 7 days.	This control is out of scope because the environment uses CrowdStrike as the approved endpoint protection platform, while the setting applies exclusively to Windows Defender. Measuring it would assess a component that is not the deployed security control.
18.10.43.13.5	Ensure 'Turn on e-mail scanning' is set to 'Enabled'	This policy setting configures e-mail scanning. When e-mail scanning is enabled, the engine will parse the mailbox and mail files, according to their specific format, in order to analyze the mail bodies and attachments. Several e-mail formats are currently supported, for example: pst (Outlook), dbx, mbx, mime (Outlook Express), binhex (Mac). The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.43.16	Ensure 'Configure detection for potentially unwanted applications' is set to 'Enabled: Block'	This policy setting controls detection and action for Potentially Unwanted Applications (PUA), which are sneaky unwanted application bundlers or their bundled applications, that can deliver adware or malware. The recommended state for this setting is: Enabled: Block. For more information, see this link: Block potentially unwanted applications with Microsoft Defender Antivirus | Microsoft Docs	Enabled: Block. For more information, see this link: Block potentially unwanted applications with Microsoft Defender Antivirus | Microsoft Docs	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.43.17	Ensure 'Control whether exclusions are visible to local users' is set to 'Enabled'	This policy setting controls whether Microsoft Defender Antivirus exclusions are visible to local users on the system. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.51.1	Ensure 'Prevent the usage of OneDrive for file storage' is set to 'Enabled'	This policy setting lets you prevent apps and features from working with files on OneDrive using the Next Generation Sync Client. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.56.1	Ensure 'Turn off Push To Install service' is set to 'Enabled'	This policy setting controls whether users can push Apps to the device from the Microsoft Store App running on other devices or the web. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.57.3.2.1	Ensure 'Restrict Remote Desktop Services users to a single Remote Desktop Services session' is set to 'Enabled'	This policy setting allows you to restrict users to a single Remote Desktop Services session. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.57.3.3.1	Ensure 'Allow UI Automation redirection' is set to 'Disabled'	This policy setting determines whether User Interface (UI) Automation client applications running on the local computer can access UI elements on the server. UI Automation gives programs access to most UI elements, which allows use of assistive technology products like Magnifier and Narrator that need to interact with the UI in order to work properly. UI information also allows automated test scripts to interact with the UI. For example, the local computer´s Narrator and Magnifier clients can be used to interact with UI on a web page opened in a remote session. The recommended state for this setting is: Disabled. Note: Remote Desktop sessions don´t currently support UI Automation redirection.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.57.3.3.2	Ensure 'Do not allow COM port redirection' is set to 'Enabled'	This policy setting specifies whether to prevent the redirection of data to client COM ports from the remote computer in a Remote Desktop Services session. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.57.3.3.3	Ensure 'Do not allow drive redirection' is set to 'Enabled'	This policy setting prevents users from sharing the local drives on their client computers to Remote Desktop Servers that they access. Mapped drives appear in the session folder tree in Windows Explorer in the following format: \\TSClient\<driveletter>$ If local drives are shared they are left vulnerable to intruders who want to exploit the data that is stored on them. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.57.3.3.5	Ensure 'Do not allow LPT port redirection' is set to 'Enabled'	This policy setting specifies whether to prevent the redirection of data to client LPT ports during a Remote Desktop Services session. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.57.3.3.6	Ensure 'Do not allow supported Plug and Play device redirection' is set to 'Enabled'	This policy setting allows you to control the redirection of supported Plug and Play devices, such as Windows Portable Devices, to the remote computer in a Remote Desktop Services session. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.57.3.3.7	Ensure 'Do not allow WebAuthn redirection' is set to 'Enabled'	This policy setting controls the redirection of web authentication (WebAuthn) requests from a Remote Desktop session to the local device. This redirection enables users to authenticate to resources inside the Remote Desktop session using their local authenticator (e.g. Windows Hello for Business, security key, or other). The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.57.3.3.8	Ensure 'Restrict clipboard transfer from server to client' is set to 'Enabled: Disable clipboard transfers from server to client'	This policy setting controls whether the clipboard can be used to transfer data from the Remote Desktop session to the client. The recommended state for this setting is: Enabled: Disable clipboard transfers from server to client.	Enabled: Disable clipboard transfers from server to client.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.57.3.9.1	Ensure 'Always prompt for password upon connection' is set to 'Enabled'	This policy setting specifies whether Remote Desktop Services always prompts the client computer for a password upon connection. You can use this policy setting to enforce a password prompt for users who log on to Remote Desktop Services, even if they already provided the password in the Remote Desktop Connection client. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured because it was not included in the latest approved syndication and is outside the CIS baseline policy. Excluding it maintains alignment with the currently governed benchmark scope.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.57.3.9.2	Ensure 'Require secure RPC communication' is set to 'Enabled'	This policy setting allows you to specify whether Remote Desktop Services requires secure Remote Procedure Call (RPC) communication with all clients or allows unsecured communication. You can use this policy setting to strengthen the security of RPC communication with clients by allowing only authenticated and encrypted requests. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.57.3.9.3	Ensure 'Require use of specific security layer for remote (RDP) connections' is set to 'Enabled: SSL'	This policy setting specifies whether to require the use of a specific security layer to secure communications between clients and RD Session Host servers during Remote Desktop Protocol (RDP) connections. The recommended state for this setting is: Enabled: SSL. Note: In spite of this setting being labeled SSL, it is actually enforcing Transport Layer Security (TLS), not the older and less secure, Secure Socket Layer (SSL) protocol.	Enabled: SSL.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.57.3.9.4	Ensure 'Require user authentication for remote connections by using Network Level Authentication' is set to 'Enabled'	This policy setting allows you to specify whether to require user authentication for remote connections to the RD Session Host server by using Network Level Authentication. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.57.3.9.5	Ensure 'Set client connection encryption level' is set to 'Enabled: High Level'	This policy setting specifies whether to require the use of a specific encryption level to secure communications between client computers and RD Session Host servers during Remote Desktop Protocol (RDP) connections. This policy only applies when you are using native RDP encryption. However, native RDP encryption (as opposed to SSL encryption) is not recommended. This policy does not apply to SSL encryption. The recommended state for this setting is: Enabled: High Level.	Enabled: High Level.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.57.3.10.1	Ensure 'Set time limit for active but idle Remote Desktop Services sessions' is set to 'Enabled: 15 minutes or less, but not Never (0)'	This policy setting allows you to specify the maximum amount of time that an active Remote Desktop Services session can be idle (without user input) before it is automatically disconnected. The recommended state for this setting is: Enabled: 15 minutes or less, but not Never (0).	Enabled: 15 minutes or less, but not Never (0).	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.57.3.11.1	Ensure 'Do not delete temp folders upon exit' is set to 'Disabled'	This policy setting specifies whether Remote Desktop Services retains a user's per-session temporary folders at logoff. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.57.3.11.2	Ensure 'Do not use temporary folders per session' is set to 'Disabled'	By default, Remote Desktop Services creates a separate temporary folder on the RD Session Host server for each active session that a user maintains on the RD Session Host server. The temporary folder is created on the RD Session Host server in a Temp folder under the user's profile folder and is named with the sessionid. This temporary folder is used to store individual temporary files. To reclaim disk space, the temporary folder is deleted when the user logs off from a session. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.58.1	Ensure 'Prevent downloading of enclosures' is set to 'Enabled'	This policy setting prevents the user from having enclosures (file attachments) downloaded from an RSS feed to the user's computer. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.59.2	Ensure 'Allow Cloud Search' is set to 'Enabled: Disable Cloud Search'	This policy setting allows search and Cortana to search cloud sources like OneDrive and SharePoint. The recommended state for this setting is: Enabled: Disable Cloud Search.	Enabled: Disable Cloud Search.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.59.3	Ensure 'Allow indexing of encrypted files' is set to 'Disabled'	This policy setting controls whether encrypted items are allowed to be indexed. When this setting is changed, the index is rebuilt completely. Full volume encryption (such as BitLocker Drive Encryption or a non-Microsoft solution) must be used for the location of the index to maintain security for encrypted files. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.59.4	Ensure 'Allow search highlights' is set to 'Disabled'	This policy setting controls search highlights in the start menu search box and in search home. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.76.2.1	Ensure 'Configure Windows Defender SmartScreen' is set to 'Enabled: Warn and prevent bypass'	This policy setting allows you to manage the behavior of Windows SmartScreen. Windows SmartScreen helps keep PCs safer by warning users before running unrecognized programs downloaded from the Internet. Some information is sent to Microsoft about files and programs run on PCs with this feature enabled. The recommended state for this setting is: Enabled: Warn and prevent bypass.	Enabled: Warn and prevent bypass.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.80.1	Ensure 'Allow suggested apps in Windows Ink Workspace' is set to 'Disabled'	This policy setting determines whether suggested apps in Windows Ink Workspace are allowed. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.80.2	Ensure 'Allow Windows Ink Workspace' is set to 'Enabled: On, but disallow access above lock' OR 'Enabled: Disabled'	This policy setting determines whether Windows Ink items are allowed above the lock screen. The recommended state for this setting is: Enabled: On, but disallow access above lock OR Enabled: Disabled.	Enabled: On, but disallow access above lock OR Enabled: Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.81.1	Ensure 'Allow user control over installs' is set to 'Disabled'	This setting controls whether users are permitted to change installation options that typically are available only to system administrators. The security features of Windows Installer normally prevent users from changing installation options that are typically reserved for system administrators, such as specifying the directory to which files are installed. If Windows Installer detects that an installation package has permitted the user to change a protected option, it stops the installation and displays a message. These security features operate only when the installation program is running in a privileged security context in which it has access to directories denied to the user. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.81.3	Ensure 'Prevent Internet Explorer security prompt for Windows Installer scripts' is set to 'Disabled'	This policy setting controls whether Web-based programs are allowed to install software on the computer without notifying the user. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.87.2	Ensure 'Turn on PowerShell Transcription' is set to 'Enabled'	This Policy setting lets you capture the input and output of Windows PowerShell commands into text-based transcripts. The recommended state for this setting is: Enabled.	Enabled.	This control is out of scope because it introduces disk-capacity and availability risks; without a durable protection and retention design, the measurement would not provide reliable assurance.
18.10.89.1.1	Ensure 'Allow Basic authentication' is set to 'Disabled'	This policy setting allows you to manage whether the Windows Remote Management (WinRM) client uses Basic authentication. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.89.1.2	Ensure 'Allow unencrypted traffic' is set to 'Disabled'	This policy setting allows you to manage whether the Windows Remote Management (WinRM) client sends and receives unencrypted messages over the network. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.89.2.2	Ensure 'Allow remote server management through WinRM' is set to 'Disabled'	This policy setting allows you to manage whether the Windows Remote Management (WinRM) service automatically listens on the network for requests on the HTTP transport over the default HTTP port. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.89.2.3	Ensure 'Allow unencrypted traffic' is set to 'Disabled'	This policy setting allows you to manage whether the Windows Remote Management (WinRM) service sends and receives unencrypted messages over the network. The recommended state for this setting is: Disabled.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.89.2.4	Ensure 'Disallow WinRM from storing RunAs credentials' is set to 'Enabled'	This policy setting allows you to manage whether the Windows Remote Management (WinRM) service will allow RunAs credentials to be stored for any plug-ins. The recommended state for this setting is: Enabled. Note: If you enable and then disable this policy setting, any values that were previously configured for RunAsPassword will need to be reset.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.90.1	Ensure 'Allow Remote Shell Access' is set to 'Disabled'	This policy setting allows you to manage configuration of remote access to all supported shells to execute scripts and commands. The recommended state for this setting is: Disabled. Note: The GPME help text for this setting is incorrectly worded, implying that configuring it to Enabled will reject new Remote Shell connections, and setting it to Disabled will allow Remote Shell connections. The opposite is true (and is consistent with the title of the setting). This is a wording mistake by Microsoft in the Administrative Template.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.92.2.1	Ensure 'Prevent users from modifying settings' is set to 'Enabled'	This policy setting prevent users from making changes to the Exploit protection settings area in the Windows Security settings. The recommended state for this setting is: Enabled.	Enabled.	This control is out of scope because the environment uses CrowdStrike as the approved endpoint protection platform, while the setting applies exclusively to Windows Defender. Measuring it would assess a component that is not the deployed security control.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
18.10.93.1.1	Ensure 'No auto-restart with logged on users for scheduled automatic updates installations' is set to 'Disabled'	This policy setting specifies that Automatic Updates will wait for computers to be restarted by the users who are logged on to them to complete a scheduled installation. The recommended state for this setting is: Disabled. Note: This setting applies only when you configure Automatic Updates to perform scheduled update installations. If you configure the Configure Automatic Updates setting to Disabled, this setting has no effect.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.93.2.2	Ensure 'Configure Automatic Updates: Scheduled install day' is set to '0 - Every day'	This policy setting specifies when computers in your environment will receive security updates from Windows Update or WSUS. The recommended state for this setting is: 0 - Every day. Note: This setting is only applicable if 4 - Auto download and schedule the install is selected in recommendation 'Configure Automatic Updates'. It will have no impact if any other option is selected.	0 - Every day.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
18.10.93.4.1	Ensure 'Manage preview builds' is set to 'Disabled'	This policy setting manages which updates that are received prior to the update being released. Dev Channel: Ideal for highly technical users. Insiders in the Dev Channel will receive builds from our active development branch that is earliest in a development cycle. These builds are not matched to a specific Windows 10 release. Beta Channel: Ideal for feature explorers	Disabled.	This control is out of scope because it targets Windows Desktop and the Windows Insider Preview channel, neither of which applies to the Windows Server platform in scope.

		who want to see upcoming Windows 10 features. Your feedback will be especially important here as it will help our engineers ensure key issues are fixed before a major release. Release Preview Channel (default): Insiders in the Release Preview Channel will have access to the upcoming release of Windows 10 prior to it being released to the world. These builds are supported by Microsoft. The Release Preview Channel is where we recommend companies preview and validate upcoming Windows 10 releases before broad deployment within their organization. The recommended state for this setting is: Disabled. Note: Preview Build enrollment requires a telemetry level setting of 2 or higher and your domain registered on insider.windows.com. For additional information on Preview Builds, see: Managing preview builds across your organization - Windows Insider Program | Microsoft Learn.		

CIS #	CIS Control Name	Description	Recommended Value	Rationale
19.5.1.1	Ensure 'Turn off toast notifications on the lock screen' is set to 'Enabled'	This policy setting turns off toast notifications on the lock screen. The recommended state for this setting is Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
19.6.6.1.1	Ensure 'Turn off Help Experience Improvement Program' is set to 'Enabled'	This policy setting specifies whether users can participate in the Help Experience Improvement program. The Help Experience Improvement program collects information about how customers use Windows Help so that Microsoft can improve it. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
19.7.5.2	Ensure 'Notify antivirus programs when opening attachments' is set to 'Enabled'	This policy setting manages the behavior for notifying registered antivirus programs. If multiple programs are registered, they will all be notified. The recommended state for this setting is: Enabled. Note: An updated antivirus program must be installed for this policy setting to function properly.	Enabled.	This control is out of scope because the environment uses CrowdStrike as the approved endpoint protection platform, while the setting applies exclusively to Windows Defender. Measuring it would assess a component that is not the deployed security control.
19.7.8.1	Ensure 'Configure Windows spotlight on lock screen' is set to 'Disabled'	This policy setting lets you configure Windows Spotlight on the lock screen. The recommended state for this setting is: Disabled. Note: Per Microsoft TechNet, this policy setting only applies to Windows 10 Enterprise and Windows 10 Education editions.	Disabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

CIS #	CIS Control Name	Description	Recommended Value	Rationale
19.7.8.2	Ensure 'Do not suggest third-party content in Windows spotlight' is set to 'Enabled'	This policy setting determines whether Windows will suggest apps and content from third-party software publishers. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
19.7.8.3	Ensure 'Do not use diagnostic data for tailored experiences' is set to 'Enabled'	This setting determines if Windows can use diagnostic data to provide tailored experiences to the user. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
19.7.8.4	Ensure 'Turn off all Windows spotlight features' is set to 'Enabled'	This policy setting lets you turn off all Windows Spotlight features at once. The recommended state for this setting is: Enabled. Note: Per Microsoft TechNet, this policy setting only applies to Windows 10 Enterprise and Windows 10 Education editions.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
19.7.8.5	Ensure 'Turn off Spotlight collection on Desktop' is set to 'Enabled'	This policy setting removes the Spotlight collection setting in Personalization, rendering the user unable to select and subsequently download daily images from Microsoft to the system desktop. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.
19.7.46.2.1	Ensure 'Prevent Codec Download' is set to 'Enabled'	This setting controls whether Windows Media Player is allowed to download additional codecs for decoding media files it does not already understand. The recommended state for this setting is: Enabled.	Enabled.	This control is not measured as it falls outside the current risk-based measurement priority scope, which prioritizes only 'URGENT' and 'CRITICAL' controls. This approach focuses assurance efforts on the highest-priority risks, without implying disregard for the control's requirements.

6 RELATED AND SOURCE DOCUMENTS

6.1 Related Documents

Document Type	Entity and Department	Owner	Document Title
Standard	Technology	Santander US Director, Information Security Head of Infrastructure Security	Secure Build and Configuration Management Standard
Procedure	Technology	Santander US Director, Information Security Head of Infrastructure Security	Compliance Configuration Governance Procedure
Process	Technology	Santander US Director, Information Security Head of Infrastructure Security	Infrastructure Security Governance Process

6.2 Source Documents

Source
• CIS Microsoft Windows Server 2025 Benchmark v1.0.0 - 03-19-2025

7 SUBSIDIARY ENDORSEMENT

Approving Body	Governance Committee Approval or Endorsement	Final Approval Date
Santander Bank CISO	Endorsement	9/16/2026
Auto CISO / Designee	Endorsement	9/10/2026
Corporate & Investment Banking (“CIB”) CISO	Endorsement	9/10/2026
Wealth Management & Insurance (“WM&I”) CISO	Endorsement	9/17/2026

8 SANTANDER GROUP ANNEX I: RULES CHECKLIST

The following checklist represents rules that have been implemented in the compliance tool, except controls marked *. Currently, it is not technically feasible that the compliance tool correctly measures these controls due to:

- The parameters can be configured in different configuration files (same ID on the checklist). Complying one of those is required.
- There is a dependency on other controls results.

These controls are included in the guide whilst they are not temporarily measured in the compliance tool (to avoid false 'KOs').

Windows Server

ID	CIS Referece	Policy Name	Recommended Value	Criticality (*)	Versions
2.1 Services					
2.1.14	18.5.1	Status of the 'MSS: (DisableIPSourceRoutingIPv6) IP source routing protection level (protects against packet spoofing)' setting	Highest protection, source routing is completely disabled	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.1.20	18.5.3	Status of the 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.2 Account Lockout Policy					
2.2.1	1.2.1	Status of the 'Account Lockout Duration' setting (invalid login attempts)	15	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticality (*)	Versions
2.2.2	1.2.2	Status of the 'Account Lockout Threshold' setting (invalid login attempts)	5	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.2.3	1.2.4	Status of the 'Reset Account Lockout Counter After' setting	1440 seconds	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.2.4	1.2.3	Status of the 'Allow Administrator account lockout' setting	Enabled	URGENT	Win 2016, 2019, 2022 and 2025
2.3 Password Policy					
2.3.1	1.1.1	Status of the 'Enforce password history' setting	10	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.3.2	1.1.4	Status of the 'Minimum Password Length' setting	8	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.3.3	1.1.7	Status of the 'Store passwords using reversible encryption' setting	Disabled	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.3.4	1.1.2	Status of the 'Maximum Password Age' setting (expiration)	45	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.3.5	1.1.5	Status of the 'Password Complexity Requirements' setting	Enabled	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.3.6	1.1.3	Status of the 'Minimum Password Age' setting	>= 1 day	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.3.7	2.3.7.7	Status of the number of days before a [Prompt user] password expiration	>=7 days	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

		warning prompt is displayed at login			
ID	**CIS Referece**	**Policy Name**	**Recommended Value**	**Criticality (*)**	**Versions**
2.3.15	18.9.33.6.3	Status of the 'Require a Password When a Computer Wakes (on Battery)' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.3.16	18.9.33.6.4	Status of the 'Require a Password When a Computer Wakes (Plugged In)' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.3.17	18.9.39.3	Status of the 'Configure SAM change password RPC methods policy' setting on the host	Enabled: Block all change password RPC methods.	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.3.18	18.10.57.2.2	Status of the 'Do not allow passwords to be saved' setting (Terminal Services)	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4 User Rights Assignment					
2.4.1	2.2.4	Current list of Groups and User Accounts granted the 'Act as part of the operating system' right	No one	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.3	2.2.44	Current list of Groups and User Accounts granted the 'Profile System Performance (SeSystemProfilePrivilege)' right	Administrators, NT\SERVICE\WdiServiceHost	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.4	2.2.36	Current list of Groups and User Accounts granted the 'Lock Pages in Memory' right	No one	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.5	2.2.35	Current list of Groups and User Accounts granted the 'Load and unload device drivers' right	Administrators	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticality (*)	Versions
2.4.6	2.2.14	Current list of Groups and User Accounts granted the 'Create a Pagefile' right	Administrators	Administrators	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.7	2.2.16	Current list of Groups and User Accounts granted the 'Create Global Objects' right	Administrators, SERVICE, LOCAL SERVICE, NETWORK SERVICE	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.8	2.2.6	Current list of Groups and User Accounts granted the 'Adjust memory quotas for a process' right	LOCAL SERVICE, NETWORK SERVICE, Administrators, IIS Users and Microsoft SQL Users	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.9	2.2.12	Current list of Groups and User Accounts granted the 'Change the system time' right	LOCAL SERVICE, Administrators	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.11	2.2.17	Current list of Groups and User Accounts granted the 'Create Permanent Shared Objects' right	No one	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.12	2.2.25	Current list of Groups and User Accounts granted the 'Deny log on locally' right	At least group ‘Guests’	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.14	2.2.31	Current list of Groups and User Accounts granted the 'Generate Security Audits' right	Local Service, Network Service	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.15	2.2.40	Current list of Groups and User Accounts granted the 'Modify an object label (SeRelabelPrivilege)' right	No one	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticality (*)	Versions
2.4.16	2.2.41	Current list of Groups and User Accounts granted the 'Modify firmware environment values (SeSystemEnvironmentPrivilege)' right	Administrators	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.17	2.2.1	Current list of Groups and User accounts granted the 'Access credential Manager as a trusted caller (SeTrustedCredManAccessPrivilege)' right	No one	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.18	2.2.42	Current list of Groups and User Accounts granted the 'Perform Volume Maintenance Tasks (SeManageVolumePrivilege)' right	Administrators	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.19	2.2.45	Current list of Groups and User Accounts granted the 'Replace a process level token (SeAssignPrimaryTokenPrivilege)' right	Local Service, Network Service, IIS Users and Microsoft SQL Users	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.20	2.2.46	Current list of Groups and User Accounts granted the 'Restore files and directories (SeRestorePrivilege)' right	Administrators	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.23	2.2.49	Current list of Groups and User Accounts granted the 'Take ownership of files or other objects (SeTakeOwnershipPrivilege)' right	Administrators	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.24	2.2.20	Current list of Groups and User Accounts granted the 'Debug Programs' right	Administrators	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticality (*)	Versions
2.4.25	2.2.15	Current list of Groups and User Accounts granted the 'Create a Token Object' right	No one	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.27	2.2.8	Current list of Groups and User Accounts granted the 'Allow log on locally (SeInteractiveLogonRight)' right	Administrators, Backup Operators	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.29	2.2.11	Current list of Groups and User Accounts granted the 'Back up files and directories' right	Administrators	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.30	2.2.13	Current list of Groups and User accounts granted the 'Change the time zone privilege (SeTimeZonePrivilege)' setting	Administrators, LOCAL SERVICE	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.31	2.2.30	Current list of Groups and User Accounts granted the 'Force shutdown from a remote system' right	Administrators	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.32	2.2.34	Current list of Groups and User Accounts granted the 'Increase Scheduling Priority' right	Administrators	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.33	2.2.43	Current list of Groups and User Accounts granted the 'Profile Single Process (SeProfileSingleProcessPrivilege)' right	Administrators	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.34	2.3.1.3	Status of the name of the 'Built-in Administrator' account	Rename administrator account	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticality (*)	Versions
2.4.35	2.2.23	Current list of Groups and User Accounts granted the 'Deny logon as a batch job' right	Guest	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.36	2.2.24	Current list of Groups and User Accounts granted the 'Deny logon as a service' right	Guest	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.4.37	2.2.27	Current list of Groups and User Accounts granted the 'Deny logon through terminal (Remote Desktop) service' right	Local Accounts or specific AD Groups	CRITICAL	Win 2016, 2019, 2022 and 2025
2.4.38	2.3.1.4	Status of the name of the 'Built-in Guest' account	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5 Security Options					
2.5.1	2.3.13.1	Status of the 'Shutdown: Allow system to be shut down without having to log on' setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.2	2.2.47	Current list of Groups and User Accounts granted the 'Shut down the system (SeShutdownPrivilege)' right	Administrators	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.3	2.3.10.2	Status of the 'Network access: Do not allow anonymous enumeration of SAM accounts' setting	Enabled	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticality (*)	Versions
2.5.4	2.3.10.3	Status of the 'Network Access: Do not allow Anonymous Enumeration of SAM Accounts and Shares' setting	Do not allow enumeration of Security Accounts Manager accounts and names	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.5	2.3.10.10	Status of the 'Network access: Restrict anonymous access to Named Pipes and Shares' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.6	2.3.10.5	Status of the 'Network Access: Let Everyone permissions apply to anonymous users' setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.8	2.3.10.8	Status of the 'Network Access: Remotely accessible registry paths' setting (Windows 2003 and later)	System\CurrentControlSet\Control\ProductOptions System\CurrentControlSet\Control\Server Applications Software\Microsoft\Windows NT\CurrentVersion	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.9	2.3.10.12	Status of the 'Network Access: Shares that can be accessed anonymously' setting	None	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.10	2.3.10.4	Status of the 'Network access: Do not allow storage of passwords and credentials for network authentication' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticality (*)	Versions
2.5.11	2.3.8.2	Status of the 'Microsoft network client: Digitally Sign Communications (if server agrees)' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.12	2.3.8.3	Status of the 'Microsoft network client: Send Unencrypted Password to Connect to Third-Party SMB Server' setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.15	2.3.2.2	Status of the 'Audit: Shut Down system immediately if unable to log security audits' setting	Disabled	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.16	2.3.2.1	Status of the 'Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.17	2.3.1.2	Status of the 'Accounts: Limit local account use of blank passwords to console logon only' setting	Enabled	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.18	2.3.1.1	Status of the local 'Guest' account (enabled/disabled)	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.19	2.3.7.1	Status of the 'Interactive Logon: Do not require CTRL+ALT+DEL' setting	Disabled	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.20	2.3.7.6	Status of the 'Interactive Logon: Number of Previous Logons to Cache (in case domain controller is not available)' setting	4 or fewer	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticality (*)	Versions
2.5.21	2.3.7.2	Status of the 'Interactive Logon: Do Not Display Last User Name' setting	Enabled	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.22	2.3.7.9	Status of the 'Interactive Logon: Smart Card Removal Behavior' setting	Lock Workstation	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.23	2.3.11.5	Status of the 'Network Security: Do not store LAN Manager password hash value on next password change' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.24	2.3.11.7	Status of the 'Network Security: LAN Manager Authentication Level' setting	Send NTLMv2 response only. Refuse LM & NTLM.	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.25	2.3.11.2	Status of the 'Network security: Allow LocalSystem NULL session fallback' setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.26	2.3.11.3	Status of the 'Network security: Allow PKU2U authentication requests to this computer to use online identities' setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.27	2.3.11.10	Status of the 'Network Security: Minimum session security for NTLM SSP based (including secure RPC) clients' setting	“Require NTLMv2 session security” and “Require 128-bit encryption” will be marked	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticality (*)	Versions
2.5.28	2.3.11.11	Status of the 'Network Security: Minimum session security for NTLM SSP based (including secure RPC) servers' setting	“Require NTLMv2 session security” and “Require 128-bit encryption” will be marked	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.29	2.3.11.1	Status of the 'Network security: Allow Local System to use computer identity for NTLM' setting	Enabled	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.30	2.3.9.4	Status of the 'Microsoft Network Server: Disconnect clients when logon hours expire' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.31	2.3.9.3	Status of the 'Microsoft network server: Digitally Sign Communications (if Client agrees) setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.32	2.3.9.1	Status of the 'Microsoft network server: Amount of Idle Time Required Before Suspending Session' setting	15 minutes or less	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.33	2.3.6.2	Status of the 'Domain member: Digitally encrypt secure channel data (when possible)' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.34	2.3.6.3	Status of the 'Domain member: Digitally sign secure channel data (when possible)' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.35	2.3.6.4	Status of the 'Domain member: Disable machine account password changes' setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticality (*)	Versions
2.5.36	2.3.6.5	Status of the 'Domain member: Maximum machine account password age' setting	Less than or equal to 45 days	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.38	2.3.4.2	Status of the 'Prevent users from installing printer drivers' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.41	2.3.15.2	Status of the 'System objects: Strengthen default permissions of internal system objects' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.44	18.4.3	Status of the 'SMB v1' protocol for LanManServer services on Windows SC	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.45	2.3.11.4	Configure 'Network Security: Configure encryption types allowed for Kerberos'	AES_128_HMAC_SHA1, AES_256_HMAC_SHA1, Future Encryption Types.	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.46	2.3.6.1	Status of the 'Domain member: Digitally encrypt or sign secure channel data (always)' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.47	2.3.6.6	Status of the 'Domain member: Require strong (Windows 2000 or later) session key' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.49	2.3.8.1	Status of the 'Microsoft network client: Digitally sign communications (always)' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.50	2.3.9.2	Status of the 'Microsoft network server: Digitally sign communication (always)' setting (SMB)	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticality (*)	Versions
2.5.51	2.3.10.1	Status of the 'TurnOffAnonymousBlock' setting on the host	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.52	2.3.10.11	Network access: Restrict clients allowed to make remote calls to SAM	Administrators: Remote Access: Allow	CRITICAL	Win 2016, 2019, 2022 and 2025
2.5.53	2.3.10.13	Status of the 'Network Access: Sharing and security model for local accounts' setting	Ensure it is set to Classic – local users authenticate as themselves	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.54	2.3.11.8	Status of the 'Network security: LDAP client encryption requirements' setting on the host	Negotiate sealing or Require sealing	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.55	2.3.11.9	Status of the 'Network Security: LDAP client signing requirements' setting	Negotiate singning or Require signing	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.56	2.3.15.1	Status of the 'System objects: Require case insensitivity for non-Windows subsystems' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.5.65	18.4.2	Status of the 'SMB 1.x MiniRedirector (mrxsmb10)' Windows service (LanmanWorkstation depend on service 'mrxsmb10')	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.7 Windows Components - WDigest Authentication					
2.7.1	18.4.7	Status of the 'WDigest Authentication' setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticality (*)	Versions
2.7.2	18.10.57.3.10.2	Status of the 'Set Time Limit for Disconnected Sessions' Group Policy setting (Terminal Services)	15 minutes	MEDIUM	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.8 Audit Policies - Account Logon					
2.8.1	17.1.1	Status of the audit setting 'Credential Validation' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.8.4	17.5.2	Status of the audit setting 'Audit Group Membership' (advanced audit setting)	Success (1)	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.9 Audit Policies - Account Management					
2.9.3	17.2.5	Status of the audit setting 'Security Group Management' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.9.4	17.2.6	Status of the audit setting 'Account Management: User Account Management' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.9.5	17.2.1	Status of the audit setting 'Application Group Management' (advanced audit setting)	Success and Failure	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.10 Audit Policies - Detailed Tracking					
2.10.1	17.3.2	Status of the audit setting 'Process Creation' (advanced audit setting)	Success (1)	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.10.2	18.9.3.1	Status of the 'Include command line in process creation events' setting	Enabled	MEDIUM	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.11 Audit Policies - Logon-Logoff					

ID	CIS Referece	Policy Name	Recommended Value	Criticality (*)	Versions
2.11.1	17.5.1	Status of the audit setting 'Account Lockout' (advanced audit setting)	Failure (2)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.11.2	17.5.3	Status of the audit setting 'Logoff' (advanced audit setting)	Success (1)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.11.3	17.5.4	Status of the audit setting 'Logon' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.11.4	17.5.6	Status of the audit setting 'Special Logon' (advanced audit setting)	Success (1)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.12 Audit Policies - Policy Change					
2.12.1	17.7.1	Status of the audit setting 'Audit Policy Change' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.12.2	17.7.2	Status of the audit setting 'Authentication Policy Change' (advanced audit setting)	Success (1)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.12.3	17.7.3	Status of the audit setting 'Authorization Policy Change' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.13 Audit Policies - Privilege Use					
2.13.1	17.8.1	Status of the audit setting 'Sensitive Privilege Use' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.14 Audit Policies - System					
2.14.1	17.9.1	Status of the audit setting 'IPsec Driver' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticality (*)	Versions
2.14.2	17.9.2	Status of the audit setting 'Other System Events' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.14.3	17.9.3	Status of the audit setting 'Security State Change' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.14.4	17.9.4	Status of the audit setting 'Security System Extension' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.14.5	17.9.5	Status of the audit setting 'System Integrity' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.14.7	17.6.2	Status of the audit setting 'File Share' (advanced audit setting)	Success and Failure	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.17 Object Access					
2.17.1	17.6.3	Status of the audit setting 'Other Object Access Events' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19 Administrative Templates (Computer)					
2.19.1	18.7.8	Status of the 'Configure RPC packet level privacy setting for incoming connections' setting	Enabled	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.2	18.7.1	Status of the 'Allow Print Spooler to accept client connections' group policy setting	Disabled	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.8	18.10.93.2.1	Status of Windows 'Automatic Updates' (WSUS) setting (NoAutoUpdate)	Enabled	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticali (*)	Versions
2.19.10	18.4.5	Status of Structured Exception Handling Overwrite Protection (SEHOP) feature in Windows	Enabled	CRITIC AL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.11	18.6.4.1	Status of the 'Configure multicast DNS (mDNS) protocol' setting on the host	Disabled	CRITIC AL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.12	18.6.4.2	Windows - Status of NetBIOS name resolution	Disabled	CRITIC AL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.13	18.6.4.3	Status of the 'Turn off default IPv6 DNS Servers' setting on the host	Enabled	CRITIC AL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.14	18.6.7.3	Status of the 'Network\Lanman Server: Audit insecure guest logon' setting on the host	Enabled	URGEN T	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.15	18.6.11.4	Status of the 'Require domain users to elevate when setting a network's location' setting	Enabled	CRITIC AL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.16	18.6.14.1	Status of the 'Hardened UNC Paths' setting for Sysvol	Enabled with Require Mutual Authentication, Require Integrity and Require Privacy	CRITIC AL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.17	18.6.14.1	Status of the 'Hardened UNC Paths' setting for Netlogon	Enabled with Require Mutual Authentication, Require Integrity and Require Privacy	CRITIC AL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.18	18.6.20.1	Status of the 'Configuration of wireless settings using Windows Connect Now' group policy setting	Disabled	CRITIC AL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticali (*)	Versions
2.19.19	18.7.2	Status of the 'Configure Redirection Guard' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.20	18.7.3	Status of the 'Configure RPC connection settings: Protocol to use for outgoing RPC connections' setting	Enabled: RPC over TCP	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.21	18.7.4	Status of the 'Use authentication for outgoing RPC over named pipes connections' setting	Enabled: Default	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.22	18.7.5	Status of the 'Protocols to allow for incoming RPC connections' setting	Enabled: RPC over TCP	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.23	18.7.6	Status of the 'Authentication protocol to use for incoming RPC connections' setting	Enabled: Negotiate or higher	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.24	18.7.7	Status of the 'Configure RPC over TCP port' setting	Enabled: 0	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.25	18.7.11	Status of the 'Manage processing of Queue-specific files' setting	Enabled: Limit Queue-specific files to Color profiles	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.27	18.9.20.1.1	Status of the 'Turn off downloading of print drivers over HTTP' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.28	18.9.20.1.5	Status of the 'Turn off Internet download for Web publishing and online ordering wizards' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticali (*)	Versions
2.19.29	18.9.20.1.6	Status of the 'Turn off printing over HTTP' service	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.30	18.9.20.1.10	Status of the 'Turn off the 'Publish to Web' task for files and folders' group policy	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.33	18.9.26.1	Status of the 'Allow Custom SSPs and APs to be loaded into LSASS' setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.34	18.9.30.1.1	Status of the 'Block NetBIOS-based discovery for domain controller location' setting on the host	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.35	18.9.35.1	Status of the 'Offer Remote Assistance' setting (Terminal Services)	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.36	18.10.4.2	Status of the 'Not allow per-user unsigned packages to install by default' setting on the host	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.37	18.10.6.1	Status of the 'Allow Microsoft accounts to be optional' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.38	18.10.8.1	Status of the 'Disallow Autoplay for non-volume devices' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.39	18.10.8.2	Status of the 'default behavior for AutoRun'	Enabled: Do not execute any autorun commands	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticali (*)	Versions
2.19.41	18.10.13.3	Status of the 'Turn off Microsoft consumer experiences' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.42	18.10.15.2	Status of 'Enumerate administrator accounts on elevation' setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.43	18.10.16.2	Status of the 'Configure Authenticated Proxy usage for the Connected User Experience and Telemetry service' (DisableEnterpriseAuthProxy) Group Policy setting	Enabled: Disable Authenticated Proxy usage	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.44	18.10.18.4	Status of the 'Enable App Installer Local Archive Malware Scan Override' setting on the host	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.45	18.10.18.6	Status of the 'Enable App Installer Microsoft Store Source Certificate Validation Bypass' setting on the host	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.46	18.10.26.1.1	Status of the 'Application: Control Event Log behavior when the log file reaches its maximum size' setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.47	18.10.26.1.2	Status of the 'Application: Maximum log size' setting (in KB)	Enabled: 32,768 or greater	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.48	18.10.26.2.1	Status of the 'Security: Control Event Log behavior when the log file reaches its maximum size' setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.49	18.10.26.2.2	Status of the 'Security: Maximum log size' setting (in KB)	Enabled: 196,608 or greater	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticali (*)	Versions
2.19.50	18.10.26.3.2	Status of the 'Setup: Maximum Log Size (KB)' setting	Enabled: 32,768 or greater	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.51	18.10.26.4.1	Status of the 'System: Control Event Log behavior when the log file reaches its maximum size' Group Policy setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.52	18.10.26.4.2	Status of the 'System: Maximum log size' setting (in KB)	Enabled: 32,768 or greater	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.53	18.10.29.3	Status of the 'Turn off Data Execution Prevention for Explorer' setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.54	18.10.42.1	Status of the 'Block all consumer Microsoft account user authentication' (DisableUserAuth) Group Policy setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.74	18.10.57.3.3.4	Status of the 'Do not allow location redirection' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.75	18.10.58.2	Status of the 'Turn on Basic feed authentication over HTTP' Windows group policy setting for RSS Feeds (Internet Explorer)	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.76	18.10.63.1	Status of the 'Turn off KMS Client Online AVS Validation' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.77	18.10.81.2	Status of the 'Windows Installer: Set Always install with elevated privileges' setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticali (*)	Versions
2.19.78	18.10.82.1	Status of the 'Enable MPR notifications for the system' setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.79	18.10.82.2	Status of the 'Sign-in last interactive user automatically after a system-initiated restart' setting	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.80	18.10.87.1	Status of the 'Turn on PowerShell Script Block Logging' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.82	18.10.89.1.3	Status of the 'Disallow Digest authentication' setting (WinRM client)	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.83	18.10.89.2.1	Status of the 'Allow Basic authentication' setting (WinRM service)	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.86	18.10.93.4.2	Status of the 'Select when Feature Updates are received - DeferFeatureUpdatesPeriodInDays' setting	Enabled: 180 or more days	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.19.87	18.10.93.4.3	Status of the 'Select when Quality Updates are received' on the host	Enabled:0 days	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.20 Member Server configuration					
2.20.1	2.2.39	Current list of Groups and User Accounts granted the 'Manage Auditing and Security Log (SeSecurityPrivilege)' right	Administrators	URGENT	Win 2016, 2019, 2022 and 2025
2.20.2	2.2.19	Status of the 'Create Symbolic Links' (SeCreateSymbolicLinkPrivilege) right	Administrators, NT VIRTUAL MACHINE\Virtual Machines	CRITICAL	Win 2016, 2019, 2022 and 2025

ID	CIS Referece	Policy Name	Recommended Value	Criticali (*)	Versions
2.20.3	2.2.22	Current list of Groups and User Accounts granted the 'Deny Access to this computer from the network' right	Guests, Local account and member of Administrators group	CRITICAL	Win 2016, 2019, 2022 and 2025
2.20.4	2.2.33	Current list of Groups and User Accounts granted the 'Impersonate a client after authentication' right	Administrators, SERVICE, Local Service, Network Service, IIS Users and Microsoft SQL Users	CRITICAL	Win 2016, 2019, 2022 and 2025
2.20.5	2.2.3	Current list of Groups and User Accounts granted the 'Access this computer from the network' right	Administrators, Authenticated users	URGENT	Win 2016, 2019, 2022 and 2025
2.20.6	2.2.29	Current list of Groups and User Accounts granted the 'Enable computer and user accounts to be trusted for delegation' right	No one	URGENT	Win 2016, 2019, 2022 and 2025
2.20.7	2.2.10	Current list of Groups and User Accounts granted the 'Allow logon through Terminal Services' right	Administrators, Remote Desktop Users	URGENT	Win 2016, 2019, 2022 and 2025
2.21 Domain Controller configuration					
2.21.1	2.2.38	Current list of Groups and User Accounts granted the 'Manage Auditing and Security Log (SeSecurityPrivilege)' right	Administrators, Exchange Servers	URGENT	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
2.21.2	2.2.18	Status of the 'Create Symbolic Links' (SeCreateSymbolicLinkPrivilege) right	Administrators	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
2.21.3	2.2.21	Current list of Groups and User Accounts granted the 'Deny Access to this computer from the network' right	At least group ‘Guests’	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD

ID	CIS Referece	Policy Name	Recommended Value	Criticali (*)	Versions
2.21.4	2.2.32	Current list of Groups and User Accounts granted the 'Impersonate a client after authentication' right	Administrators, SERVICE, Local Service, Network Service	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
2.21.5	2.2.2	Current list of Groups and User Accounts granted the 'Access this computer from the network' right	Administrators, ENTERPRISE DOMAIN CONTROLLERS, Authenticated users	URGENT	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
2.21.6	2.2.28	Current list of Groups and User Accounts granted the 'Enable computer and user accounts to be trusted for delegation' right	No one, Administrators	URGENT	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
2.21.7	2.2.9	Current list of Groups and User Accounts granted the 'Allow logon through Terminal Services' right	Administrators	URGENT	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
2.22 Administrative Templates (User)					
2.22.1	19.7.5.1	Status of the "Do not preserve zone information in file attachments" setting for Windows users	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.22.3	19.7.26.1	Status of the 'Prevent users from sharing files within their profile' setting	Enabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD
2.22.4	19.7.44.1	Status of the 'Always install with elevated privileges' setting for Windows User	Disabled	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022, 2022 AD, 2025 and 2025 AD

(*) Five criticality levels have been defined: minimal, medium, serious, critical, and urgent, from lower to higher level of criticality.

External Regulatory Requirements

ID	Policy Name	Recommended Value	Criticality (*)	Versions
2.1.1	Telnet Server service status	Ensure Telnet Server service is not running	URGENT	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD
2.1.2	Status of the 'Microsoft FTP (Publishing) Service'	Disabled	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD
2.1.15	Status of the PowerShell version	At least PowerShell 5.1	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD
2.1.17	TFTP Protocol	Ensure TFTP port is not listening	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD
2.1.18	SMTP Protocol	Ensure SMTP port is not listening	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD
2.1.19	Delete credentials after logging off registry	Less or Equal than 30 seconds	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD
2.6.6	Status of the 'Prevent local guests group from accessing system log' setting	Yes	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD
2.10.3	Status of the audit setting 'Process Termination' (advanced audit setting)	Success (1)	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD
2.15.1	Crowd Strike Service Status	"CSFalconService" running	CRITICAL	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD
2.18.1*	Status of the 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run' registry key	Audit Creation and Update	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD

ID	Policy Name	Recommended Value	Criticality (*)	Versions
2.18.2*	Status of the 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\RunOnce' registry key	Audit Creation and Update	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD
2.18.3*	Status of the 'HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Session Manager' registry key	Audit Creation and Update	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD
2.18.4*	Status of the 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\Shell' registry key	Audit All	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD
2.18.5*	Status of the 'HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon' registry key	Audit All	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD
2.18.6*	Status of the 'HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\Userinit' registry key	Audit All	SERIOUS	Win 2016, 2016 AD, 2019, 2019 AD, 2022 and 2022 AD

(*) Five criticality levels have been defined: minimal, medium, serious, critical, and urgent, from lower to higher level of criticality.

SOX Policy

ID	Policy Name	Recommended Value	Criticality (*)
2.1.1	Telnet Server service status	Ensure Telnet Server service is not running	URGENT
2.1.2	Status of the 'Microsoft FTP (Publishing) Service'	Disabled	SERIOUS
2.1.17	TFTP Protocol	Disabled	SERIOUS
2.1.18	SMTP Protocol	Disabled	SERIOUS
2.1.19	Delete credentials after logging off	Less or Equal than 30 seconds	SERIOUS
2.2.1	Status of the 'Account Lockout Duration' setting (invalid login attempts)	15	URGENT
2.2.2	Status of the 'Account Lockout Threshold' setting (invalid login attempts)	5	URGENT
2.2.3	Status of the 'Reset Account Lockout Counter After' setting	1440 seconds	URGENT
2.3.1	Status of the 'Enforce password history' setting	10	URGENT
2.3.2	Status of the 'Minimum Password Length' setting	8	CRITICAL
2.3.3	Status of the 'Store passwords using reversible encryption' setting	Disabled	URGENT
2.3.4	Status of the 'Maximum Password Age' setting (expiration)	45	URGENT
2.3.5	Status of the 'Password Complexity Requirements' setting	Enabled	URGENT
2.3.6	Status of the 'Minimum Password Age' setting	>= 1 day	URGENT
2.5.17	Status of the 'Accounts: Limit local account use of blank passwords to console logon only' setting	Enabled	URGENT
2.5.18	Status of the local 'Guest' account (enabled/disabled)	Disabled	CRITICAL

ID	Policy Name	Recommended Value	Criticality (*)
2.5.21	Status of the 'Interactive Logon: Do Not Display Last User Name' setting	Enabled	SERIOUS
2.5.23	Status of the 'Network Security: Do not store LAN Manager password hash value on next password change' setting	Enabled	CRITICAL
2.5.36	Status of the 'Domain member: Maximum machine account password age' setting	Less than or equal to 45 days	CRITICAL
2.6.6	Status of the 'Prevent local guests group from accessing system log' setting	Yes	CRITICAL
2.7.1	Status of the 'WDigest Authentication' setting	Disabled	CRITICAL
2.7.2	Status of the 'Set Time Limit for Disconnected Sessions' Group Policy setting (Terminal Services)	15 minutes	MEDIUM

(*) Five criticality levels have been defined: minimal, medium, serious, critical, and urgent, from lower to higher level of criticality.

Active Directory

ID	CIS Reference	Policy Name	Recommended Value	Criticality (*)	Versions
3.1 Active Directory Audit Policies					
3.1.1	17.1.2	Status of the audit setting 'Kerberos Authentication Service' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.1.2	17.1.3	Status of the audit setting 'Kerberos Service Ticket Operations' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.1.3	17.5.5	Status of the audit setting 'Other Logon/Logoff Events' (advanced audit setting)	Success and Failure (3)	SERIOUS	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.1.4	17.2.3	Status of the audit setting 'Distribution Group Management' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.1.5	17.4.1	Status of the audit setting 'Directory Service Access' (advanced audit setting)	Failure (2)	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.1.6	17.2.2	Status of the audit setting 'Computer Account Management' (advanced audit setting)	Success	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.1.7	17.2.4	Status of the audit setting 'Other Account Management Events' (advanced audit setting)	Success	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.2 Active Directory Specific requirements					
3.2.11	18.1.1.1	Status of the 'Lock screen camera' setting	Enabled	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD

ID	CIS Reference	Policy Name	Recommended Value	Criticality (*)	Versions
3.2.12	18.1.1.2	Status of the 'Lock screen slide show' setting	Enabled	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.2.13	18.6.8.5	Status of the 'Enable insecure guest logons' setting	Disabled	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.2.14	18.9.19.2	Status of the 'Registry policy processing (Option: Do not apply during periodic background processing)' setting	Disabled	SERIOUS	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.2.15	18.9.19.4	Status of the 'Configure security policy processing: Do not apply during periodic background processing' setting	Disabled	SERIOUS	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.2.16	18.9.20.1.3	Status of 'Process even if the Group Policy objects have not changed' setting in Configure Registry preference extension policy processing GPO	Enabled	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.2.17	18.9.28.2	Status of the 'Do not display network selection UI' setting	Enabled	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.2.19	18.10.16.4	Status of the 'Do not show feedback notifications' setting	Enabled	MEDIUM	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.2.21	17.4.2	Status of the audit setting 'Directory Service Changes' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.2.31	2.3.5.3	Status of the 'Domain controller: LDAP server channel binding token requirements' setting	Always (2)	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD

ID	CIS Reference	Policy Name	Recommended Value	Criticality (*)	Versions
3.2.32	2.2.5	Current list of Groups and User Accounts granted the 'Add workstations to domain' right	Administrators	URGENT	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.2.33	2.2.7	Current list of Groups and User Accounts granted the 'Log on as a batch job (SeBatchLogonRight)' right	Administrators	URGENT	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.2.34	2.2.48	Current list of Groups and User Accounts granted the 'Synchronize directory service data (SeSyncAgentPrivilege)' right	No One	URGENT	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.2.35	2.3.5.2	Status of the 'Domain controller: Allow vulnerable Netlogon secure channel connections (Security descriptor)' Group policy setting	Not Configured	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.2.36	2.3.5.4	Status of the 'Domain Controller: LDAP Server Signing Requirements' setting	Require signing	CRITICAL	Win 2016 AD, 2019 AD and 2022 AD
3.2.37	2.3.5.5	Status of the 'Domain controller: LDAP server signing requirements Enforcement' setting on the host	Enabled	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.2.38	2.3.5.6	Status of the 'Domain Controller: Refuse machine account password changes' setting	Disabled	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD
3.2.39	18.9.39.1	Status of the 'Configure validation of ROCA-vulnerable WHfB keys during	Enabled: Audit or Enabled: Block	CRITICAL	Win 2016 AD, 2019 AD, 2022 AD and 2025 AD

		authentication' setting			

(*) Five criticality levels have been defined: minimal, medium, serious, critical and urgent, from lower to higher level of criticality.

External Regulatory Requirements

ID	Policy Name	Recommended Value	Criticality (*)	Versions
External Regulatory Requirements				
3.3.1	Configure 'Network Security:Restrict NTLM: Outgoing NTLM traffic to remote servers'	Audit all	SERIOUS	Win 2016 AD, 2019 AD and 2022 AD
3.3.2	Status of the 'Network Security:Restrict NTLM: Audit Incoming NTLM Authentication in this domain' setting	Enable all	SERIOUS	Win 2016 AD, 2019 AD and 2022 AD
3.3.3	Status 'Network Security:Restrict NTLM: Audit Incoming NTLM Traffic' setting	Enable auditing for all accounts	SERIOUS	Win 2016 AD, 2019 AD and 2022 AD
3.4.1	Azure Advanced Threat Protection Sensor Service	Ensure ATP sensor is enabled	URGENT	Win 2016 AD, 2019 AD and 2022 AD
3.4.2	Azure AD Password Protection Service Status	Enforce PWD security	SERIOUS	Win 2016 AD, 2019 AD and 2022 AD

(*) Five criticality levels have been defined: minimal, medium, serious, critical, and urgent, from lower to higher level of criticality.

ADFS

ID	Policy Name	Recommended Value	Criticality (*)	Versions	Type (**)
4.1 ADFS Initial System Configuration					
4.1.1	Status of Application Identity Service	AppIDSvc disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.2	Status of the 'Application Experience Lookup' service	AeLookupSvc disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.3	Status of the 'Application Layer Gateway (ALG)' service	ALG disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.4	Status of the 'Application Management' service	AppMgmt disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.5	Status of the 'Startup type' of 'AppX Deployment Service' (AppXSVC)	AppXSvc disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.6	Status of the 'Windows Audio Endpoint Builder' service	AudioEndpointBuilder disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.7	Status of the 'Windows Audio' service	Audiosrv disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.8	Status of the 'Distributed Link Tracking Client' service	TrkWks disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.9	Status of the 'Windows Extensible Authentication Protocol' (EAP) service	Eaphost disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.10	Status of Windows Function Discovery Provider Host Service	fdPHost disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.11	Status of the 'Windows Function Discovery Resource Publication' service	FDResPub disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.12	Status of the 'Windows Health Key and Certificate Management' service	hkmsvc disabled	CRITICAL	Win 2016, 2019 and 2022	ADFS
4.1.13	Status of the 'Hyper-V Data Exchange' Service	vmickvpexchange disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS

ID	Policy Name	Recommended Value	Criticality (*)	Versions	Type (**)
4.1.14	Status of the 'Hyper-V Guest Service Interface' service	vmicguestinterface disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.15	Status of the 'Hyper-V Guest Shutdown' Service	vmicshutdown disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.16	Status of the 'Hyper-V Heartbeat' Service	vmicheartbeat disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.17	Status of the 'Hyper-V Remote Desktop Virtualization' Service	vmicrdv disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.18	Status of the 'Hyper-V Time Synchronization' service	vmictimesync disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.19	Status of the 'Hyper-V Volume Shadow Copy Requestor' Service	vmicvss disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.20	Status of the 'KDC Proxy Server' Service	KPSSVC disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.21	Status of the 'Windows Link-Layer Topology Discovery Mapper' service	lltdsvc disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.22	Status of the 'Microsoft iSCSI Software Target' Service	MSiSCSI disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.25	Status of the 'Portable Device Enumerator' service	WPDBusEnum disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.26	Status of the 'Print Spooler' service	Spooler disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.27	Status of the 'Printer Extensions and Notifications' service	PrintNotify disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.28	Status of the 'Problem Reports and Solutions Control Panel Support' service	wercplsupport disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.29	Status of the 'Remote Access Auto Connection Manager' service	RasAuto disabled	CRITICAL	Win 2016, 2019 and 2022	ADFS

ID	Policy Name	Recommended Value	Criticality (*)	Versions	Type (**)
4.1.30	Status of the 'Remote Access Connection Manager (RasMan)' service	RasMan disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.32	Status of the 'Resultant Set of Policy Provider' group policy setting	RSoPProv disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.33	Status of the 'Secure Socket Tunneling Protocol' service	SstpSvc disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.34	Status of the 'Simple Network Management Protocol (SNMP) trap' service	SNMPTRAP disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.35	Status of the 'Special Administration Console Helper' service	sacsvr disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.36	Status of the 'Superfetch' service	SysMain disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.37	Status of the 'Telephony' service	tapisrv disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.38	Status of the 'Themes' service	Themes disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.39	Status of the 'Windows Error Reporting' service	WerSvc disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.40	Status of the 'Windows Event Collector' service	Wecsvc disabled	CRITICAL	Win 2016, 2019 and 2022	ADFS
4.1.41	Status of the 'Windows Remote Management Service'	WinRM Automatic	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.42	Status of the 'Wired AutoConfig' service	dot3svc disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.44	Status of the Windows IKE and AuthIP IPsec Keying Modules service	IKEEXT manual	CRITICAL	Win 2016, 2019 and 2022	ADFS
4.1.45	Status of the 'Windows Net.Tcp Port Sharing' service	NetTcpPortSharing disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS

ID	Policy Name	Recommended Value	Criticality (*)	Versions	Type (**)
4.1.46	Status of the 'Smart Card' service	SCardSvr disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.47	Status of the 'Auto Time Zone Updater' service	tzautoupdate disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.49	Status of the 'Windows Offline Files' service	cscService disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.50	Status of the ‘User Experience Virtualization’ Service	UevAgentService disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.51	Status of the 'Windows Search' service	Wsearch disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.52	Status of the 'Specify use of ActiveX Installer Service for installation of ActiveX controls' setting (Internet Explorer) (HKU)	AxInstSV disabled	SERIOUS	Win 2019 and 2022	ADFS
4.1.53	Status of 'Bluetooth Support' Windows service startup type	bthserv disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.54	Status of the 'Contact Data (PimIndexMaintenanceSvc)' service	PimIndexMaintenanceSvc disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.55	Status of the 'Downloaded Maps Manager' (MapsBroker) Windows Service 'Startup type'	MapsBroke disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.56	Status of the 'Geolocation Service' (lfsvc) Windows Service 'Startup type'	lfsvc disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.57	Status of the 'Microsoft Account Sign-in Assistant' service	wlidsvc disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.58	Status of the 'Microsoft Passport' service	NgcSvc disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.59	Status of the 'Microsoft Passport Container' service	NgcCtnrSvc disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS

ID	Policy Name	Recommended Value	Criticality (*)	Versions	Type (**)
4.1.60	Status of the 'Phone Service'	PhoneSvc disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.61	Status of the 'Quality Windows Audio Video Experience' service	QWAVE disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.62	Status of the 'Radio Management Service'	RmSvc disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.63	Status of the 'Sensor Data' Service	SensorDataService disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.64*	Sensor Monitoring Service	SensrSvc disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.65	Status of the 'Sensor' service	SensorService disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.66	Status of 'Smart Card Device Enumeration' Service	ScDeviceEnum disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.67	Status of the 'Startup type' of 'Still Image Acquisition Events' service	WiaRpc disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.68	Permissions set for the 'Universal Plug and Play (UPnP) Device Host' service	upnphost disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.69	Status of the 'Startup type' of 'WalletService' service	WalletService disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.70	Status of the 'Windows Camera Frame Server' service	frameServer disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.71	Status of the 'Windows Image Acquisition (WIA)' service	stisvc disabled	MEDIUM	Win 2016, 2019 and 2022	ADFS
4.1.72	Status of Windows Insider Service	wisvc disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.1.73	Status of the 'Windows Mobile Hotspot Service' (icssvc) Windows Service 'Startup type'	icssvc disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS

4.1.74	Status of the audit setting 'Application Generated' (advanced audit setting)	Success and Failure (3)	CRITICAL	Win 2016, 2019 and 2022	ADFS

4.2 ADFS Local Policies

ID	Policy Name	Recommended Value	Criticality (*)	Versions	Type (**)
4.2.1	Current list of Groups and User Accounts granted the 'Generate Security Audits' right	Local service, Network service, NT SERVICE\adfssrv, NT SERVICE\drs, dominio\servicioADFS	URGENT	Win 2016, 2019 and 2022	ADFS
4.2.2	Status of the 'ExtendedProtectionTokenCheck' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	ExtendedProtectionTokenCheck Allow	URGENT	Win 2016, 2019 and 2022	ADFS
4.2.3	Status of the 'PreventTokenReplays' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	PreventTokenReplays True	CRITICAL	Win 2016, 2019 and 2022	ADFS
4.2.4	Status of the 'ProxyTrustTokenLifetime' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	PreventTokenReplays 22000 minutes	CRITICAL	Win 2016, 2019 and 2022	ADFS
4.2.5	Status of the 'ReplayCacheExpirationInterval' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	ReplayCacheExpirationInterval 60 minutes	CRITICAL	Win 2016, 2019 and 2022	ADFS
4.2.6	Status of the 'PersistentSsoEnabled' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	EnablePersistentSso True	CRITICAL	Win 2016, 2019 and 2022	ADFS
4.2.7	Status of the 'SamlMessageDeliveryWindow' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	SamlMessageDeliveryWindow 60 minutes	CRITICAL	Win 2016, 2019 and 2022	ADFS
4.2.8	Status of the 'KmsiEnabled' setting for Active Directory	EnableKmsi False	CRITICAL	Win 2016, 2019 and 2022	ADFS

	Federation Services (ADFS) (Qualys Agent only)				
ID	**Policy Name**	**Recommended Value**	**Criticality (*)**	**Versions**	**Type (**)**
4.2.9	Status of the 'PersistentSsoLifetimeMins' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	PersistentSsoLifetimeMins 1440 minutes	CRITICAL	Win 2016, 2019 and 2022	ADFS
4.2.10	Status of the 'LogLevel' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	LogLevel FailureAudits	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.2.11	Status of the 'MSS: (NtfsDisable8dot3NameCreation) Enable the computer to stop generating 8.3- style filenames' setting	Disabled on all volumes (1)	SERIOUS	Win 2016, 2019 and 2022	WAP
4.3 Protection against brute force attacks and user account lockout					
4.3.1	Status of the lockout algorithm for extranet	EnableExtranetLockout Enabled	CRITICAL	Win 2016, 2019 and 2022	ADFS
4.3.2	Maximum number of bad password attempts	EnableLockoutThresold <=4	CRITICAL	Win 2016, 2019 and 2022	ADFS
4.3.3	Timespan of the lockout observation window	ExtranetObservation Window >=30	CRITICAL	Win 2016, 2019 and 2022	ADFS
4.4 ADFS Certificates installation and specifications					
4.4.1	Status of the 'CertificateDuration' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	CertificateDuration 397 days	CRITICAL	Win 2016, 2019 and 2022	ADFS
4.4.2*	Self-signed certificate length	>=3072 bits	CRITICAL	Win 2016, 2019 and 2022	ADFS and WAP
4.5 EndPoint of ADFS					
4.5.1	Status of endpoint of ADFS	disabled	SERIOUS	Win 2016, 2019 and 2022	ADFS
4.6 ADFS Ciphers					

ID	Policy Name	Recommended Value	Criticality (*)	Versions	Type (**)
4.6.2*	Status of the 'ResponseHeadersEnabled' setting for Active Directory Federation Services (ADFS) (Qualys Agent only)	AdfsResponseHeaders disabled	CRITICAL	Win 2016, 2019 and 2022	WAP
4.6.3	Allowed ciphers	TLSv1.3: TLS_AES_256_GCM_SHA384, TLS_AES_128_GCM_SHA256 TLSv1.2: TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384,TLS_DHE_RSA_WITH_AES_256_GCM_SHA384,TLS_DHE_RSA_WITH_AES_256_CCM,TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256, TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256,TLS_DHE_RSA_WITH_AES_128_GCM_SHA256.	CRITICAL	Win 2016, 2019 and 2022	WAP
4.6.4	Status of TLS 1.0 protocols setting	Server/Enabled: 0, Server/DisabledByDefault: 1	CRITICAL	Win 2016, 2019 and 2022	WAP
4.6.5	Status of TLS 1.1 protocols setting	Server/Enabled: 0, Server/DisabledByDefault: 1	CRITICAL	Win 2016, 2019 and 2022	WAP
4.6.6	Status of SSL 2.0 protocols setting	Server/Enabled: 0, Server/DisabledByDefault: 1	CRITICAL	Win 2016, 2019 and 2022	WAP
4.6.7	Status of SSL 3.0 protocols setting	Server/Enabled: 0, Server/DisabledByDefault: 1	CRITICAL	Win 2016, 2019 and 2022	WAP
4.6.8	Status of TLS 1.2 protocols setting	Server/Enabled: 1, Server/DisabledByDefault: 0	CRITICAL	Win 2016, 2019 and 2022	WAP

(*) Five criticality levels have been defined: minimal, medium, serious, critical, and urgent, from lower to higher level of criticality.

(**) This column represents the type of Windows Server ADFS than be applied to each control.